WIRELESS PENETRATION TESTING & NETWORK RECONNAISSANCE

Hands-on security laboratory | WPA/WPA2 · Airgeddon · Nmap · SMB

Pedro Gonçalves

Technical portfolio | 2026

Ficha Prática 3

Testes de Intrusão em Redes Sem Fios e Footprinting

Alvo: Rede sem fios local (ESSID "raaj") e rede interna de laboratório 192.168.56.0/24 (Windows Server 192.168.56.103)

Campo	**Informação**
Formandos	Pedro Gonçalves;
Módulo / UFCD	Módulos 5, 6 e 7
Data de entrega	16/07/2026
Domínio analisado	N/A — o exercício não incidiu sobre um domínio público (ver "Alvo", acima)
Documento	Parte I – Testes de intrusão em redes sem fios (Airgeddon) e reconhecimento de rede; Parte II – Relatório de footprinting

Este documento integra, num único ficheiro, os trabalhos realizados nos Módulos 5, 6 e 7 do Nível E (Ficha 3): (Parte I) os testes de intrusão em redes sem fios com Airgeddon, complementados por reconhecimento, scanning e enumeração de rede; e (Parte II) o relatório de footprinting elaborado com base nesses resultados, no formato utilizado para apresentação de resultados. Nota: ao contrário de um footprinting estritamente passivo, a Parte I incluiu técnicas activas de intrusão (desautenticação, quebra de chave WPA/WPA2, PMKID e Evil Twin).

Índice

Parte I – Testes de Intrusão em Redes Sem Fios e Reconhecimento de Rede	**4**
Criação das interfaces	4
Identificação do Adaptador Wireless	5
Interface de AP	7
Instalação do serviço hostapd	8
Instalação do Airgeddon no Kali	11
Inicialização do programa Airgeddon	12
Funcionalidades e Instalação/Utilização do Airgeddon	14
Captura de Handshake e Desautenticação	14
Lançar Ataque de Desautenticação	20
Ataque de Dicionário com Aircrack (Handshake WPA)	22
Ataque de Força Bruta com Aircrack (Handshake WPA)	26
Ataque Baseado em Regras com Hashcat (Handshake WPA)	29
Ataque Evil Twin	37
Ataque PMKID	48
Descoberta / Mapeamento de Rede	51
Scanning de Portas (Nmap)	53
Unicornscan / Masscan / Hping3	58
Enumeration — Banner Grabbing e SO	60
SMB	62
RPC / NFS	65
Scripts de Autenticação Genéricos	66
Sniffing (Módulo 6)	67
Parte II – Relatório de Footprinting	**69**
1. Apresentação, Objecto e Metodologia	71
2. Quadro Recapitulativo de Informação	72
3. Recomendações Adicionais	72
4. Entrega / Assinaturas	74
5. Anexos integrados no relatório (Anexos A–E)	75
6. Anexos externos ao relatório	77

1. **Título** — enquadramento no Módulo 5
2. **Objetivo do trabalho** — com citação direta dos objetivos do Módulo 5 (CNCS)
3. **Ambiente de laboratório** — a tua construção com `mac80211_hwsim`, `hostapd`, `wpa_supplicant`
4. **Instalação & modo monitor** — comparando o comando de referência do Módulo 5 com a tua execução no Airgeddon
5. **Captura de Handshake e Desautenticação**
6. **Ataque de Dicionário (Aircrack)**
7. **Ataque de Força Bruta (Aircrack + Crunch)**
8. **Ataque Baseado em Regras (Hashcat)**
9. **Evil Twin + Portal Cativo**
10. **Ataque PMKID** — citando o comando do Módulo 5 (`wifite --pmkid`), assinalado honestamente como "captura pendente de screenshot próprio" (já que ainda não tens essa evidência)
11. **Conclusões** — tabela a mapear cada objetivo do Módulo 5 com a técnica aplicada e o resultado obtido
12. **Referências** — CNCS, Airgeddon, Wifite2, aircrack-ng/hashcat

Testes de Intrusão em Redes Sem Fios

Testes de Intrusão Wireless: Airgeddon

Neste documento é demonstrado como utilizar a ferramenta **airgeddon** para ataques a redes Wi-Fi.
A ferramenta permite a captura de *handshakes* WPA/WPA2 e PMKID, com o objetivo de iniciar ataques de força bruta à chave de acesso Wi-Fi. Adicionalmente, possibilita a criação de um Ponto de Acesso (AP) falso, permitindo a execução de um ataque *Evil Twin* através do aliciamento de clientes para um portal cativo.

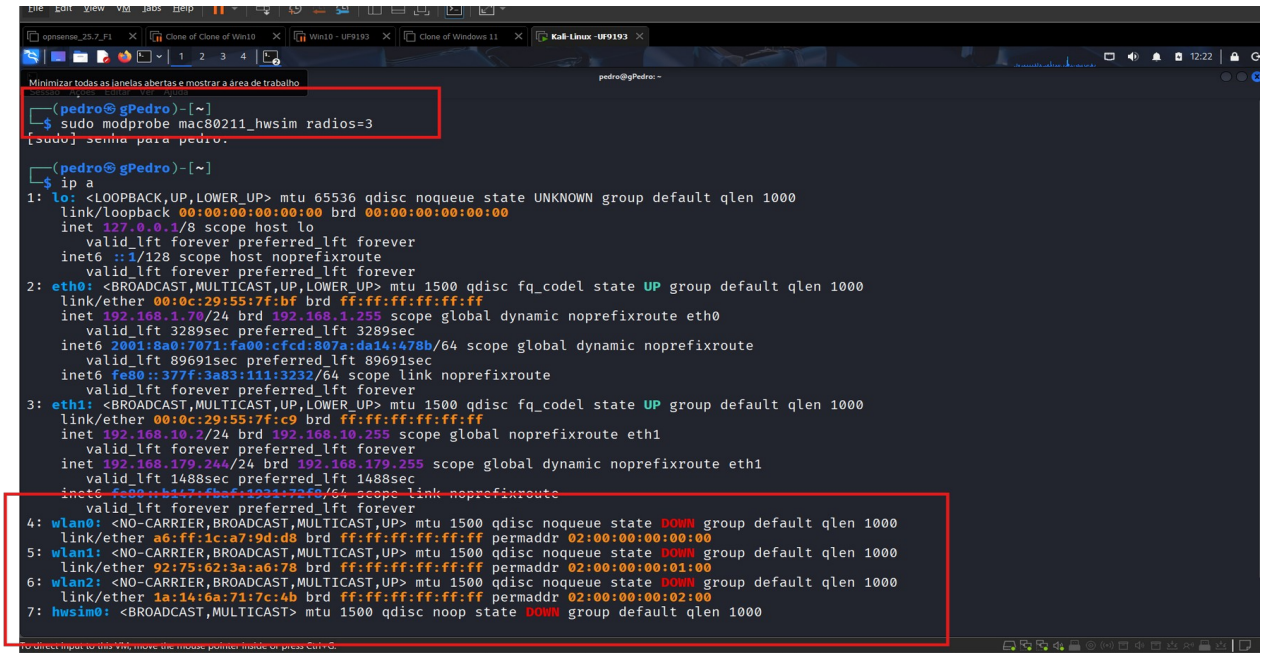
Índice

- Instalação e utilização do Airgeddon
- Captura de Handshake e Desautenticação
- Ataque por dicionário com Aircrack a Handshake WPA
- Ataque por força bruta com Aircrack a Handshake WPA
- Ataque baseado em regras com Hashcat
- Ataque Evil Twin
- Ataque PMKID

Criação das interfaces

Comando : sudo modprobe mac80211_hwsim radios=3

Descrição : “ Carregar o módulo de simulação Wi-Fi do kernel e cria **3 interfaces wireless virtuais** para testes e laboratórios. “

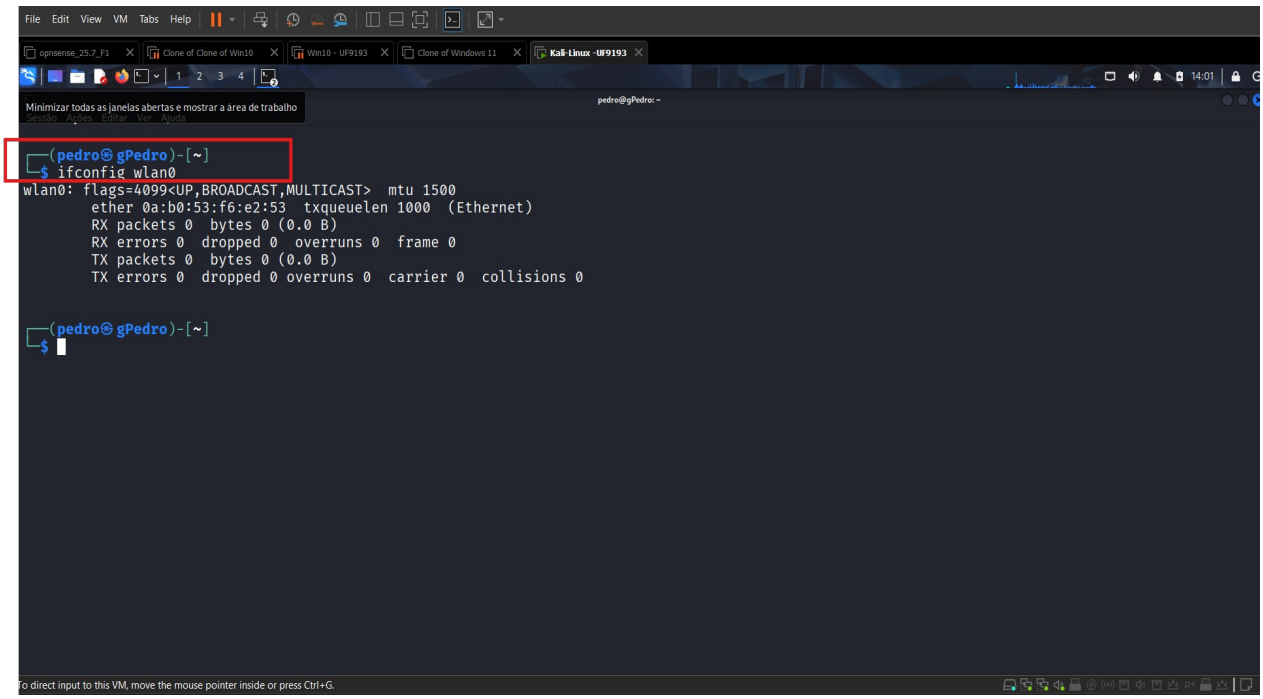


Identificação do Adaptador Wireless

Começa-se por identificar o estado do adaptador wireless através do comando:

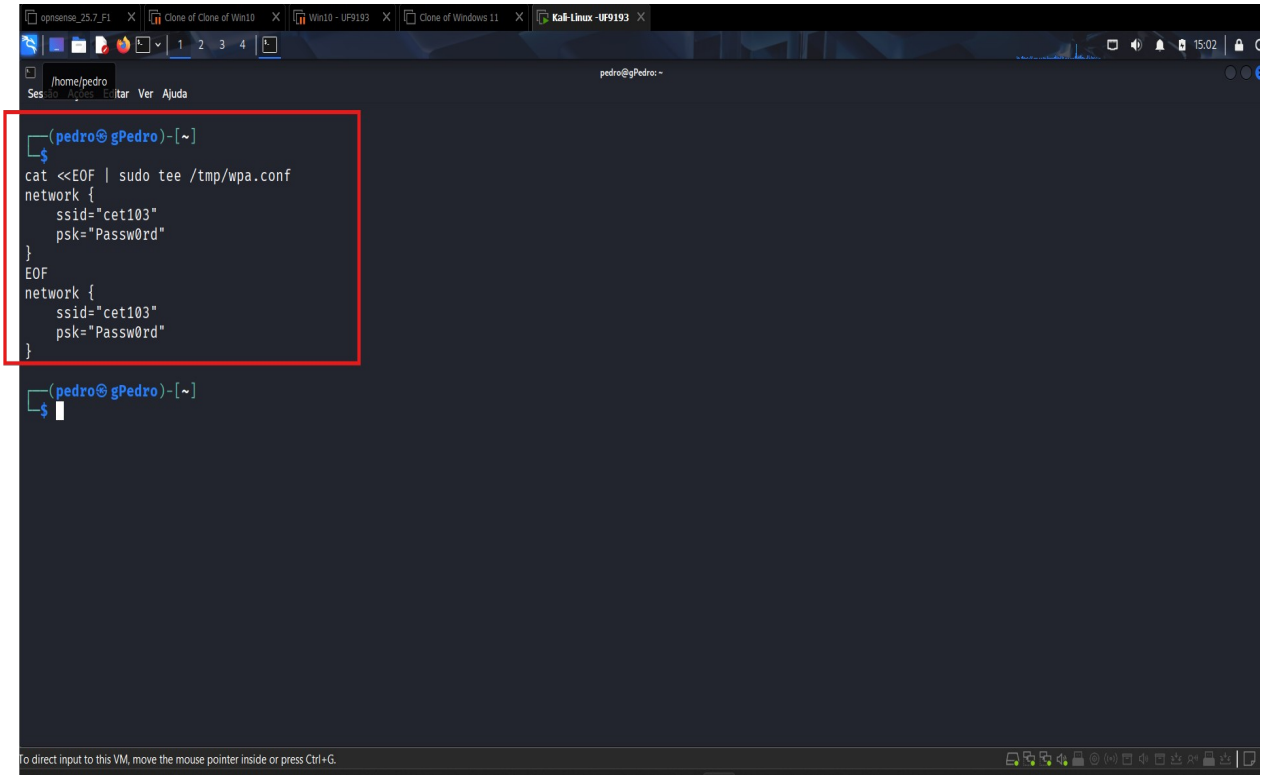
ifconfig wlan0

A interface **wlan0** indica que o modo de ligação Wi-Fi se encontra ativo no sistema



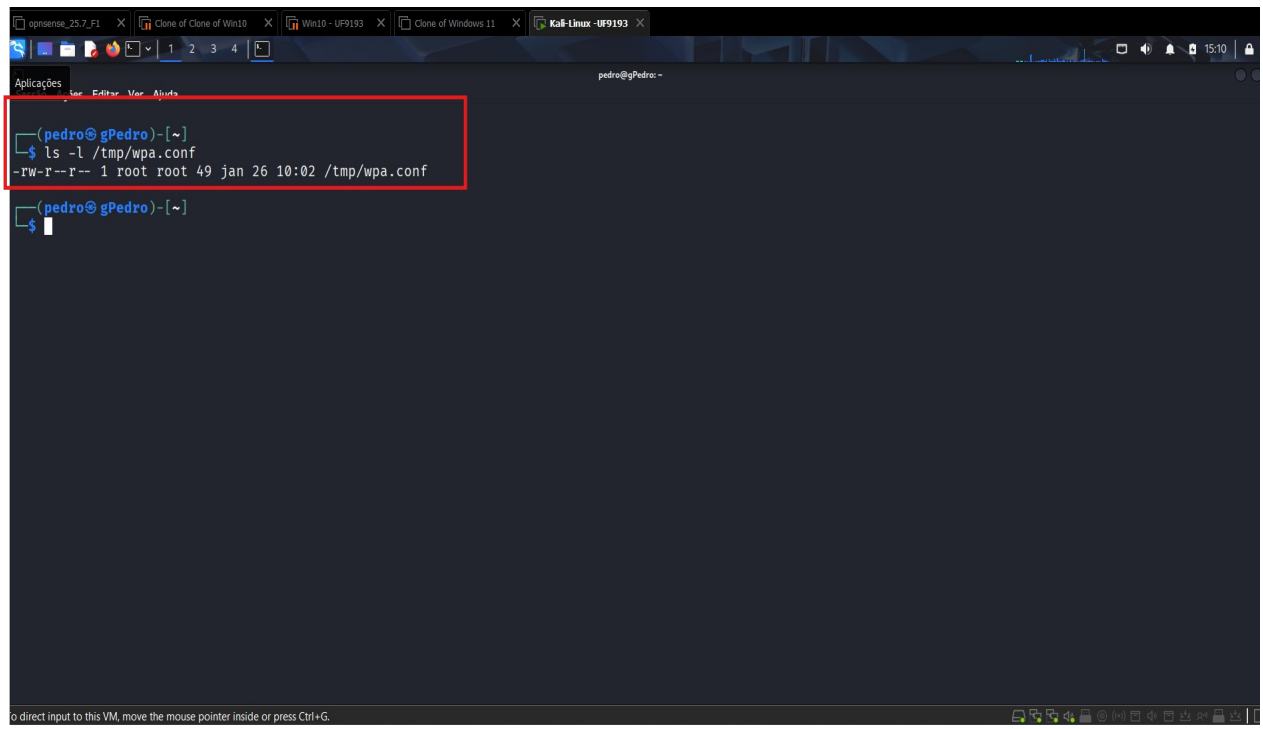
Criação de **um ficheiro de configuração Wi-Fi**, escrevendo o conteúdo indicado com permissões de administrador.

Comando : **cat << EOF | sudo tee /tmp/wpa.conf**



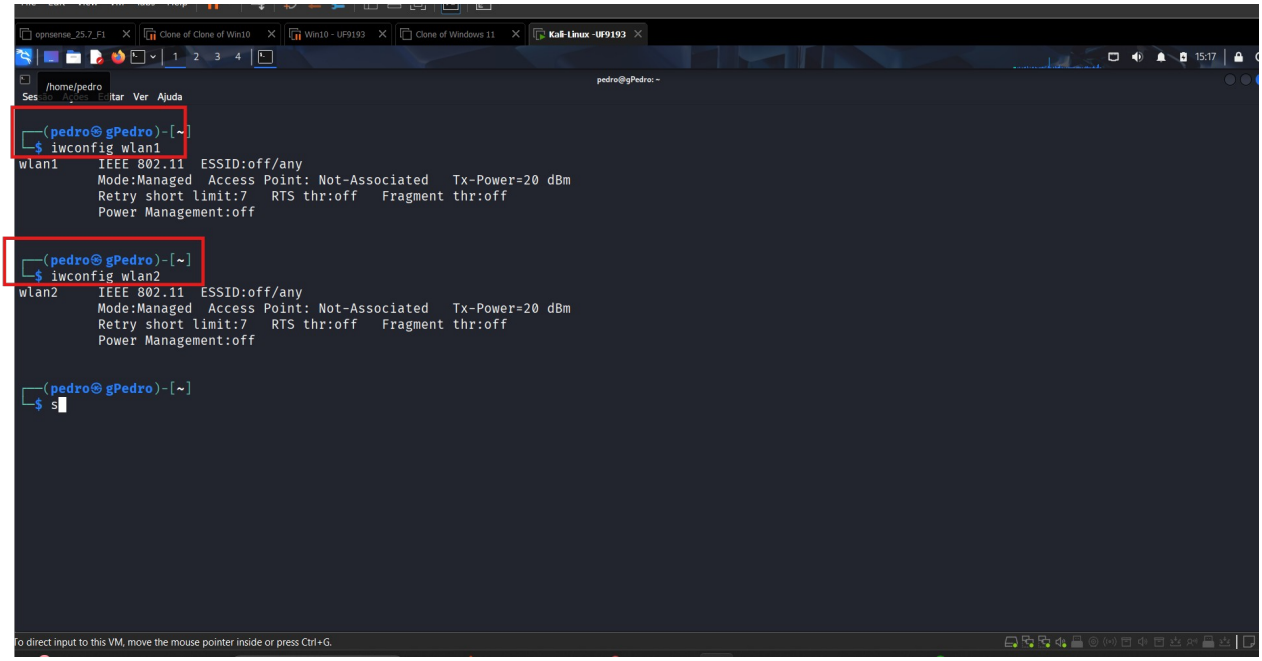
Listar a **informação detalhada** sobre o ficheiro **/tmp/wpa.conf**

Comando : **ls -l /tmp/wpa.conf**



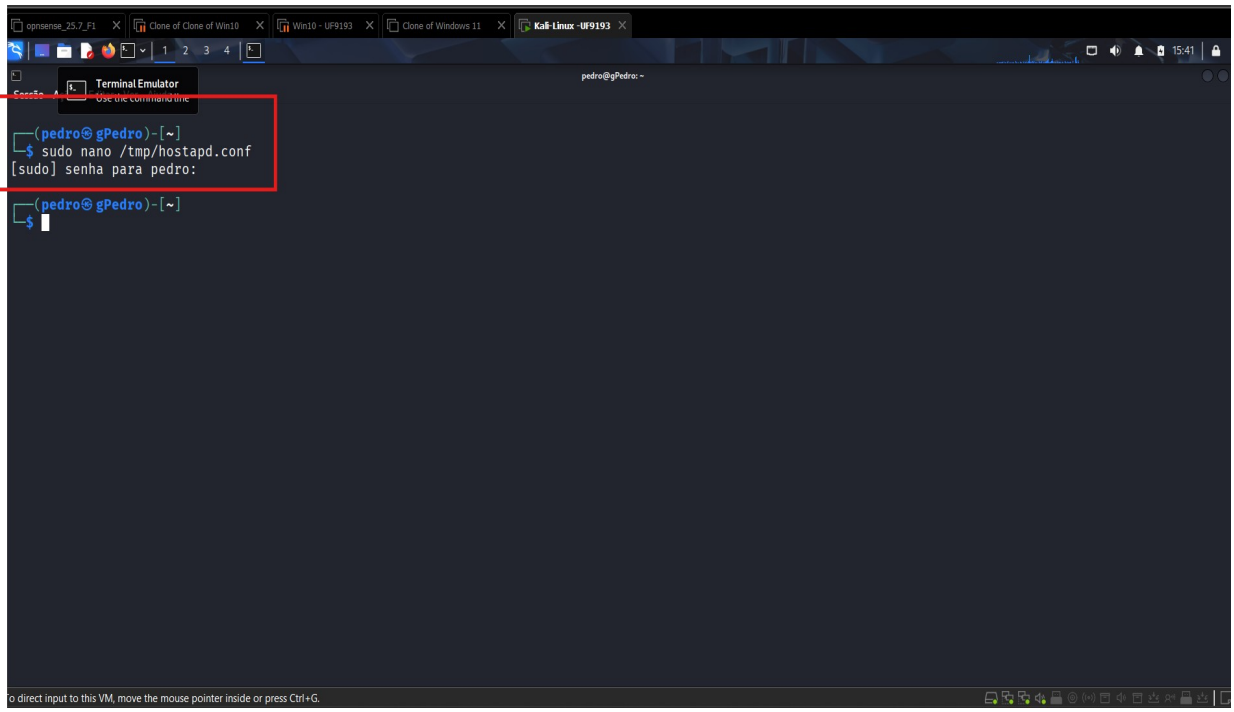
Estado atual da interface Wi-Fi wlan1, wlan2

Comando : iwconfig wlan1 e iwconfig wlan2

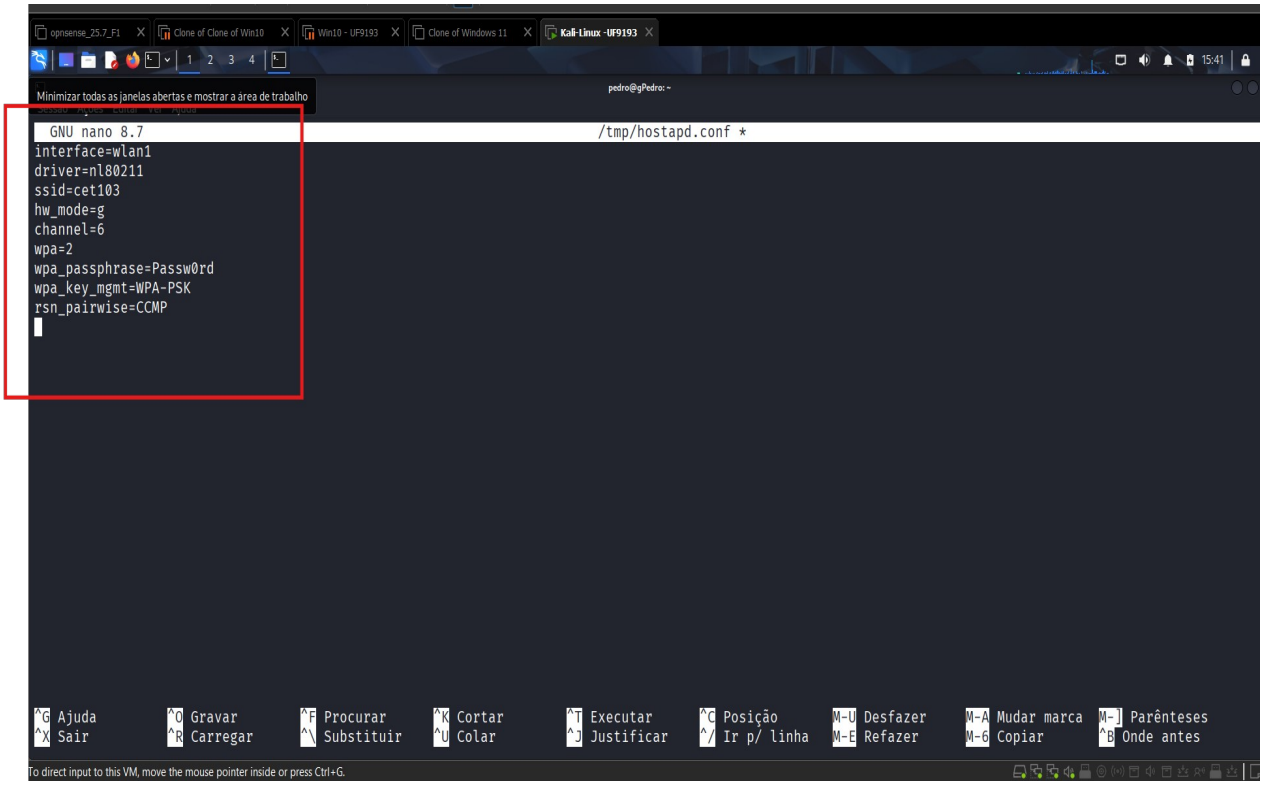


Interface de Ap

Comando : nano /tmp/hostapd.conf

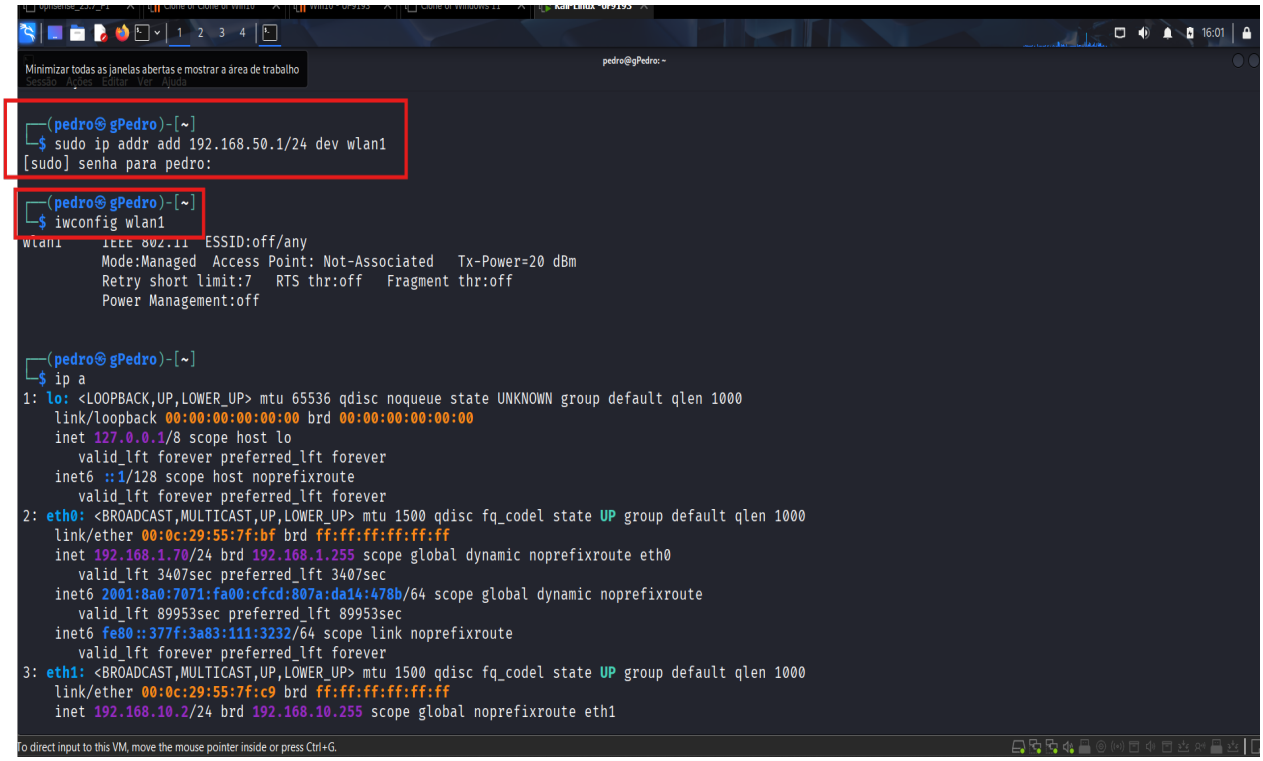


Conteúdo do ficheiro:



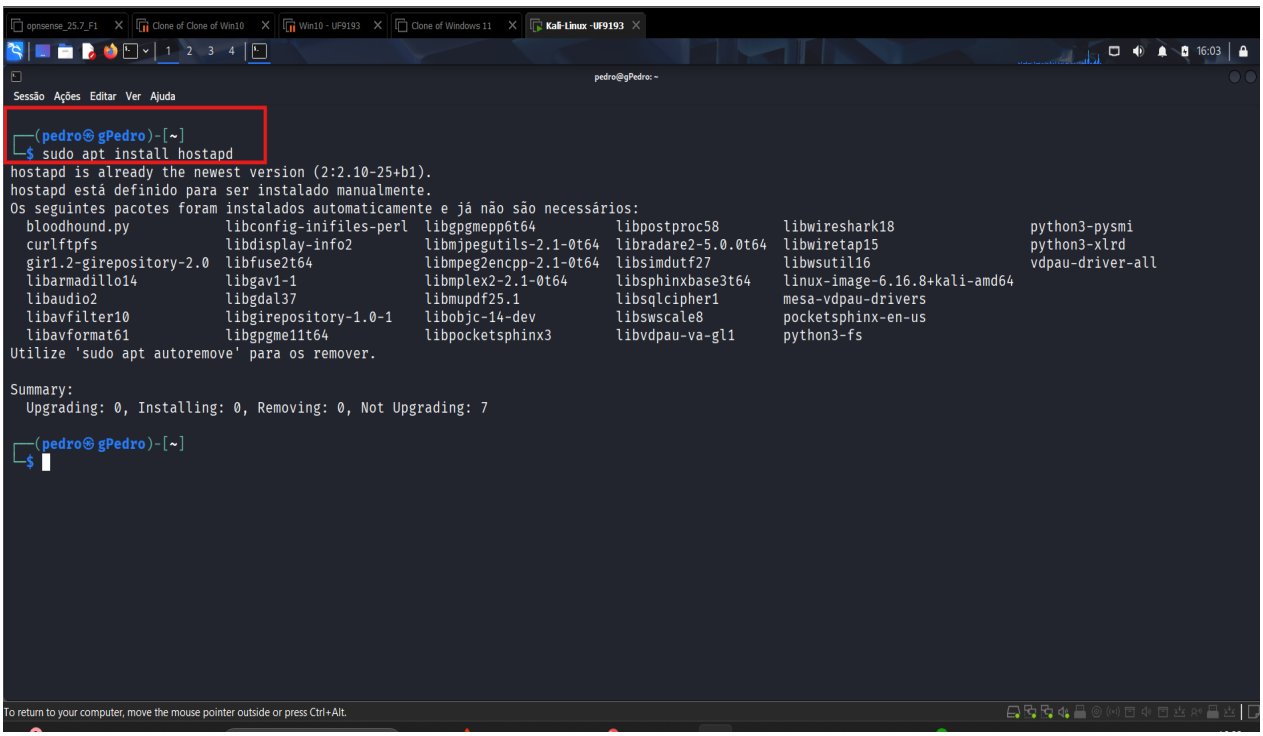
Atribuição do ip ao AP (wlan1)

Comando: **sudo ip addr add 192.168.50.1/24 dev wlan1**



Instalação do serviço hostapd:

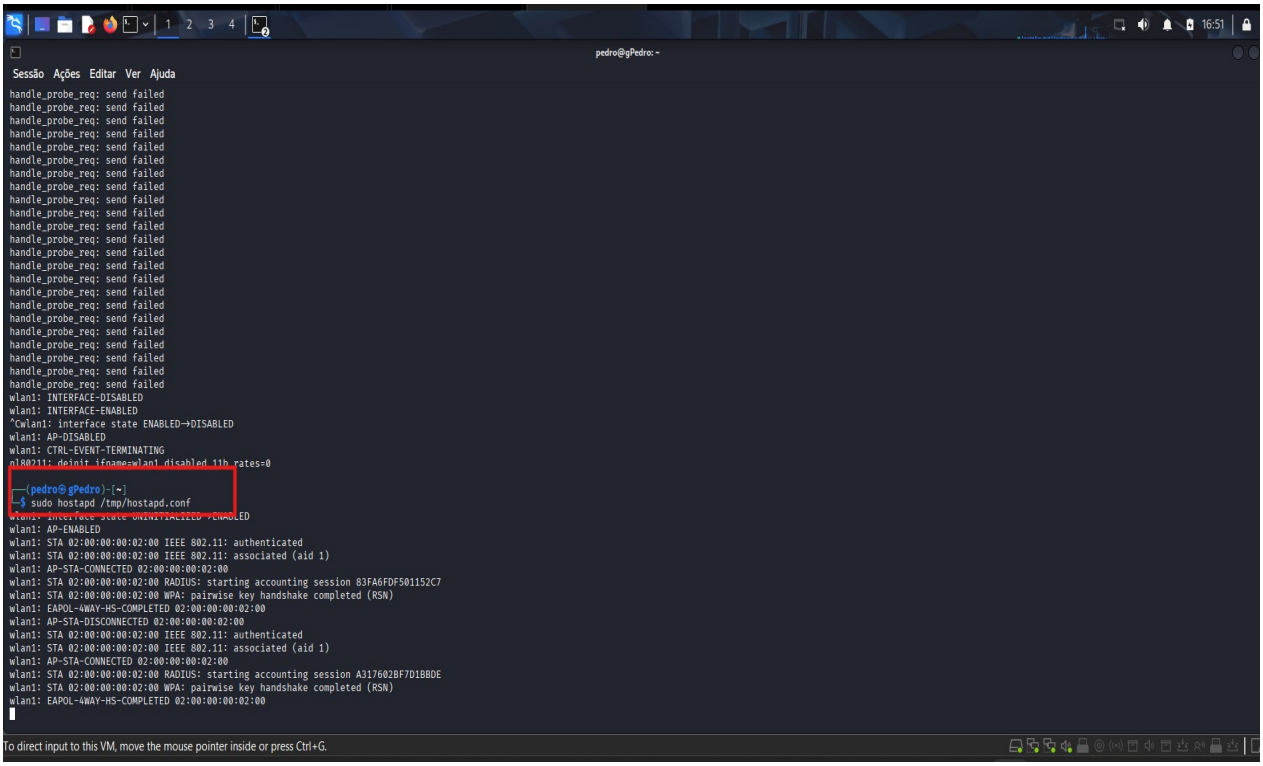
Comando : **sudo apt install hostapd**



Inicializar com o serviço

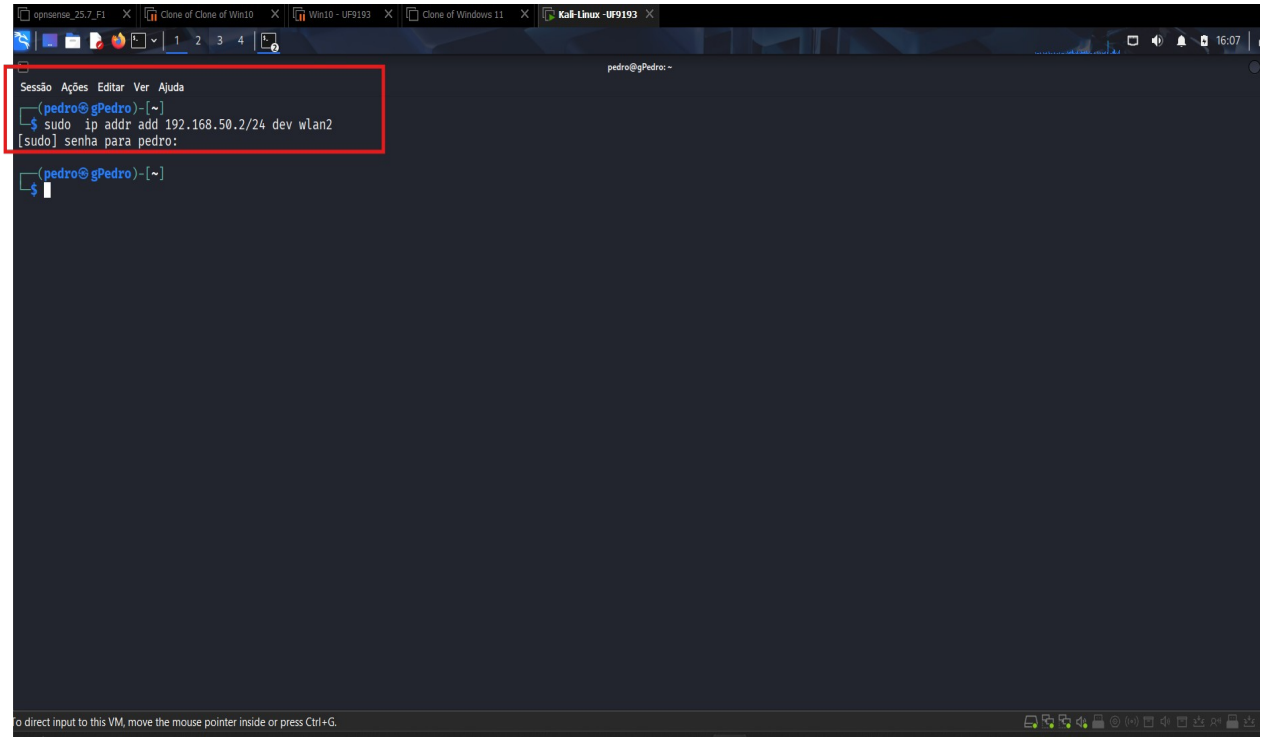
NOTA: o serviço fica à escuta de ligações

Comando : **sudo hostapd /tmp/hostapd.conf**



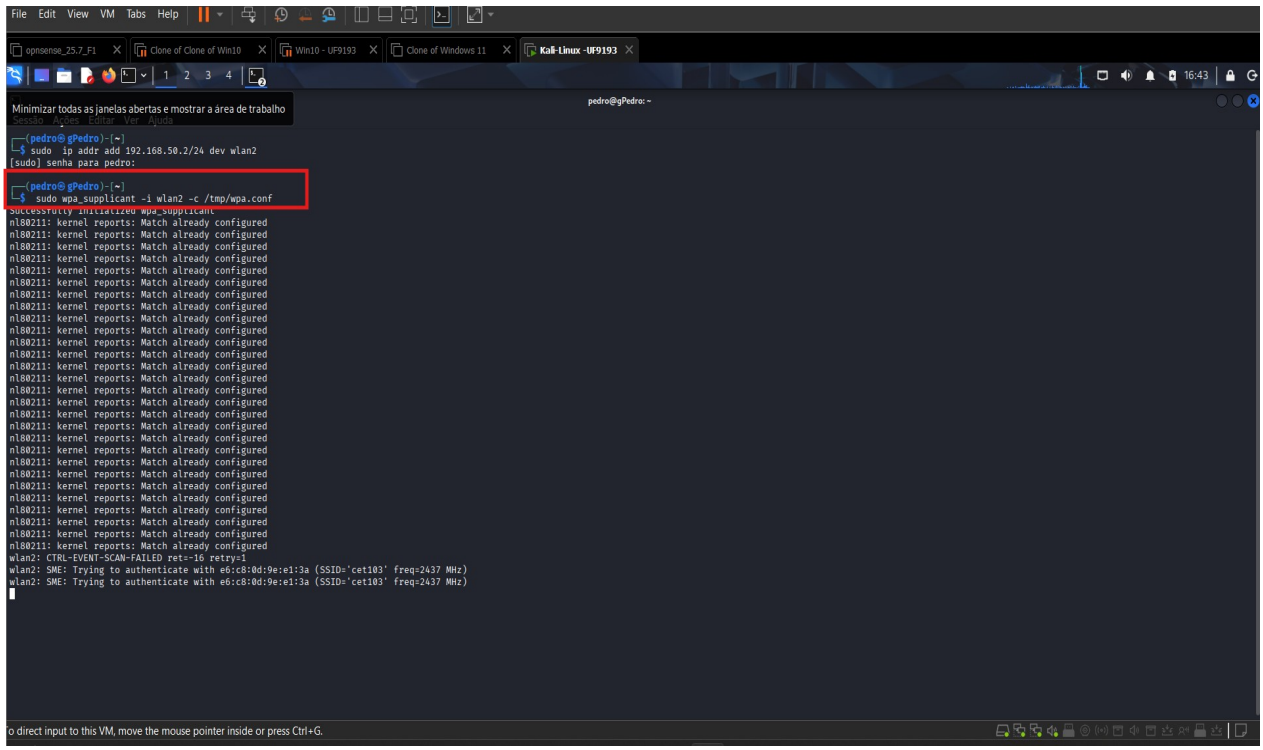
Atribuição de IP ao cliente e estabelcer ligação com o AP

Comando: **sudo ip addr add 192.168.50.2/24 dev wlan2**



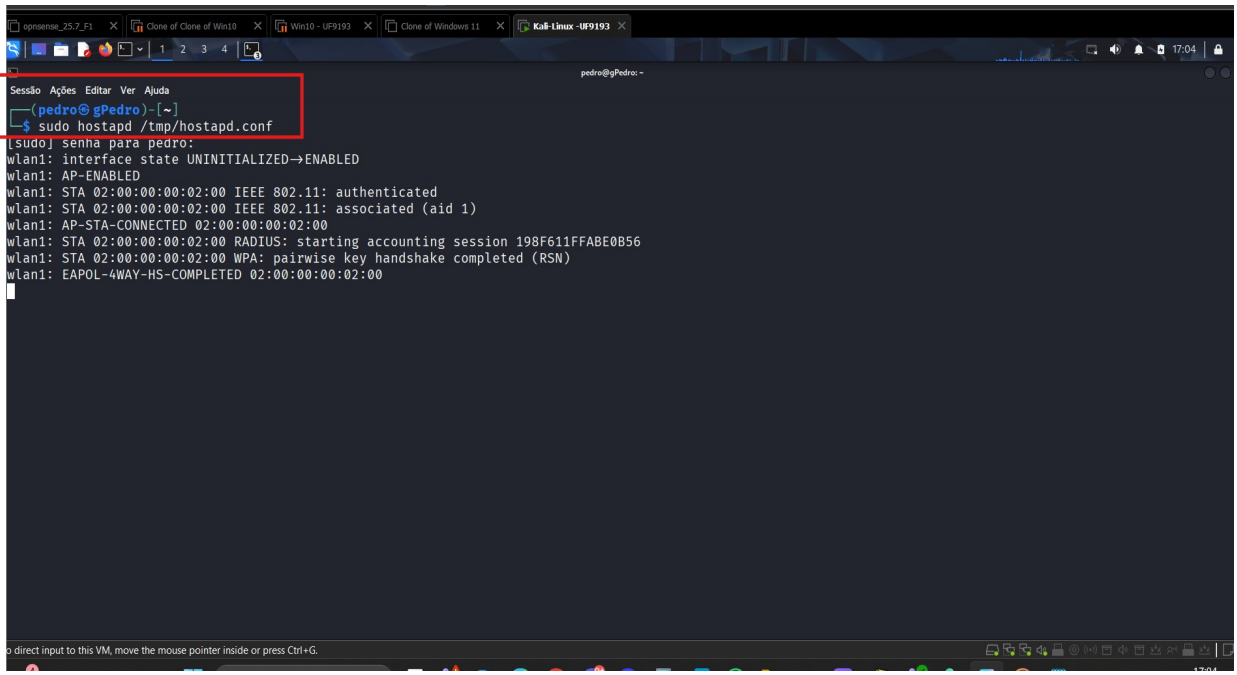
ligar o cliente ao AP

Comando : **sudo wpa_supplicant -i wlan2 -c /tmp/wpa.conf**



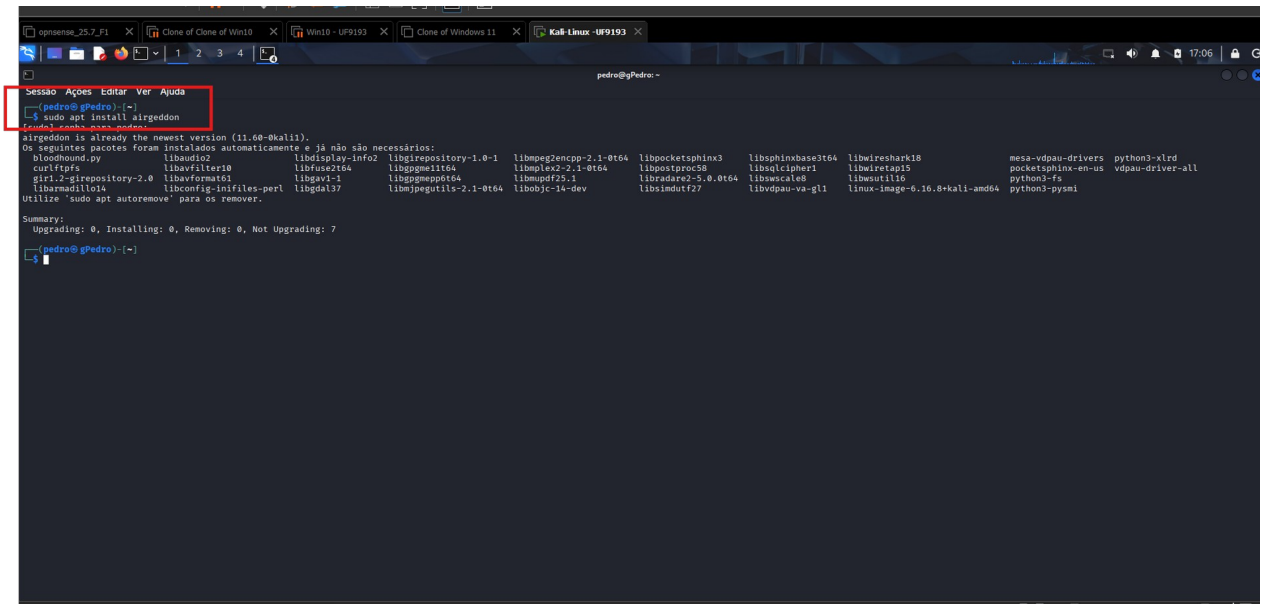
Output do "AP"

Comando : **sudo hostapd /tmp/hostapd.conf**



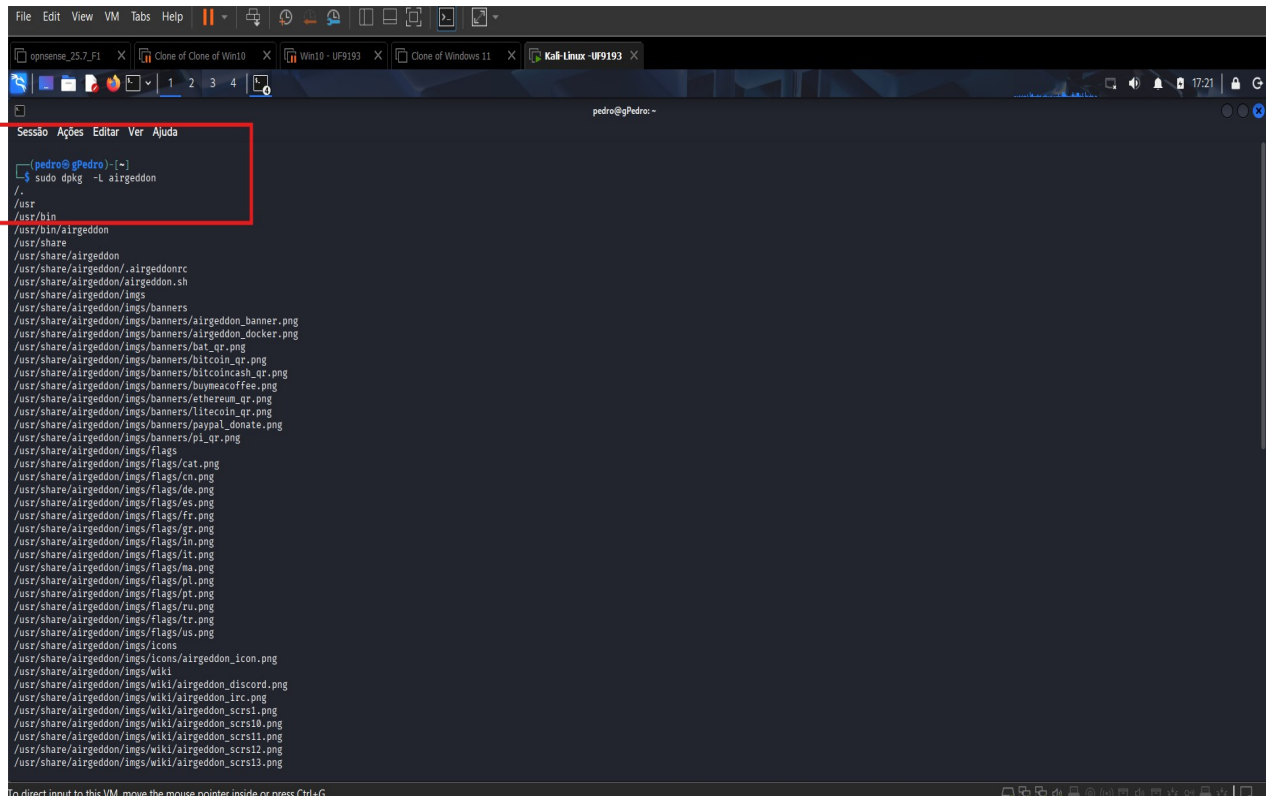
Instalação airgeddon no Kali

Comando : **sudo apt install airgeddon**



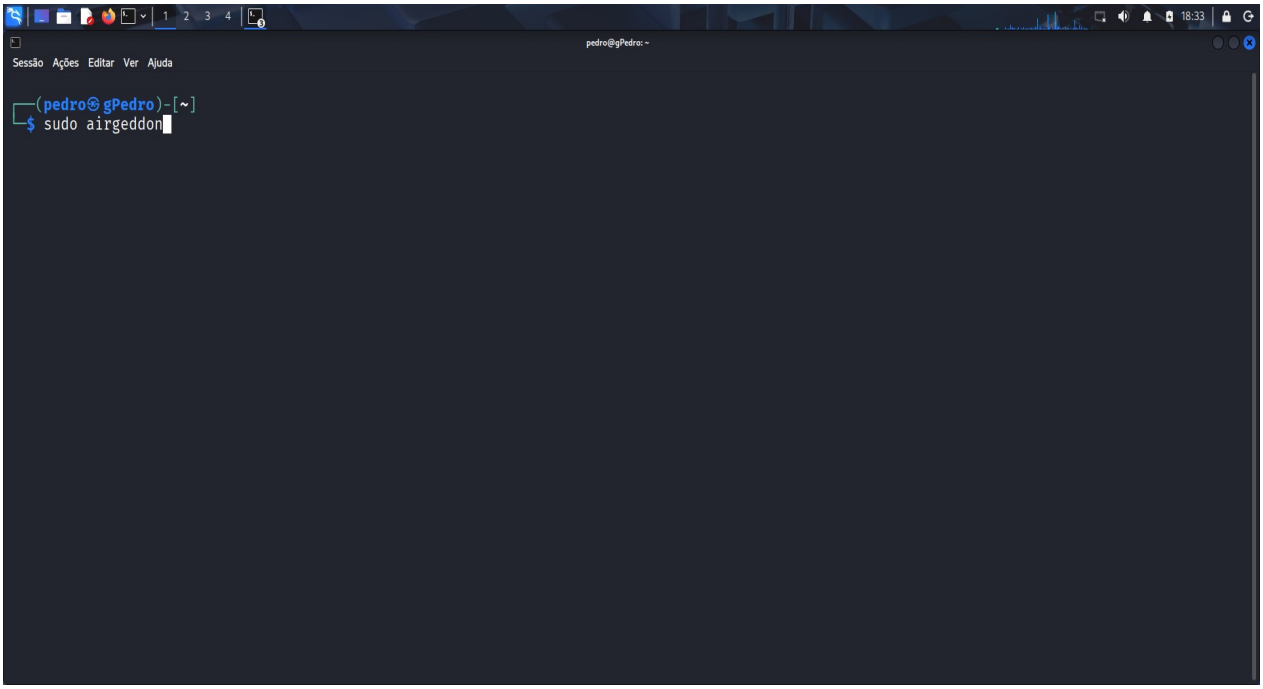
Listagem de todos os ficheiros instalados por um pacote específico –"airgeddon"

Comando : **sudo dpkg -L airgeddon**

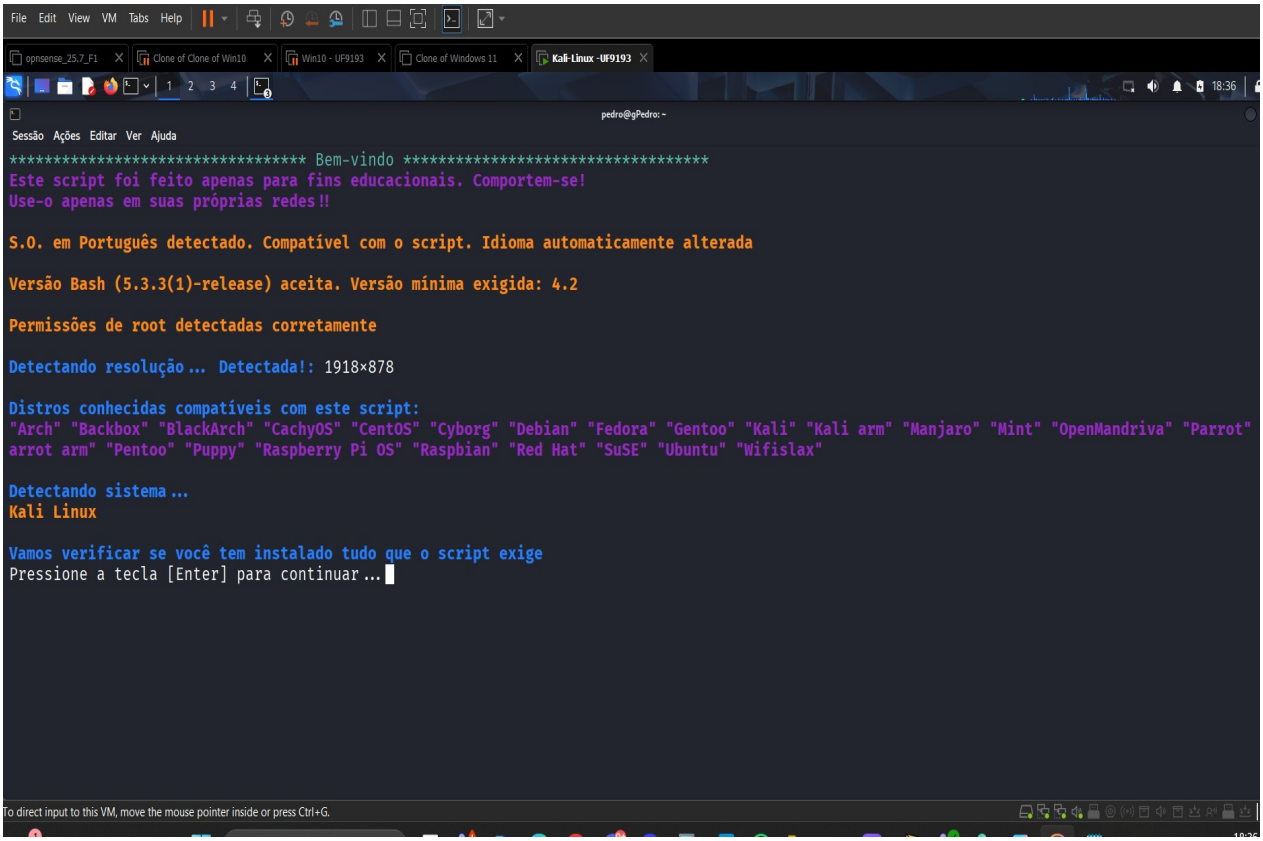


Inicialização do programa "airgeddon"

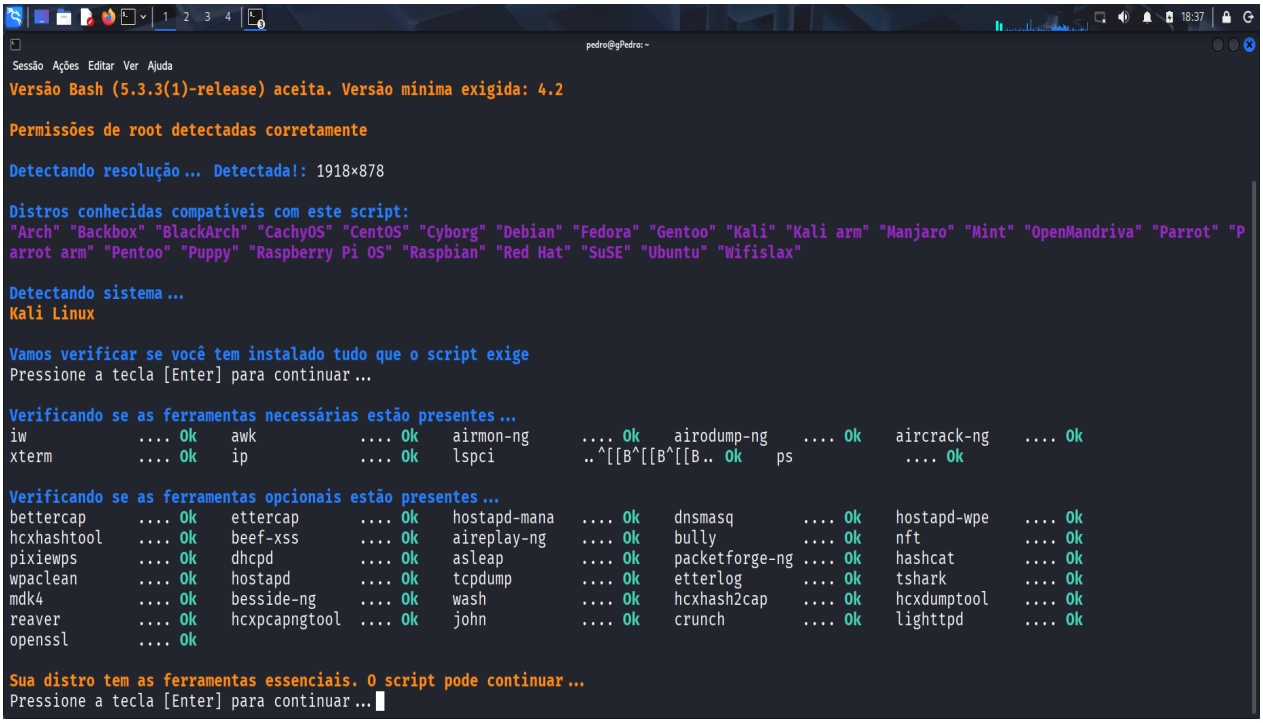
Comando :**sudo airgeddon**



Continuação…



Continuação ...(pressionar “enter” para continuar)



- **Teste de Penetração Wireless**
- **Teste de Penetração Wireless: Airgeddon**
- Está a ser explicado como utilizar o **airgeddon** para ataques a redes Wi-Fi neste artigo. A ferramenta está a permitir a captura de handshakes **WPA/WPA2** e **PMKID**, com o objetivo de iniciar um ataque de força bruta à chave de acesso da rede Wi-Fi. Adicionalmente, está a auxiliar na criação de um **Ponto de Acesso (AP) falso**, possibilitando a execução de um **ataque Evil Twin**, através do aliciamento de clientes para um **portal cativo**.

- **Índice**
  - Instalação e Utilização do Airgeddon
-
  - Captura de Handshake e Desautenticação
  - Ataque por Dicionário com Aircrack ao Handshake WPA
  - Ataque de Força Bruta com Aircrack ao Handshake WPA
  - Ataque Baseado em Regras com Hashcat ao Handshake WPA
  - Ataque Evil Twin
  - Ataque PMKID

Inicialização pela identificação do estado do adaptador wireless, através da execução do comando ifconfig wlan0. A interface **wlan0** está a indicar que o modo de ligação Wi-Fi se encontra ativo na máquina

Instalação e Utilização do Airgeddon

Comando : sudo apt install airgedon

Funcionalidades do Airgeddon:

• Suporte completo para as bandas 2.4 GHz e 5 GHz
• Captura assistida de ficheiros de handshake WPA/WPA2 (redes pessoais) e PMKID
• Comutação do modo da interface (Monitor ↔ Managed)
• Desencriptação offline de palavras-passe WPA/WPA2 a partir de ficheiros capturados (handshakes e PMKIDs) em redes pessoais, utilizando ataques por dicionário, força bruta e baseados em regras, recorrendo às ferramentas aircrack, crunch e hashcat
• Desencriptação de palavras-passe de redes Enterprise, com base nas ferramentas john the ripper, crunch, asleap e hashcat
• Ataques Evil Twin (AP rogue / ponto de acesso malicioso)
• Funcionalidades WPS

Download e execução do Airgeddon

Executar o download e a execução do script airgeddon através dos seguintes comandos em Kali Linux.
Nota: o script deve ser executado como root ou superutilizador**.**

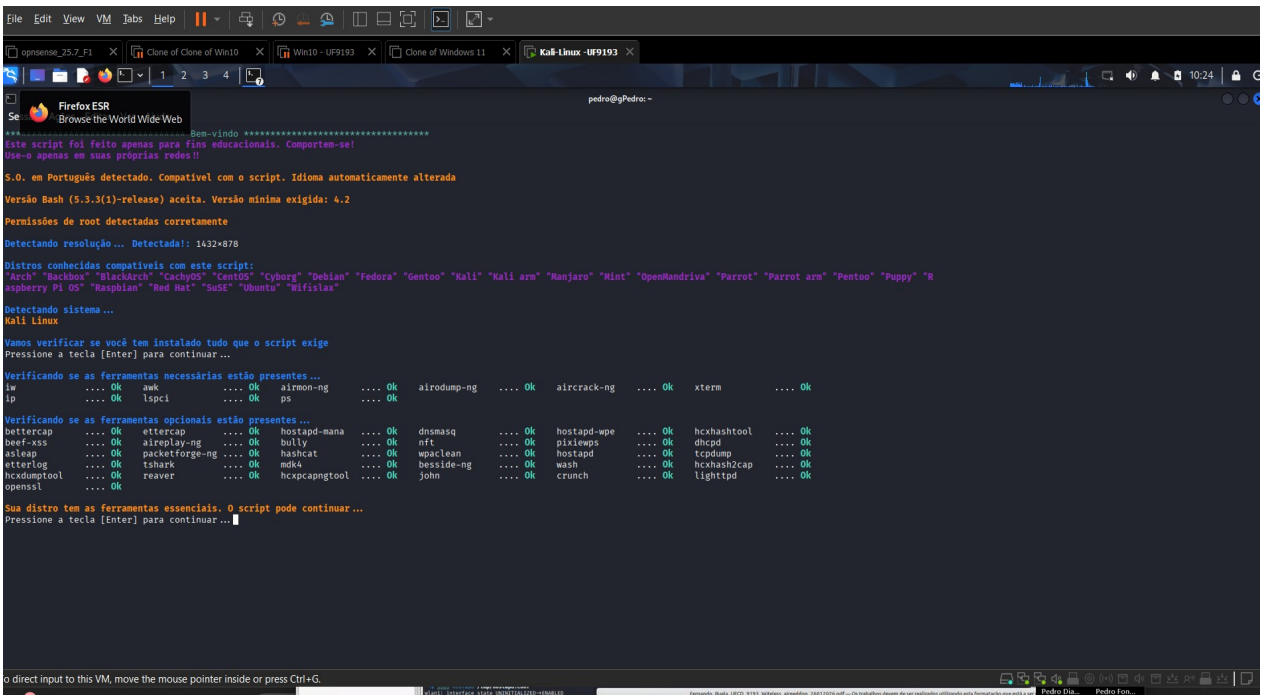
Instalação Opcional

git clone https://github.com/v1s1t0r1sh3r3/airgeddon.git

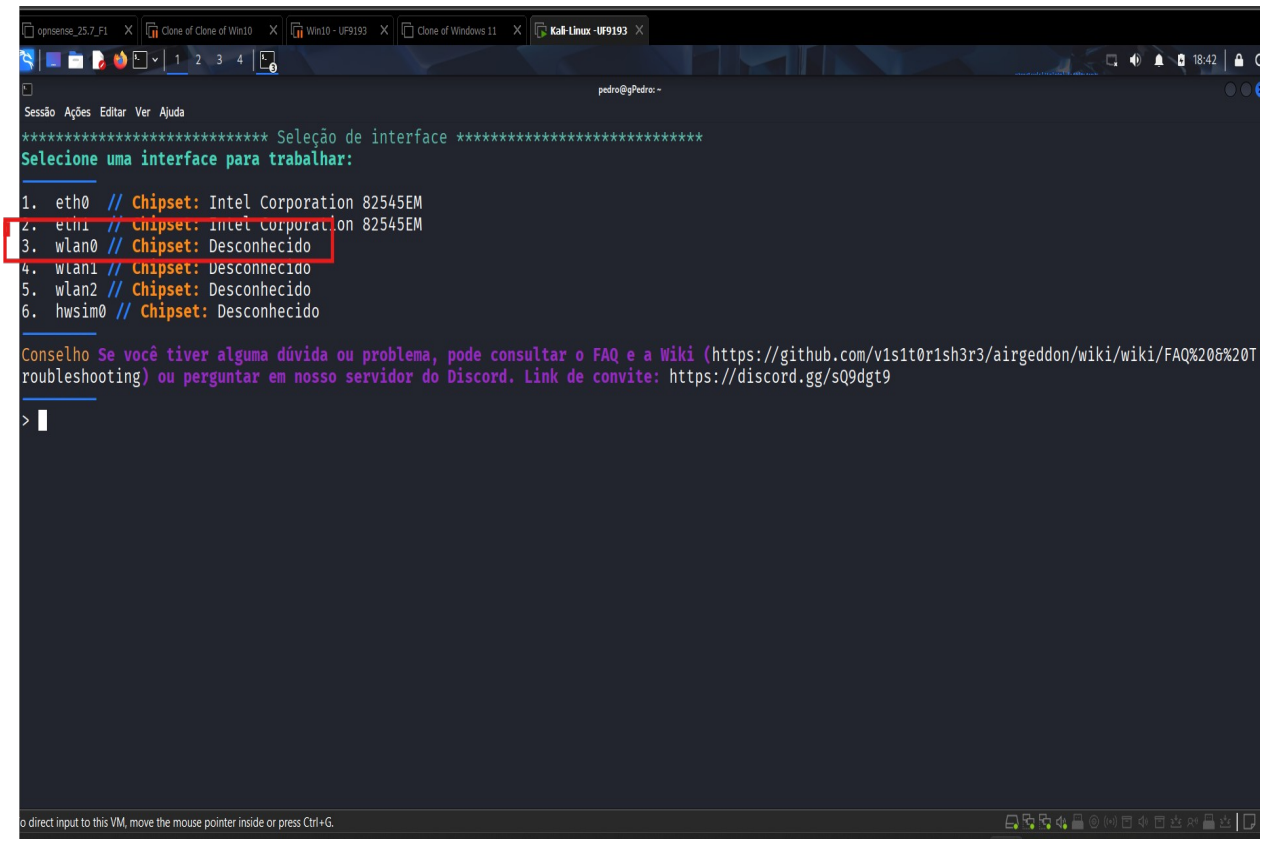
cd airgeddon

./airgeddon.sh

Inicialmente, o framework inicia todas as dependências e ferramentas necessárias antes de ser iniciado. Caso alguma esteja em falta, está a ser tentada a sua instalação automática, o que poderá demorar algum tempo.
Conforme indicado, após a conclusão da instalação, está a ser apresentado o estado OK tanto para as ferramentas obrigatórias como para as opcionais.



De seguida, está-se a selecionar a **interface de rede**. Para uma ligação **wireless**, a interface utilizada é a **wlan0**; deste modo, está-se a escolher a opção 3, conforme apresentado na imagem.

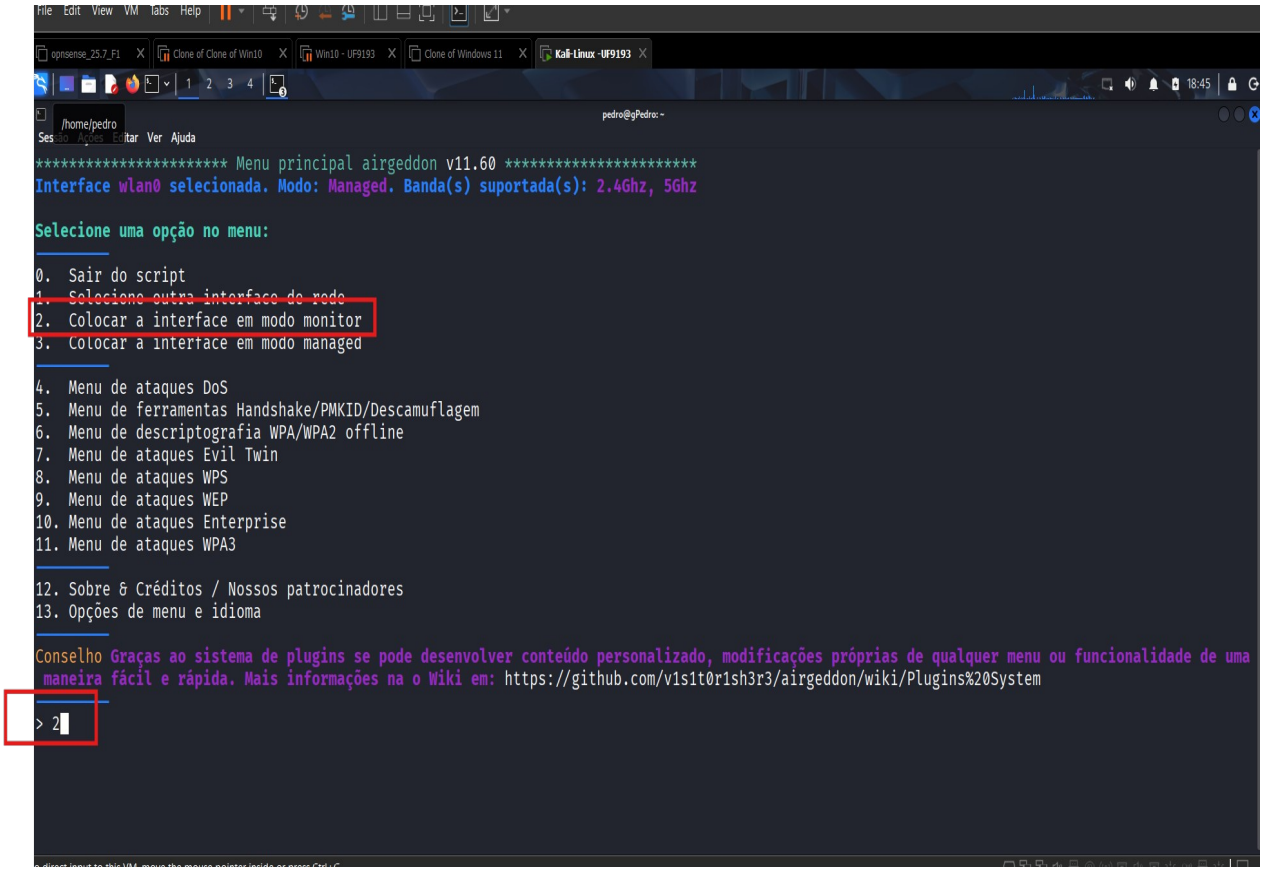


De seguida, coloca-se a placa Wi-Fi em modo monitor. Por defeito, a placa encontra-se em modo managed, o que significa que não é possível capturar pacotes de várias redes. No entanto, uma interface Wi-Fi em modo monitor consegue capturar pacotes que estão a circular no ar.

Está-se a selecionar a opção 2 para ativar o modo Monitor.

Nota:

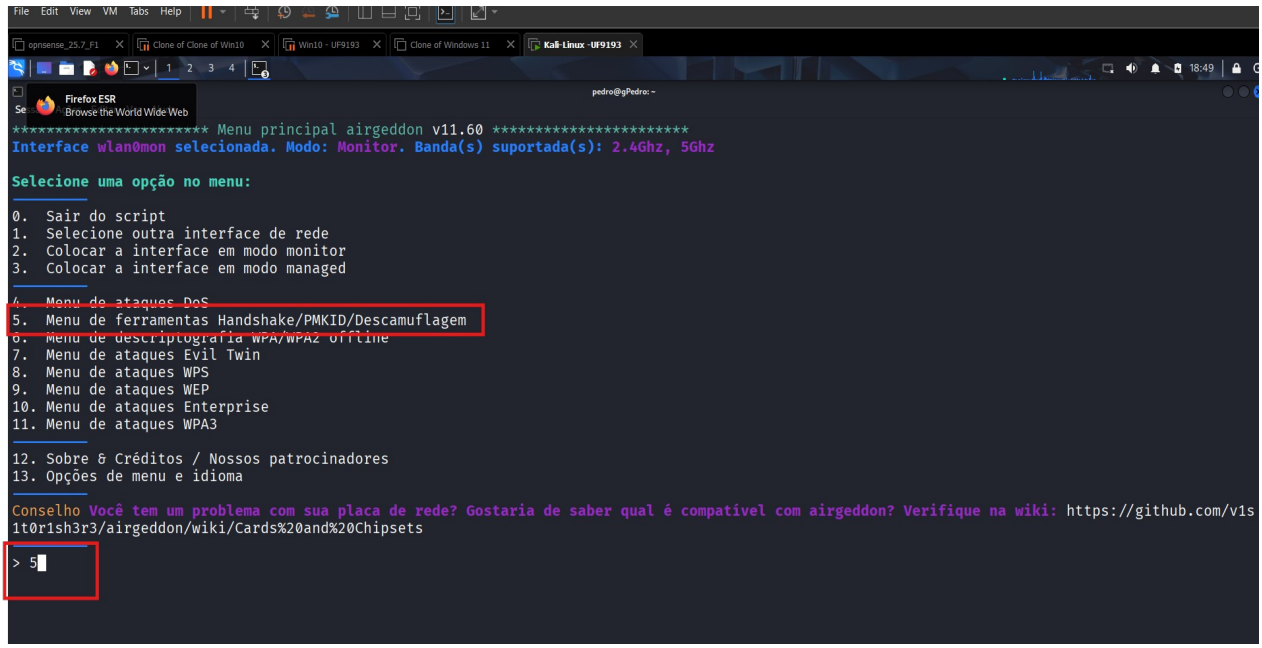
O modo monitor é o modo utilizado para a monitorização de tráfego, normalmente num canal específico. Uma grande parte do hardware wireless possui capacidade para entrar em modo monitor, mas essa funcionalidade depende do suporte do driver da placa de rede.
Desta forma, em Linux é possível forçar muitas placas a entrarem em modo monitor; já em Windows, geralmente é necessário desenvolver ou utilizar um driver específico para que a placa wireless suporte este modo.



Captura de Handshake e Desautenticação

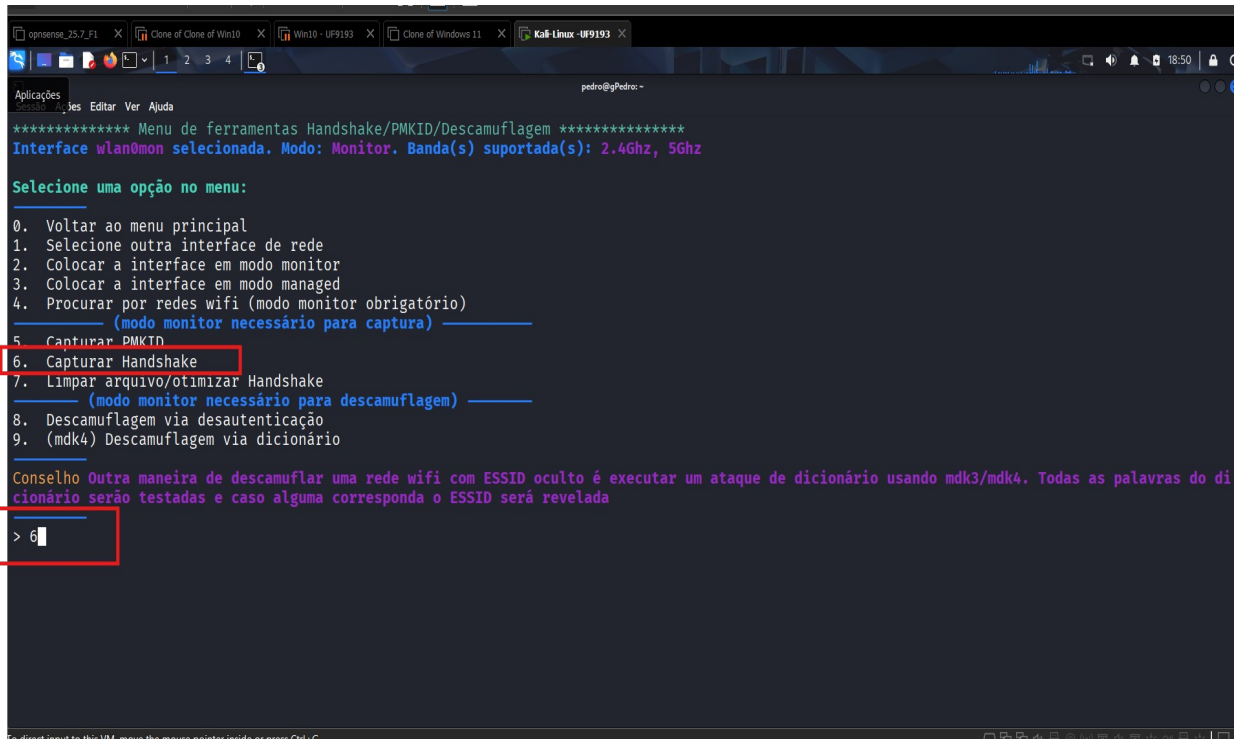
A interface **wlan0mon** encontra-se em **modo monitor**, pelo que está-se a proceder à captura de pacotes de **handshake** da rede wireless, no âmbito dos protocolos **WPA** e **WPA2**.

Para obter a ferramenta destinada à **captura de Handshake/PMKID**, está-se a selecionar a **opção 5**.

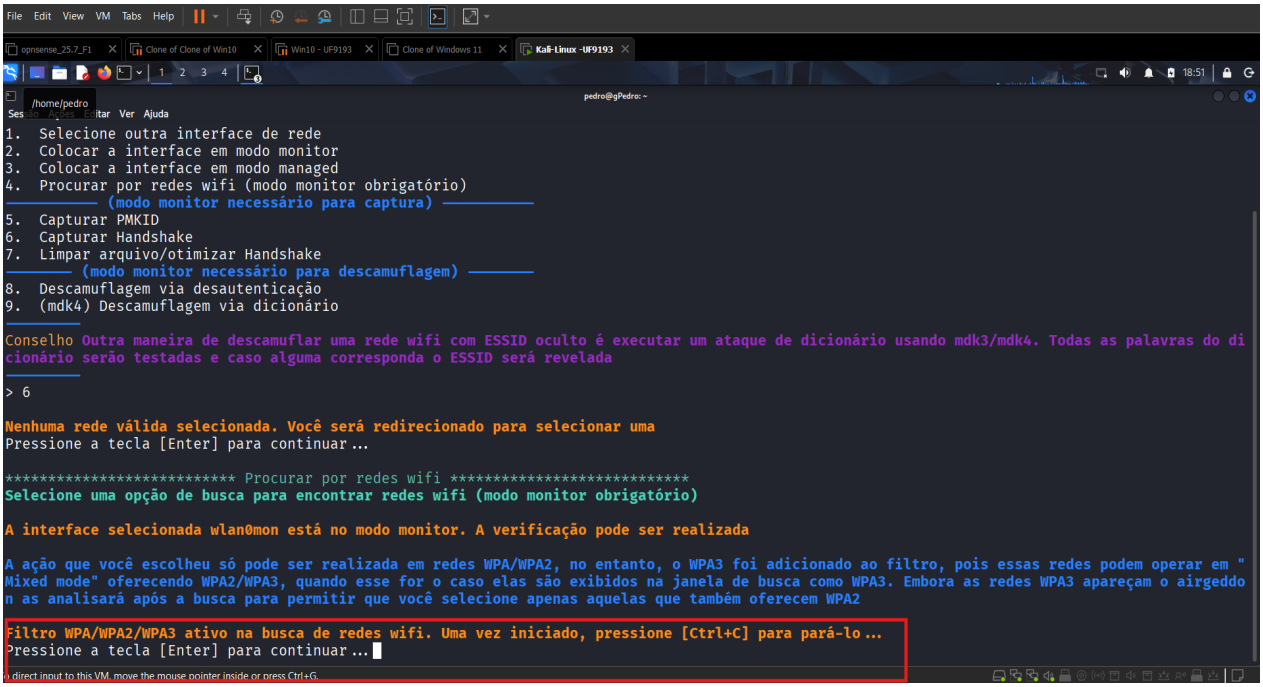


Seleção da opção 6 para proceder à captura do handshake.

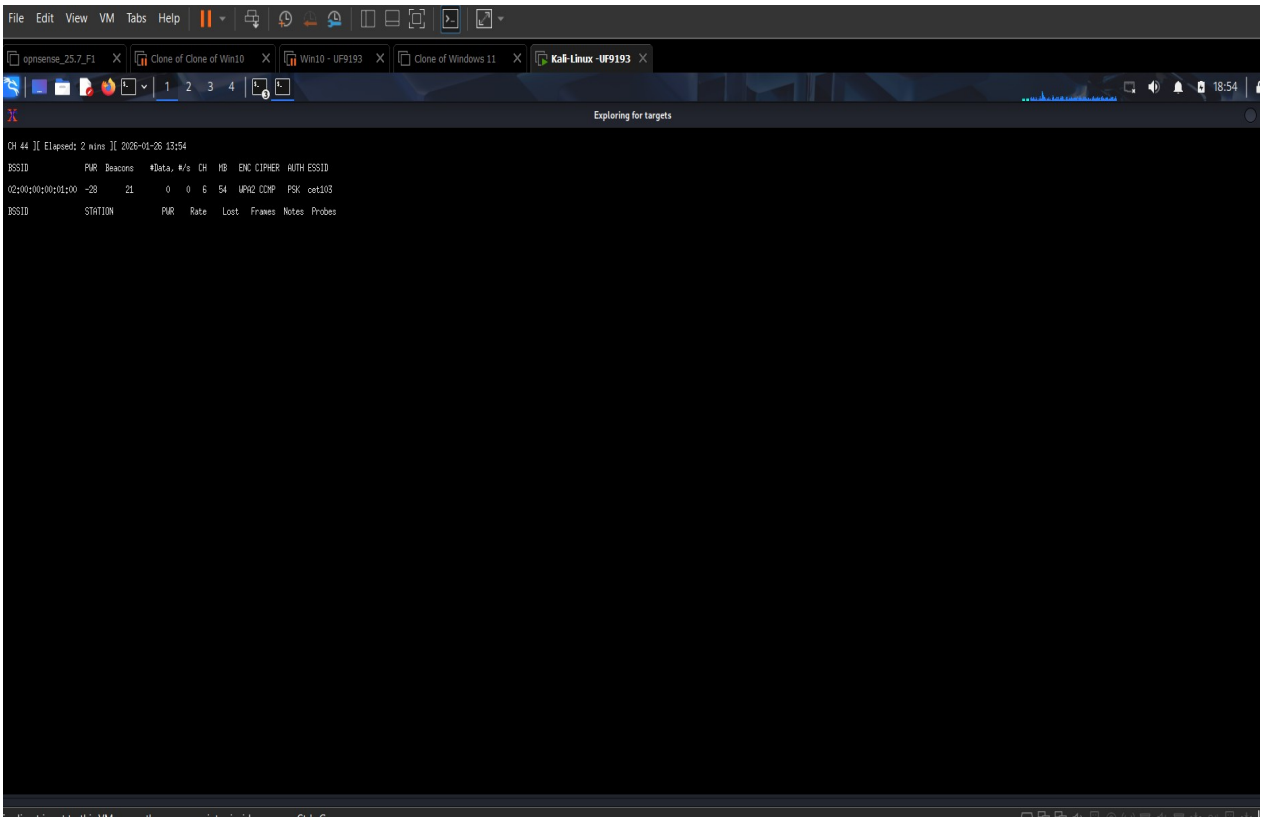
Ao selecionar a opção 6, está a ser aberta uma nova janela, onde está a ser efetuado o scan de redes WPA e WPA2, com o objetivo de capturar o 4-way handshake para um ficheiro .cap.
Após ser identificado o AP (Access Point) alvo, pode ser utilizado CTRL + C para interromper o processo



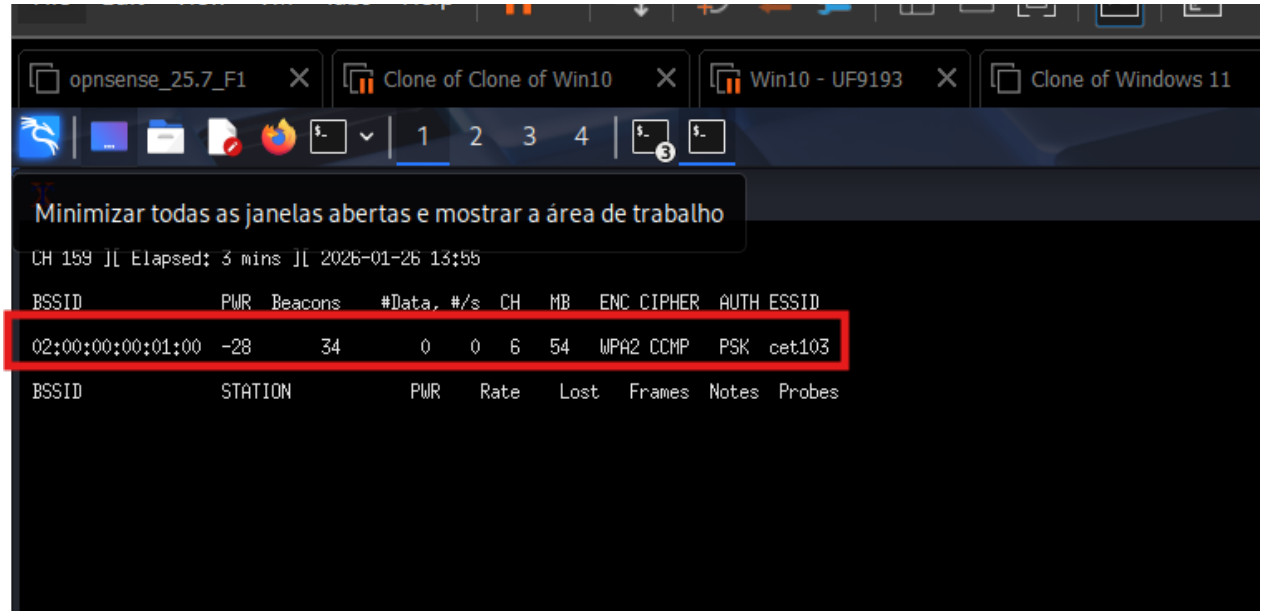
Continuação ...



Resultado:



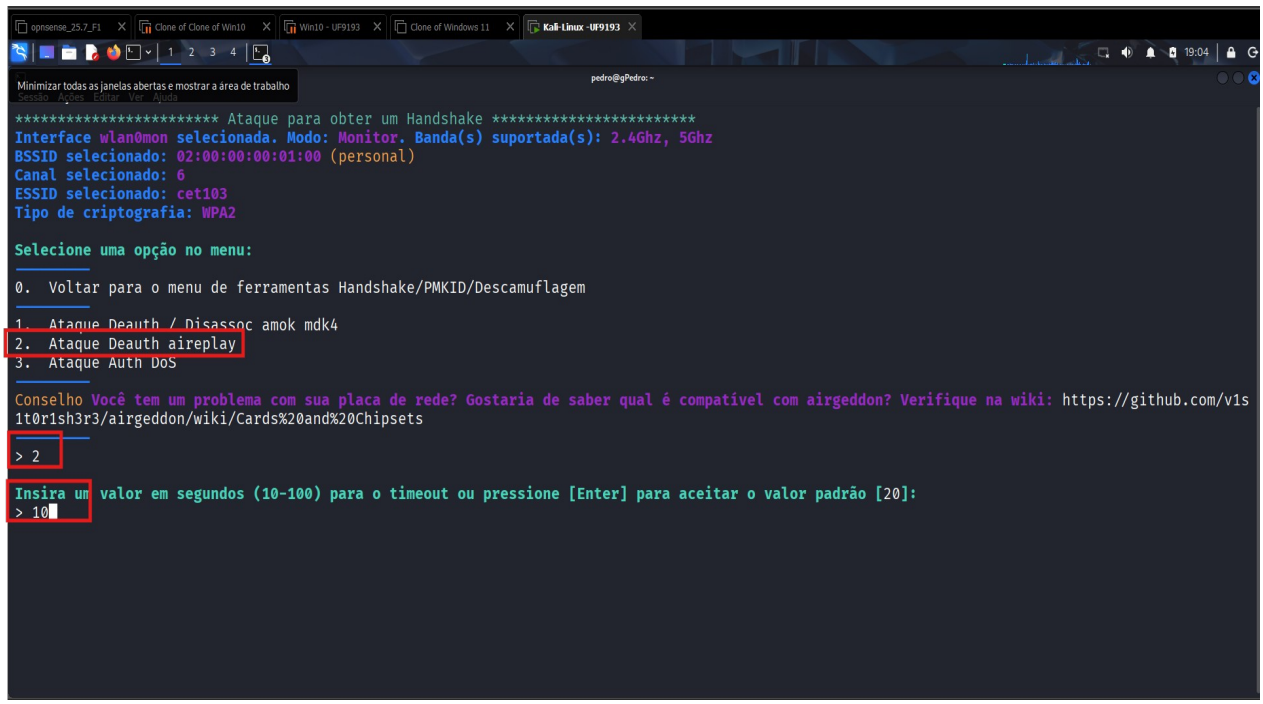
Amplificado :



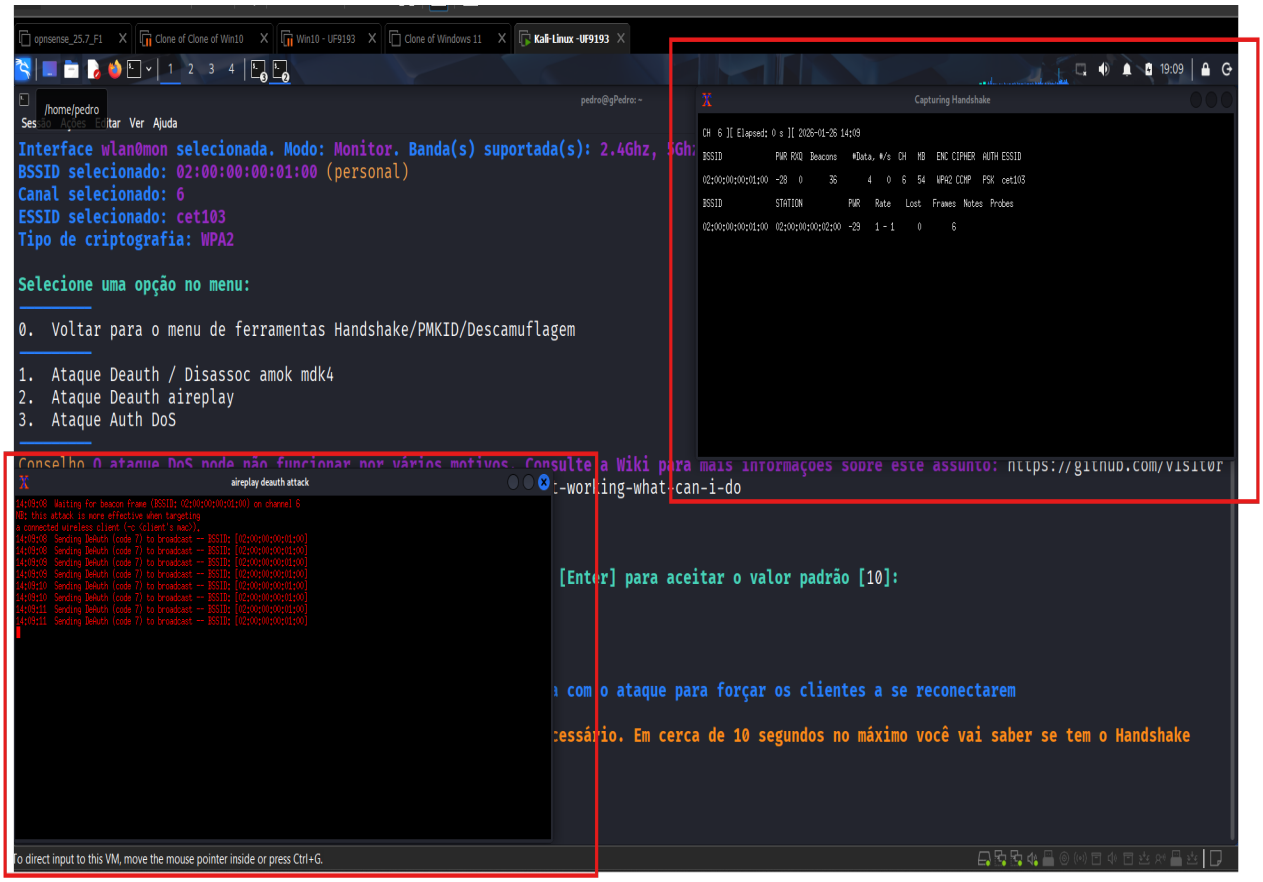
Será apresentada uma lista com todos os ESSIDs (nomes das redes Wi-Fi) analisados, bem como os respetivos BSSID (endereços MAC) e o tipo de protocolo de encriptação (ENC).
De seguida, tal como foi feito para o ESSID "Raaj", o alvo pode ser selecionado através da introdução do respetivo número de série.

Nota:
Os asteriscos (*) indicam pontos de acesso com clientes ligados; estes são, geralmente, os melhores "clientes" para a obtenção de handshakes. Qualquer Access Point que utilize o protocolo de encriptação WEP será ignorado pelo Airgeddon.

Lançar Ataque de Desautenticação
Este ataque envia pacotes de desassociação para um ou mais clientes que se encontram atualmente associados a um determinado ponto de acesso. A desassociação dos clientes pode ser realizada por vários motivos:
• Recuperação de um ESSID oculto – trata-se de um ESSID que não está a ser difundido (broadcast). Outro termo utilizado é "cloaked".
• Captura de *handshakes* WPA/WPA2, forçando os clientes a reautenticar-se.
• Geração de pedidos ARP (clientes Windows, por vezes, limpam a cache ARP quando são desligados).
De seguida, será solicitado que se selecione o tipo de ataque; está-se a escolher a opção 2, correspondente ao ataque de *Deauth Replay*, que irá utilizar um ataque de desautenticação para desligar todos os clientes antes de capturar o *handshake* entre o AP e o cliente.
Posteriormente, para o timeout, seleciona-se um período de 10 segundos.



Será possível observar o aparecimento de **duas janelas**. Após a **desautenticação**, uma delas estará a executar o **ataque de deauth**, enquanto a outra estará a tentar **registar o 4-way handshake** entre o **cliente** e o **ponto de acesso (AP)**.

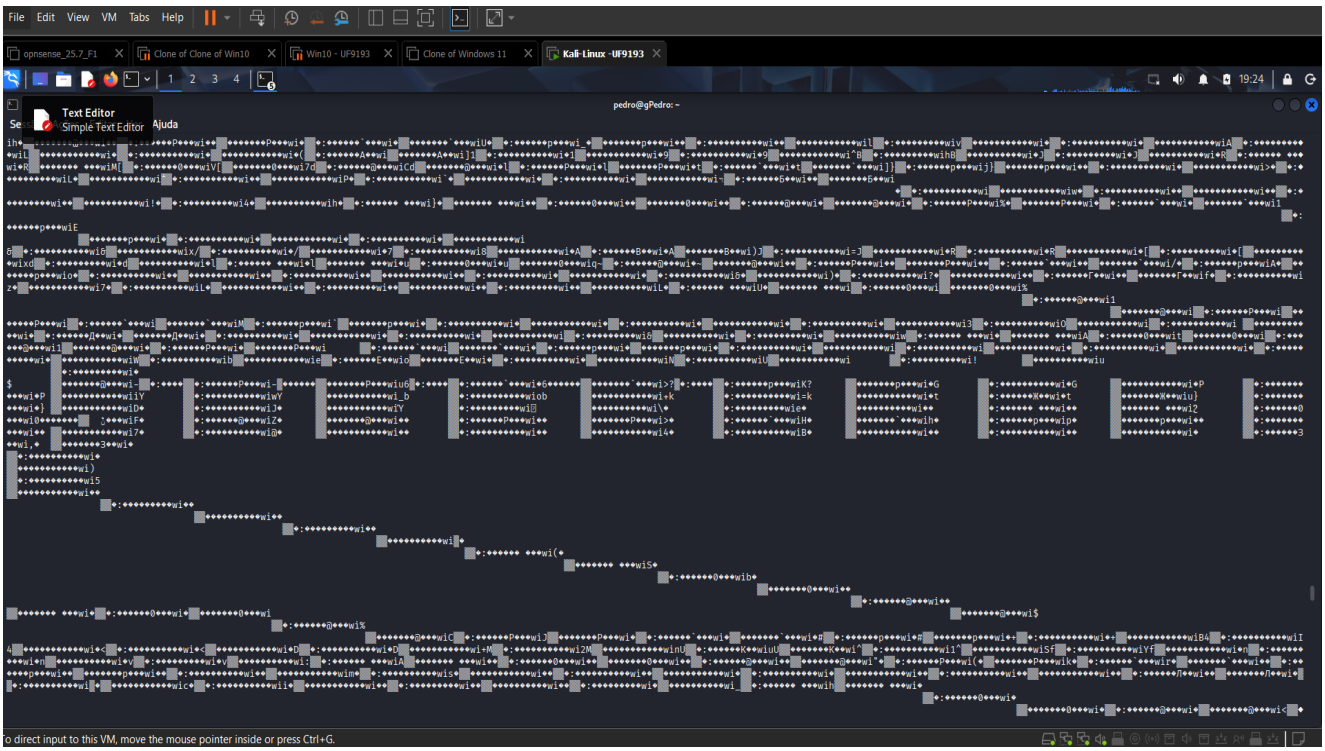


Deve aguardar-se até que o WPA Handshake seja apresentado no canto superior direito da janela e, de seguida, pressionar CTRL + C.

Como é possível observar-se, o handshake WPA do AP “raaj” foi capturado com sucesso. O ficheiro .cap pode agora ser guardado no sistema.

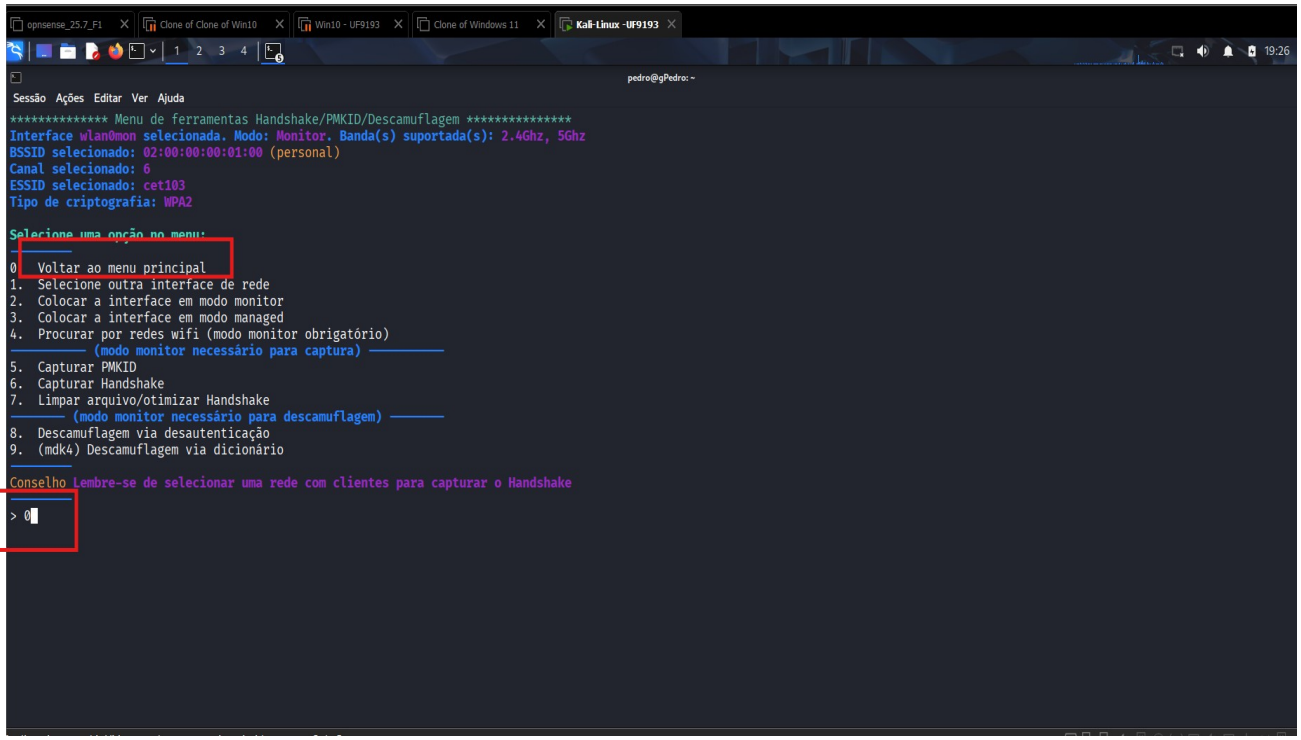
mkdir -p /root/handshakes

sudo cat /root/handshakes/handshake.cap

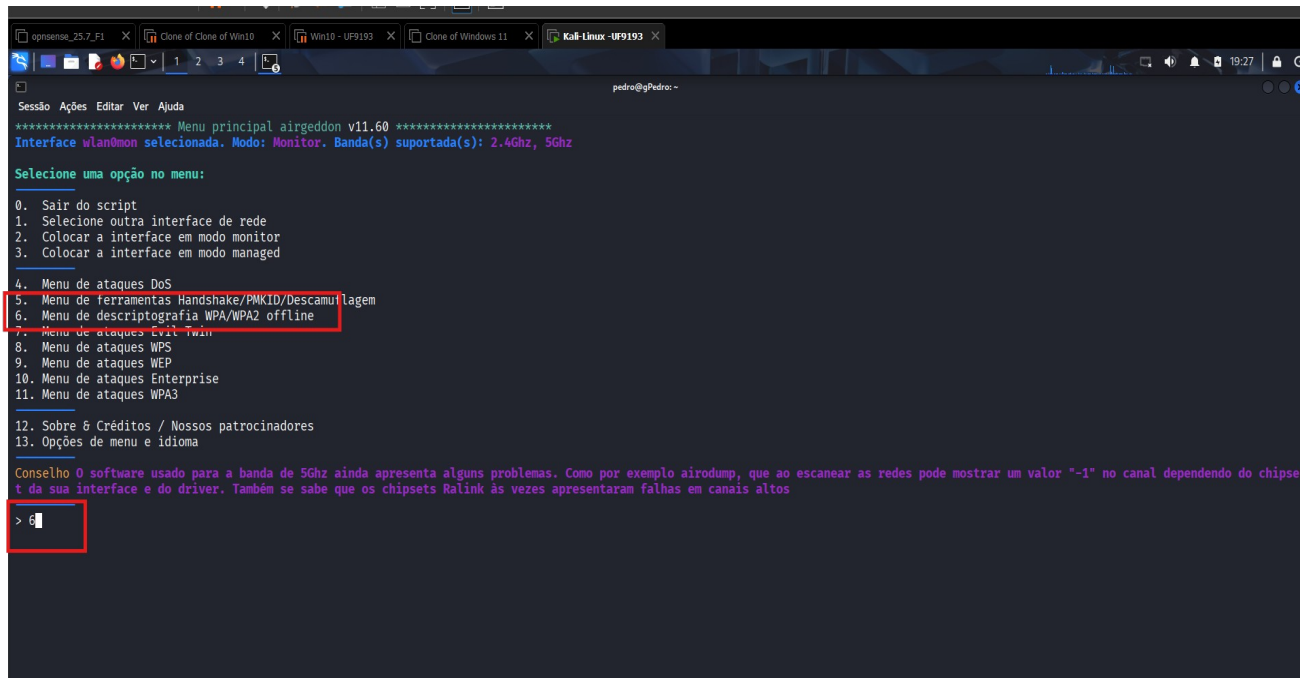


Ataque de Dicionário com Aircrack para Handshake WPA

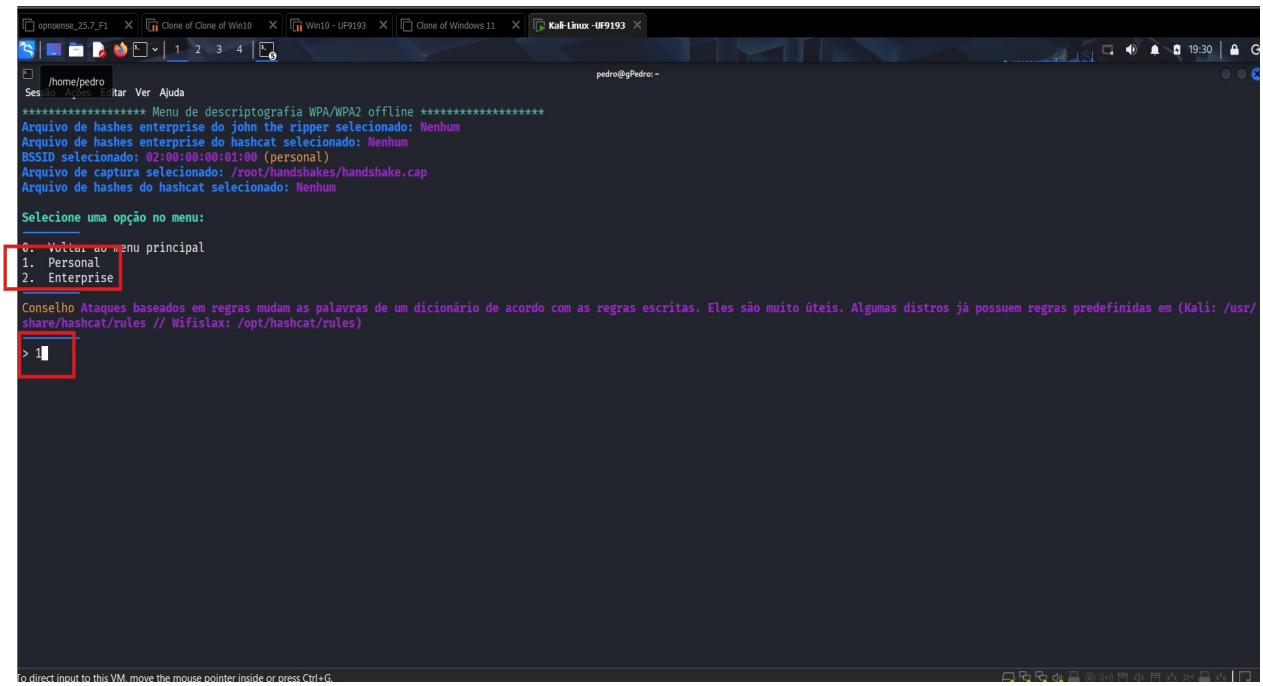
A palavra-passe Wi-Fi ficou guardada num ficheiro de handshake, mas, por se encontrar encriptada, foi necessário desencriptá-la para obter a palavra-passe. De seguida, regressa-se ao menu principal selecionando a opção 0.



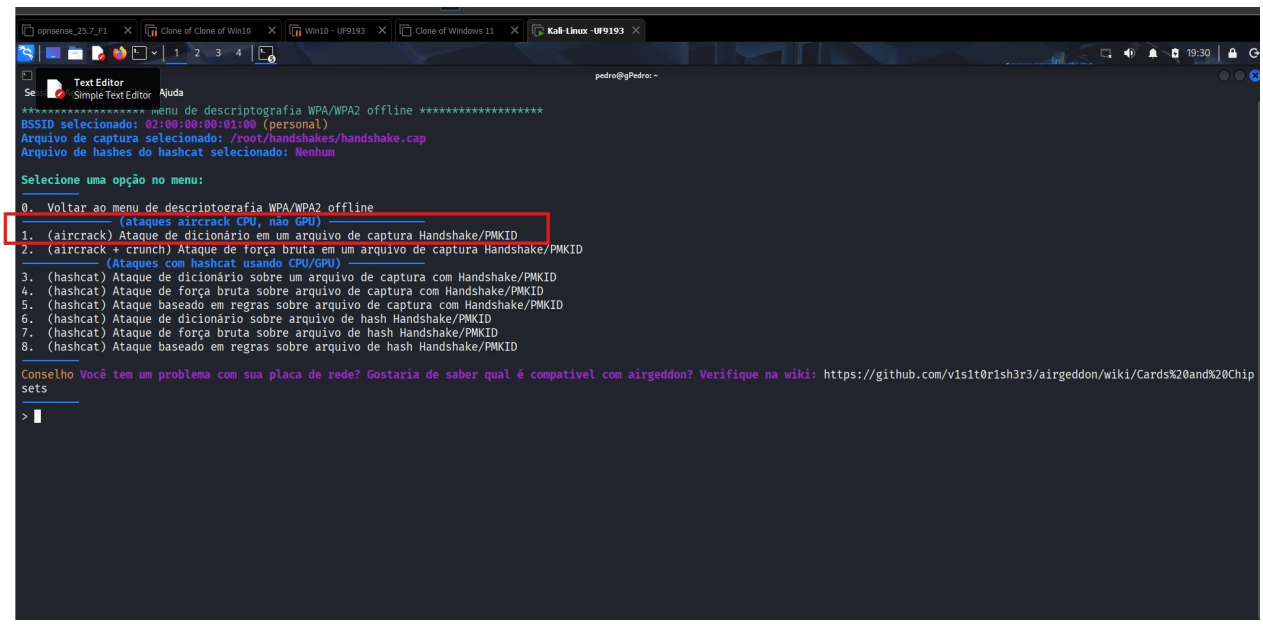
Apresentadas as opções de ataque; seleciona-se a opção 6 para aceder ao menu de desencriptação offline WPA/WPA2.



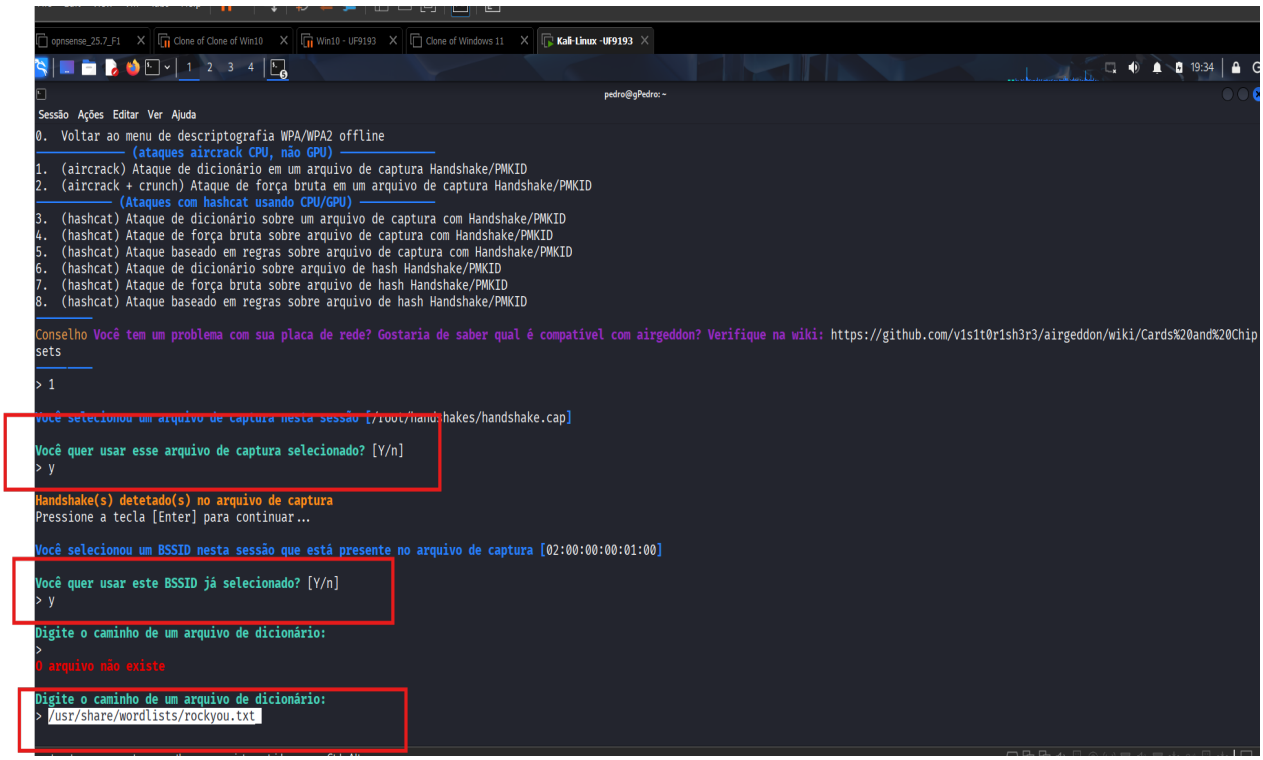
Seleciona-se a opção 1 para escolher **Personal**



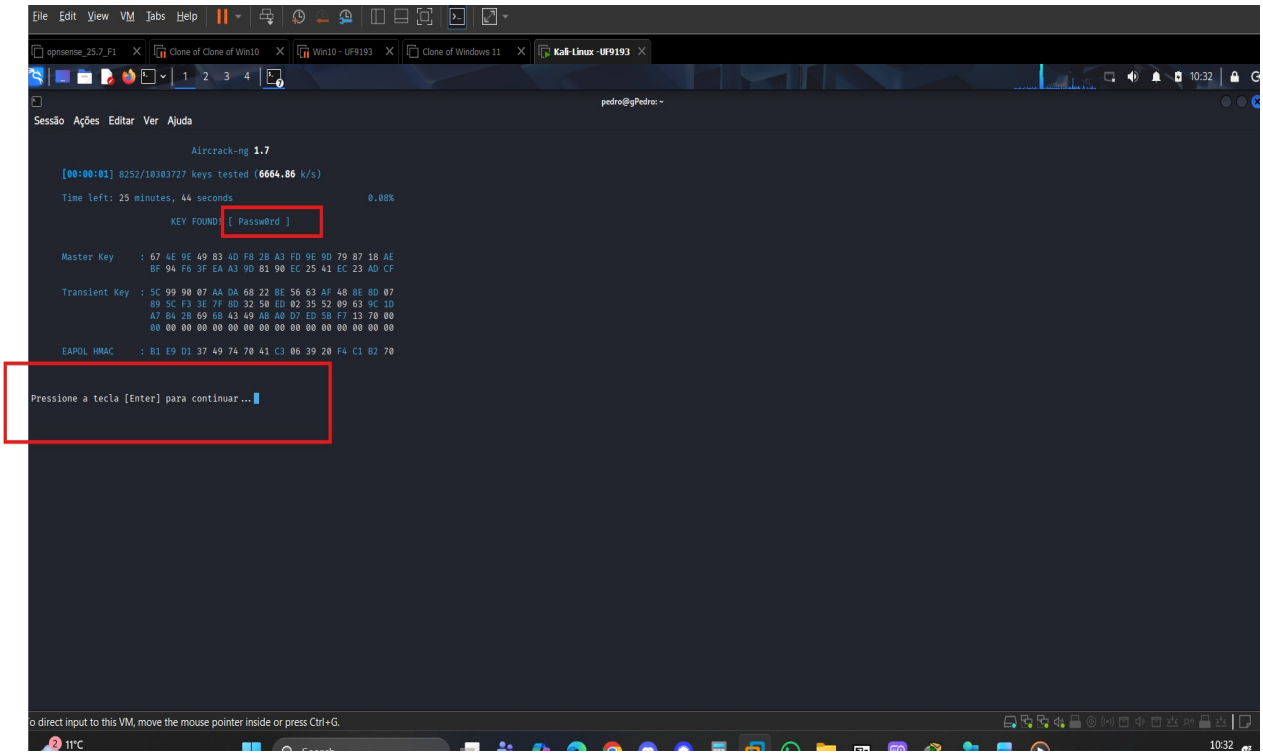
Seguidamente , é utilizado um dicionário para desencriptar o ficheiro de handshake capturado.
Seleciona-se a opção 1, conforme apresentado na imagem.
Por defeito, é utilizado o último ficheiro capturado para o ataque de força bruta; introduz-se Y para selecionar o caminho e o BSSID do último ficheiro capturado.
Posteriormente, é fornecido o caminho do dicionário — /usr/share/wordlists/rockyou.txt ou rockyou.txt — e pressiona-se a tecla ENTER para iniciar o ataque de dicionário contra o handshake WPA



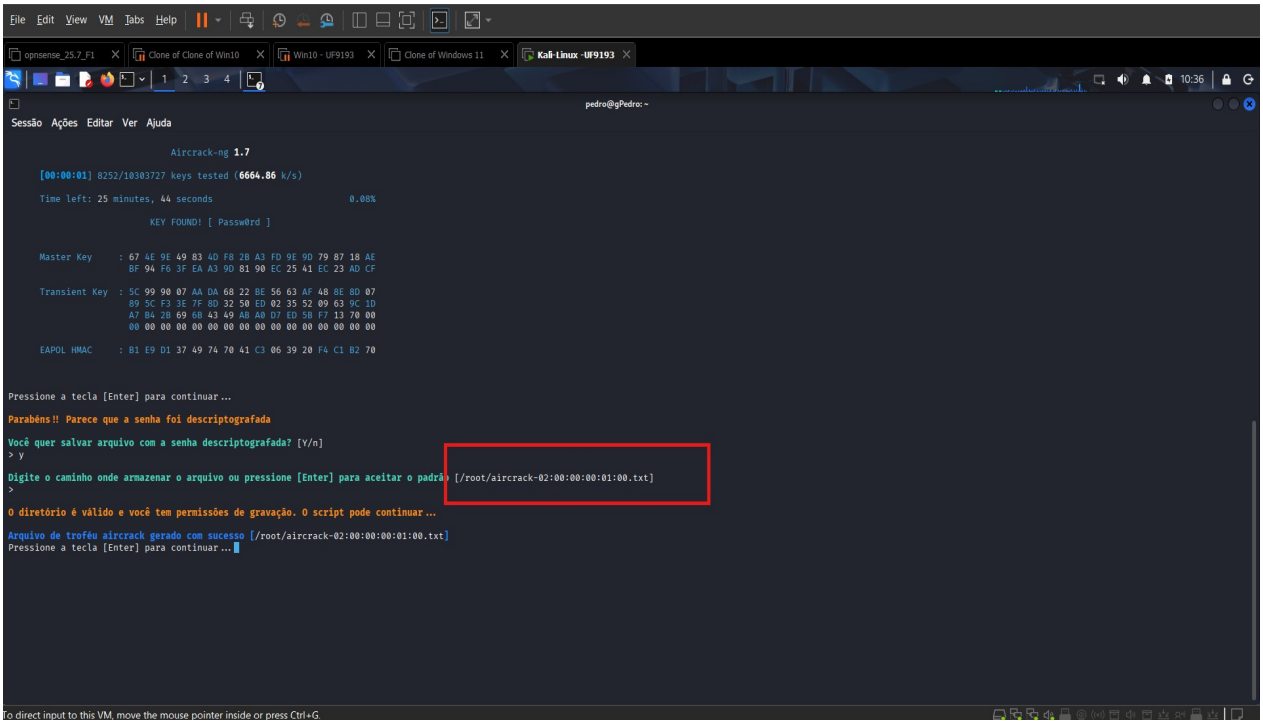
Continuação...



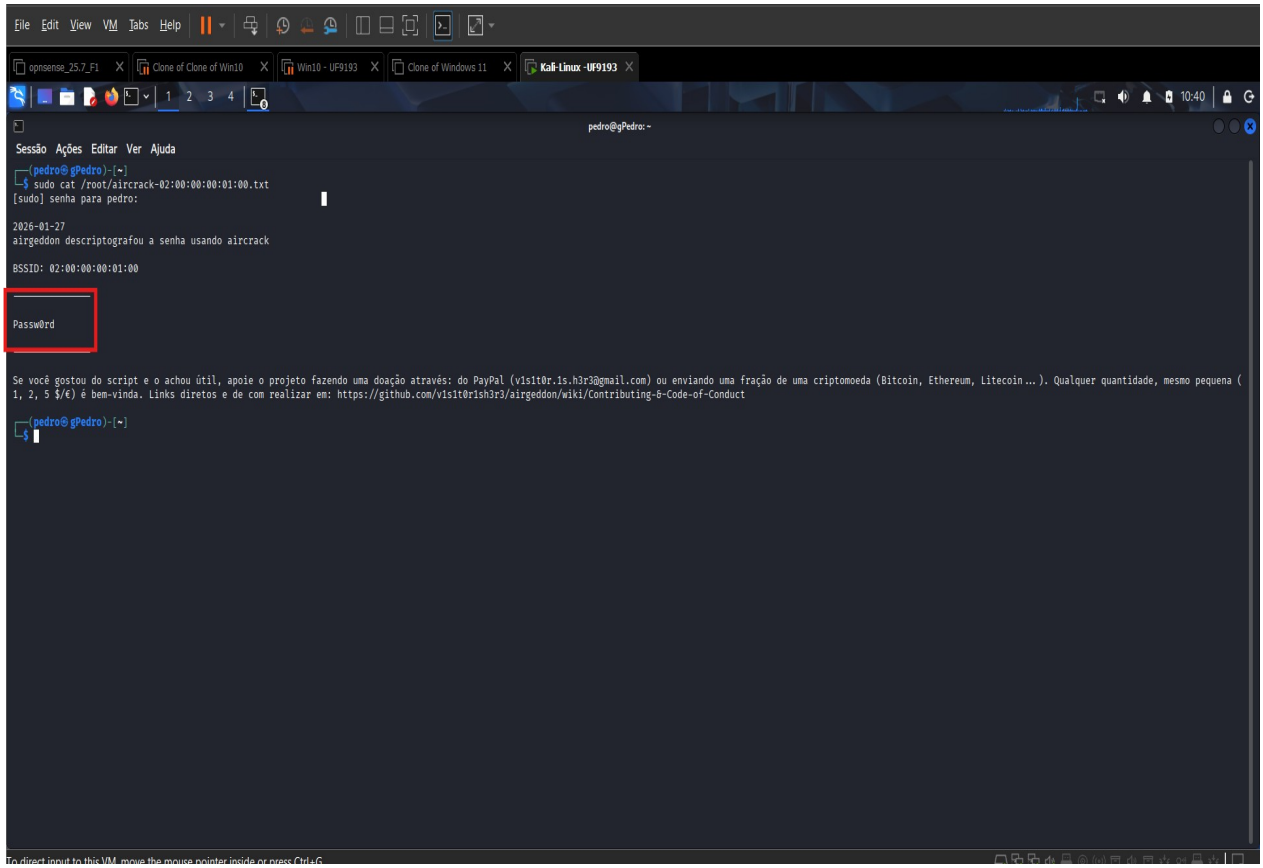
Continuação...



A palavra-passe ou chave Wi-Fi será então apresentada, conforme ilustrado na figura abaixo. Caso se pretenda guardar a chave, o sistema irá solicitar essa confirmação

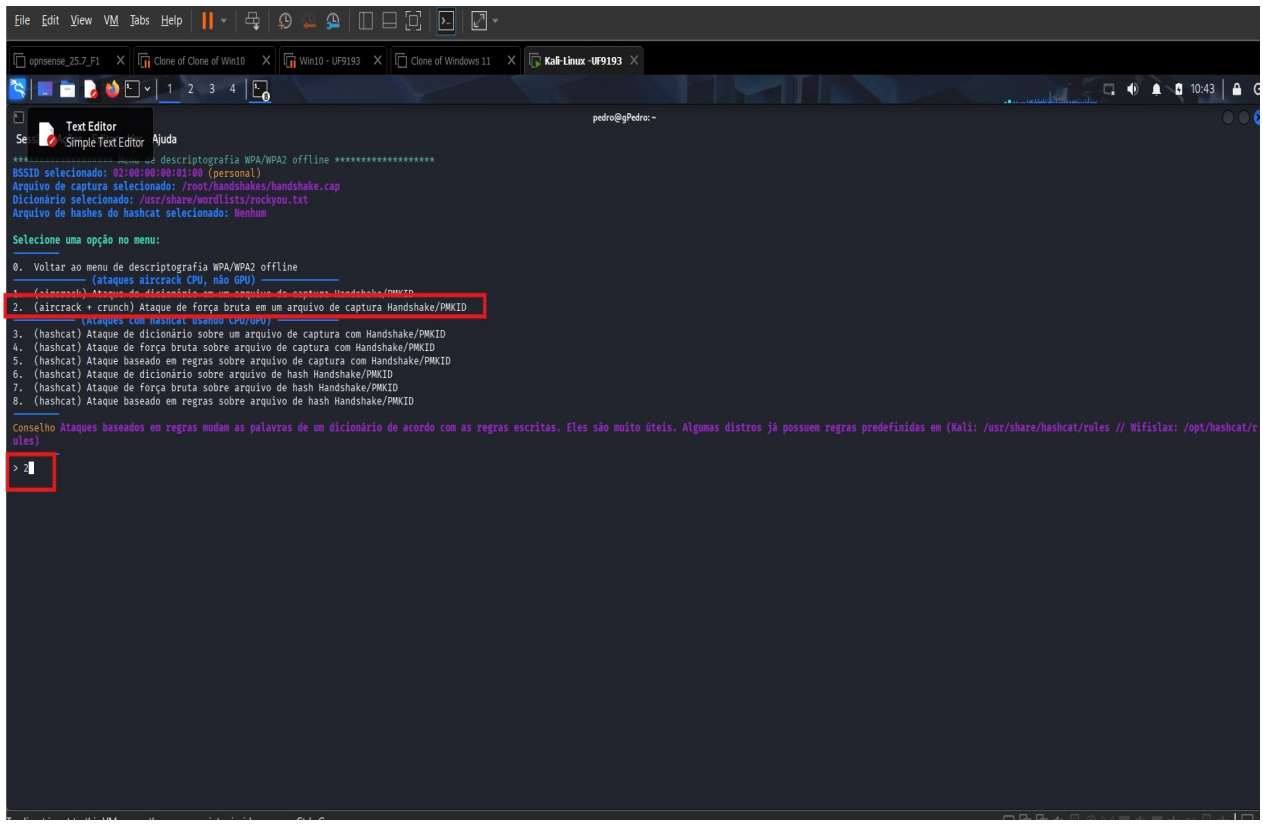


Comando : **sudo cat /root/aircrack-02:00:00:00:01:00.txt**

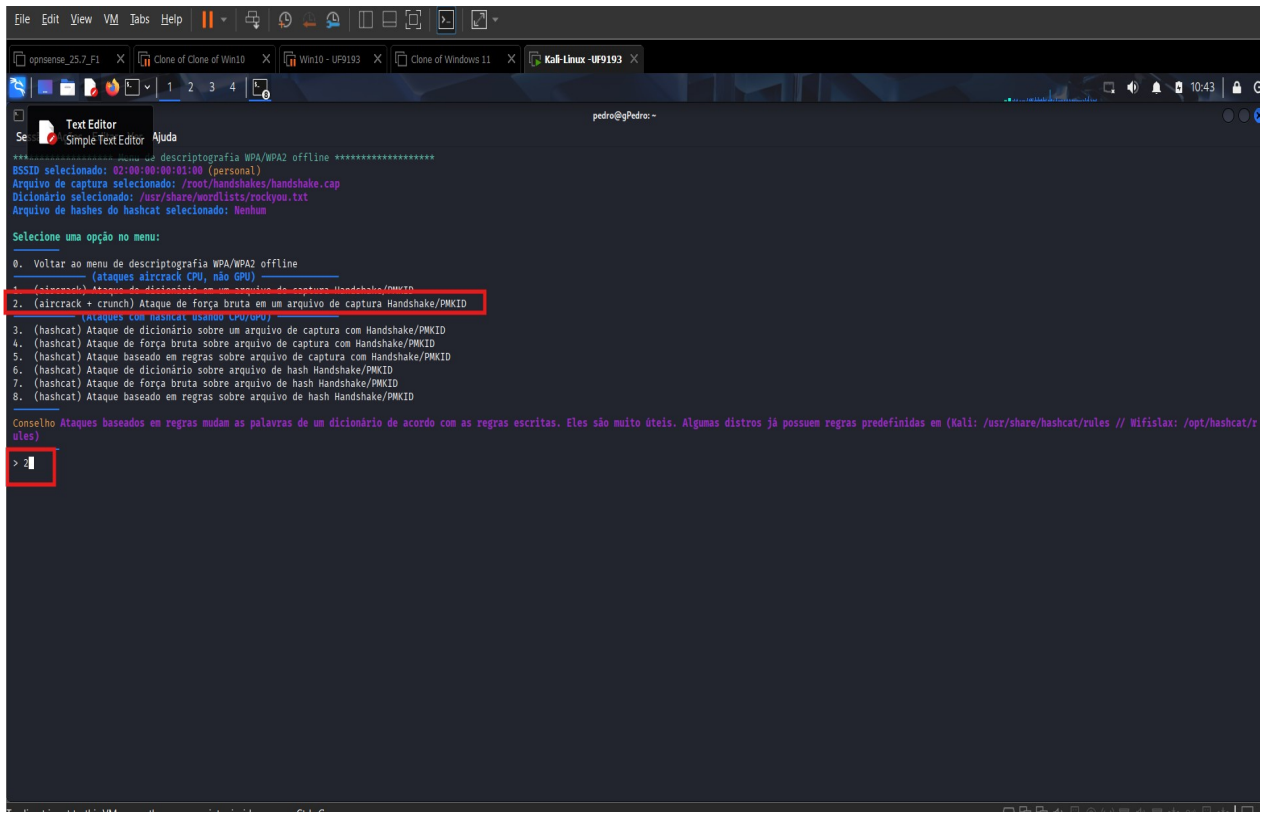


Ataque de Força Bruta com Aircrack para Handshake WPA

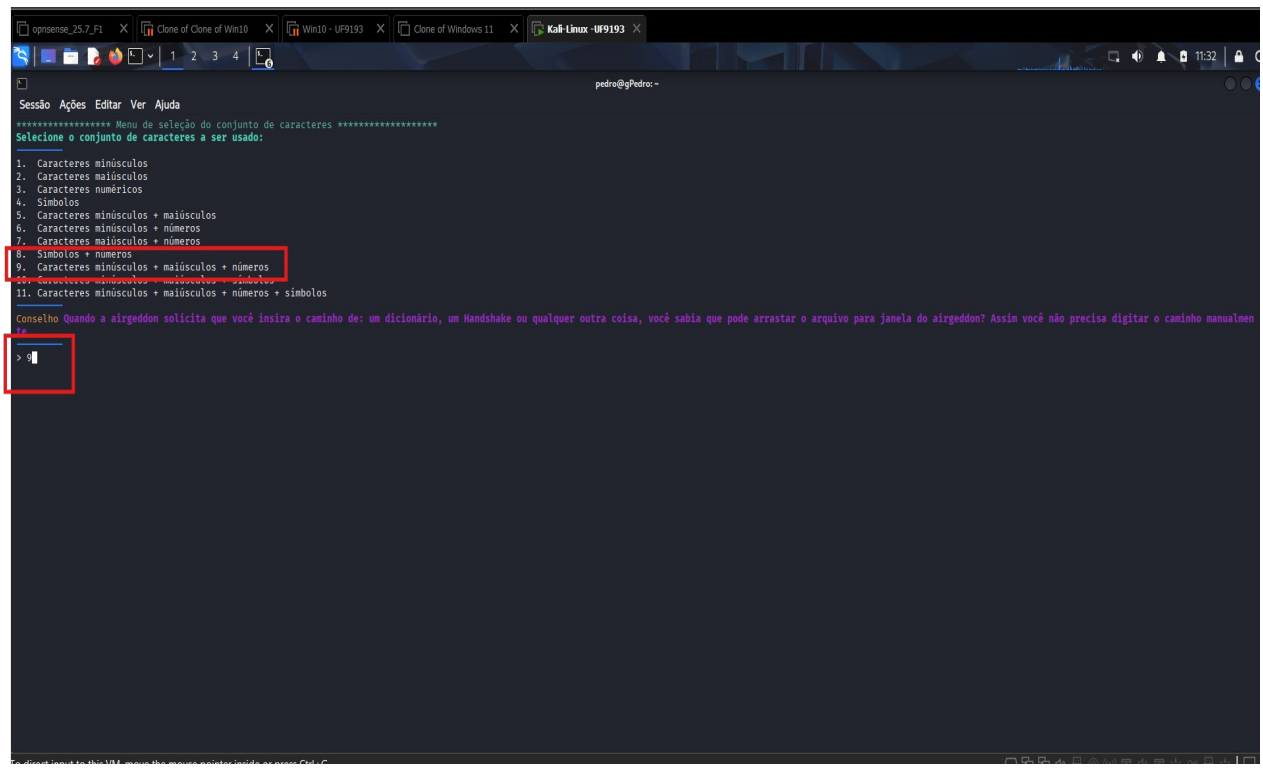
Seleciona-se a opção 2 para realizar um ataque de força bruta ao ficheiro de handshake WPA, que irá descodificar os pacotes utilizando o crunch e o aircrack. Por defeito, é utilizado o último ficheiro capturado. Introduz-se Y para selecionar o diretório e o BSSID do último ficheiro capturado.
De seguida, introduz-se o caminho para o dicionário ou para o ficheiro rockyou.txt e pressiona-se a tecla ENTER para iniciar o ataque de força bruta ao handshake WPA.



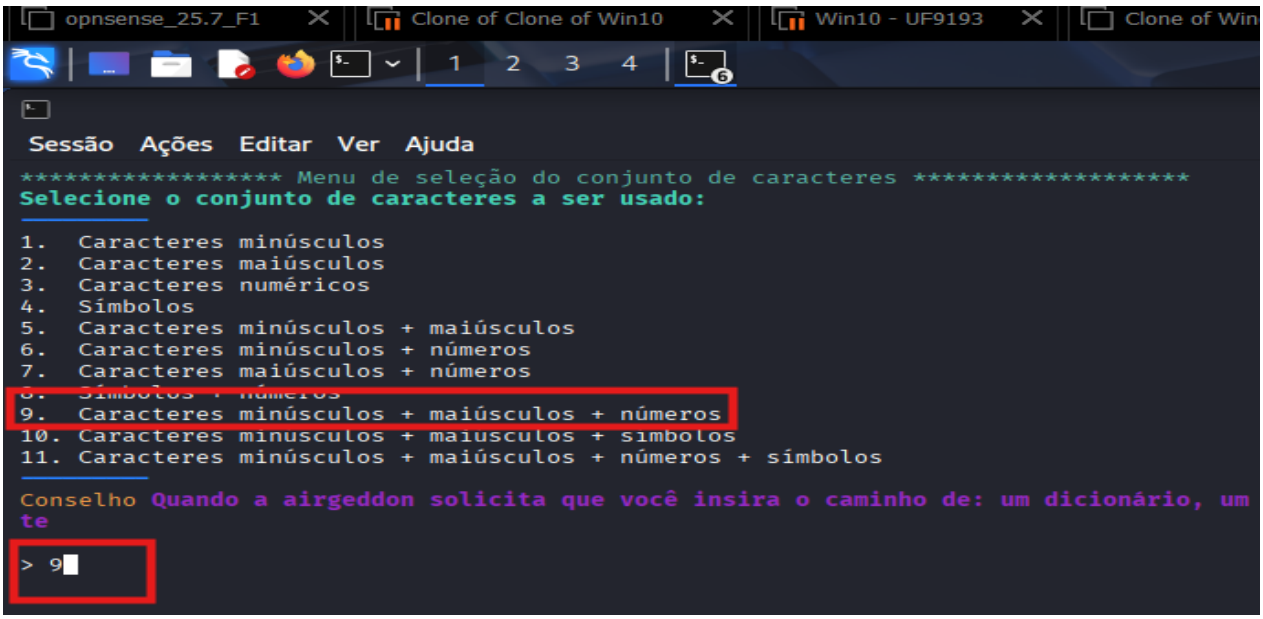
Continuação..



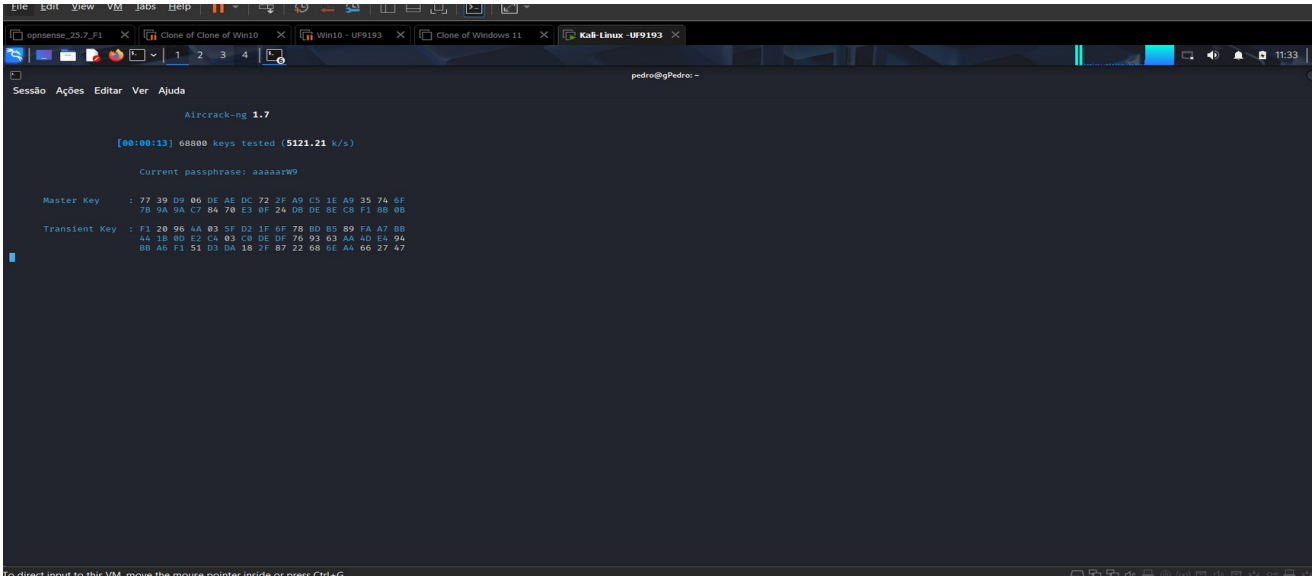
Seleciona-se o conjunto de caracteres, neste caso a opção 9, correspondente a letras minúsculas + letras maiúsculas + caracteres numéricos, que irá tentar executar um ataque de força bruta à chave Wi-Fi utilizando um conjunto de caracteres alfanuméricos. Para iniciar o ataque, pressiona-se a tecla ENTER.



Continuação...

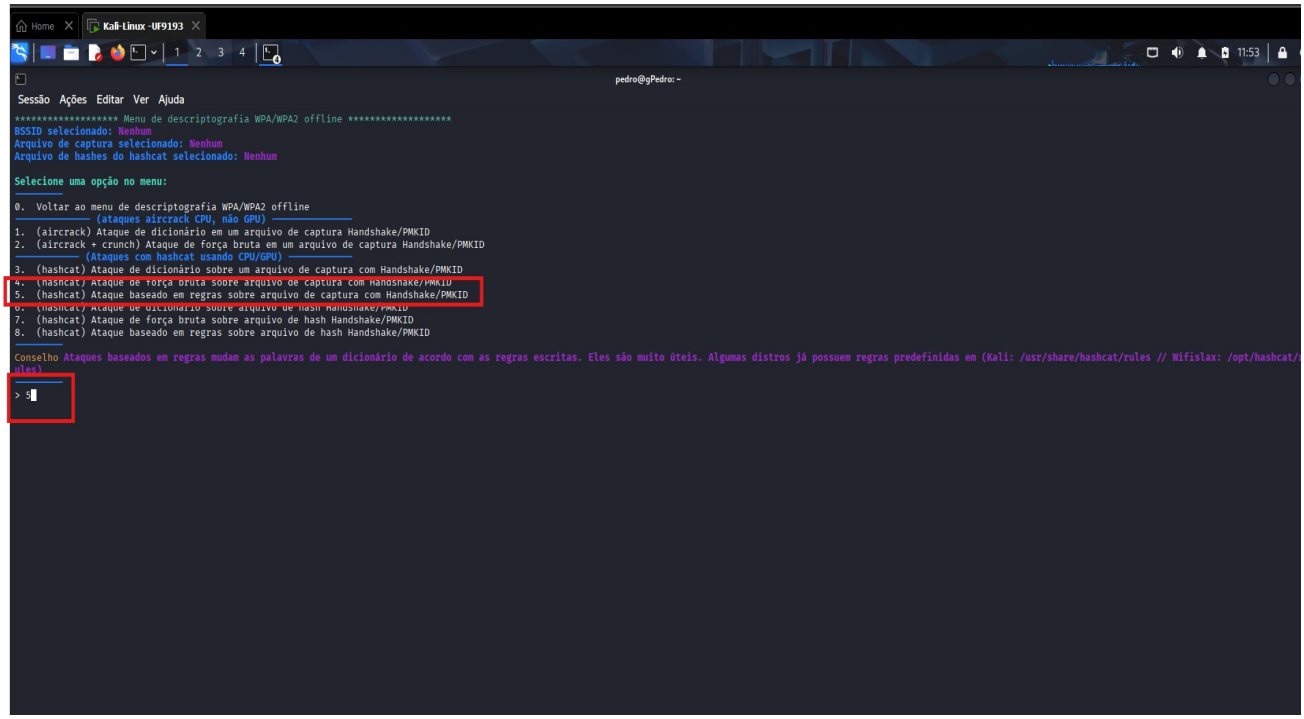


Caso a tentativa seja bem-sucedida, a palavra-passe ou chave Wi-Fi será apresentada, conforme ilustrado na figura abaixo

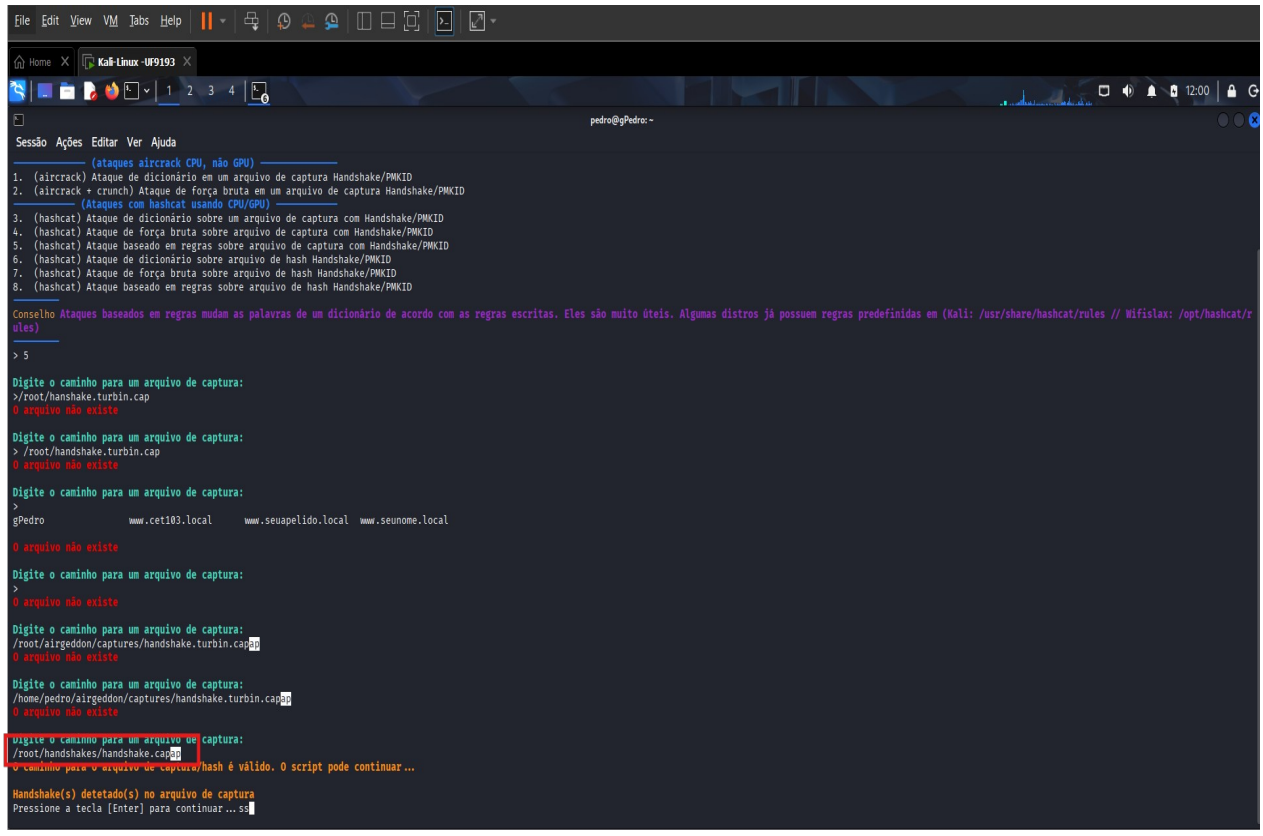


Ataque Baseado em Regras com Hashcat para Handshake WPA

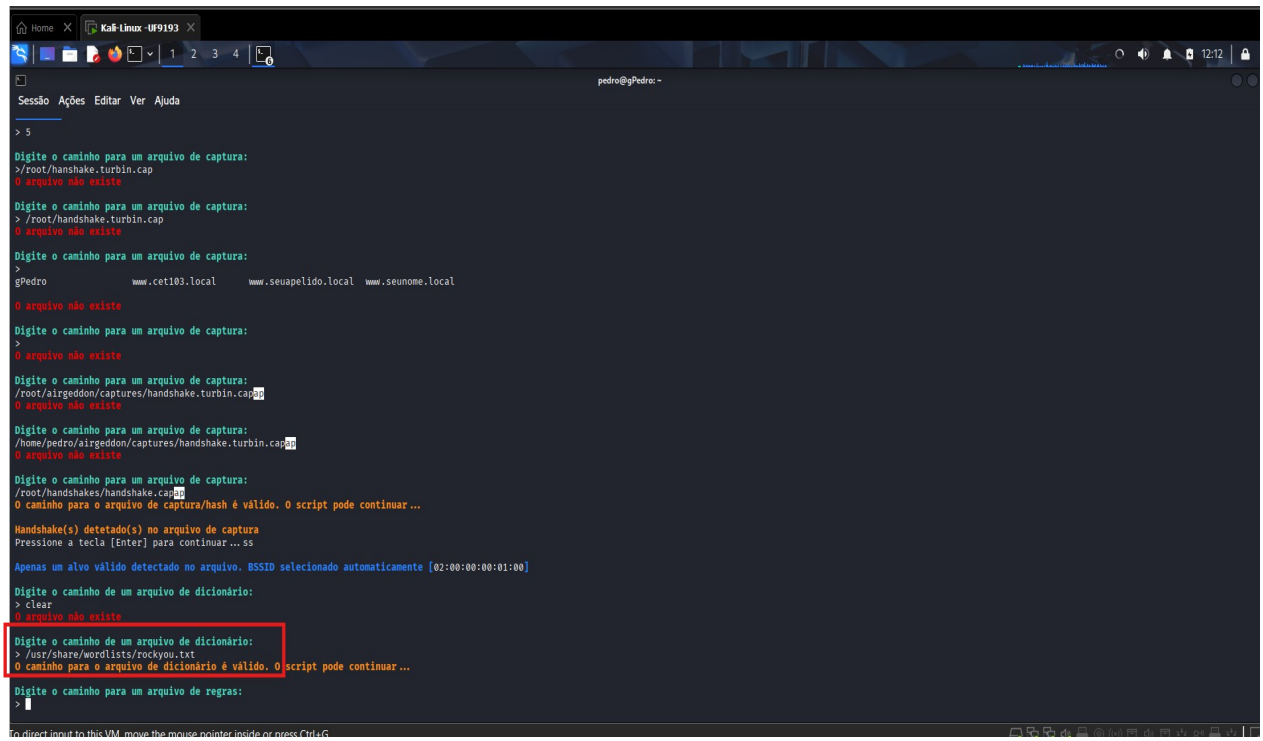
Uma vez que estamos todos familiarizados com a capacidade do hashcat, o airgeddon disponibiliza a possibilidade de utilizar o hashcat para quebrar a chave Wi-Fi. Deve escolher-se a opção 5 e introduzir o caminho para o ficheiro de handshake WPA, para o dicionário ou para o ficheiro de regras a utilizar. Aqui é fornecido o caminho para o ficheiro best64.rule, o qual será utilizado para realizar um ataque baseado em regras com o hashcat.



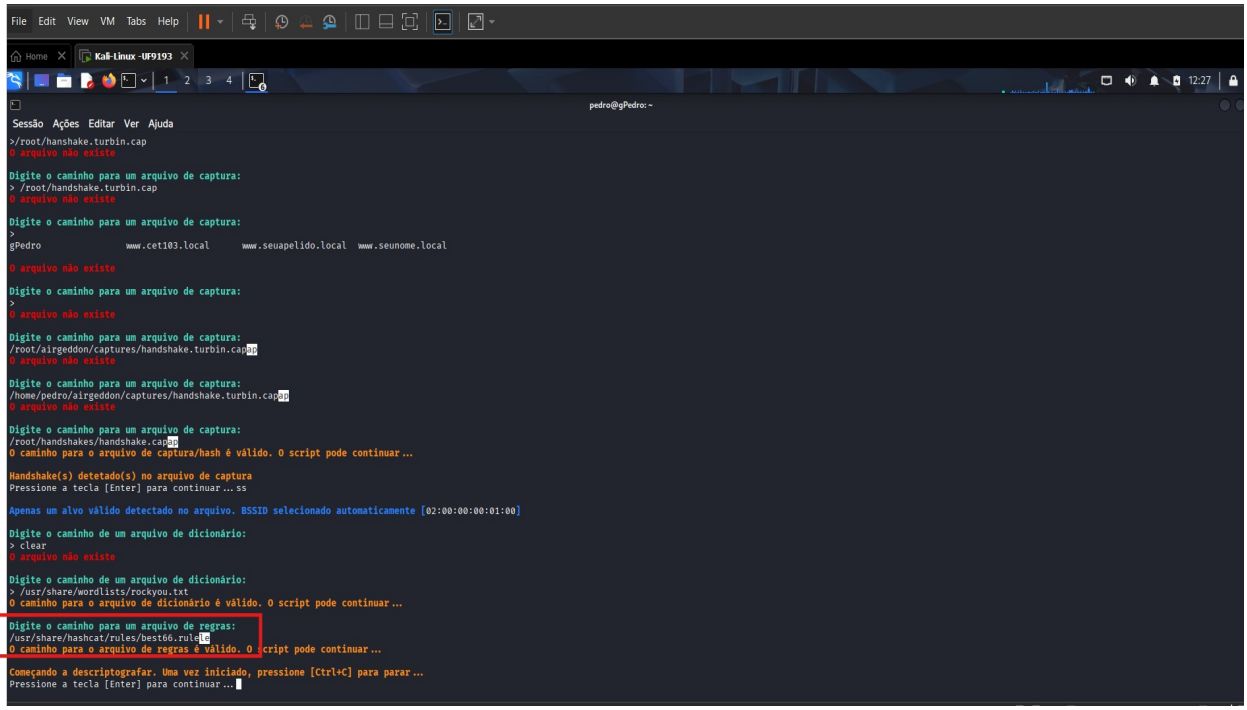
Caminho para o arquivo de captura : **/root/handshakes/handshake.cap**



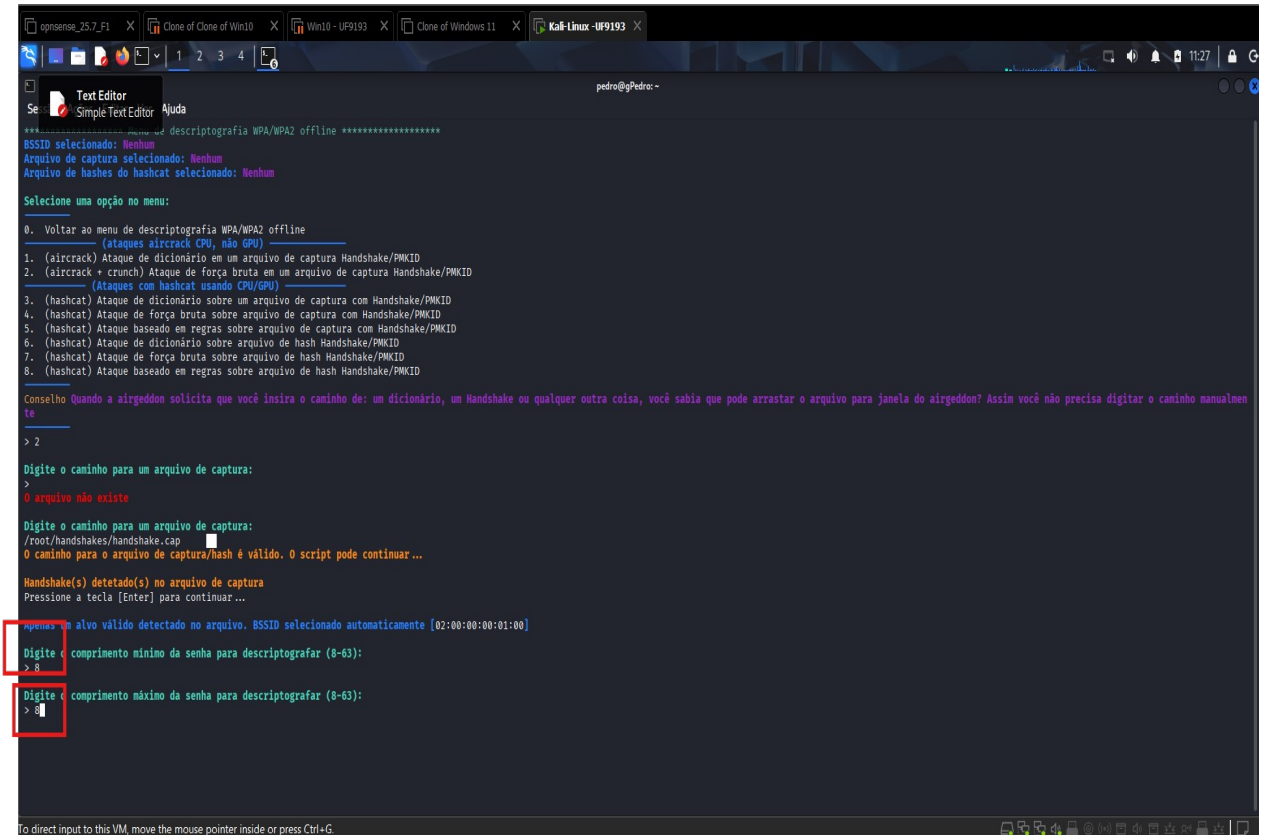
Caminho de um arquivo de dicionário:**/usr/share/wordlists/rockyou.txt**



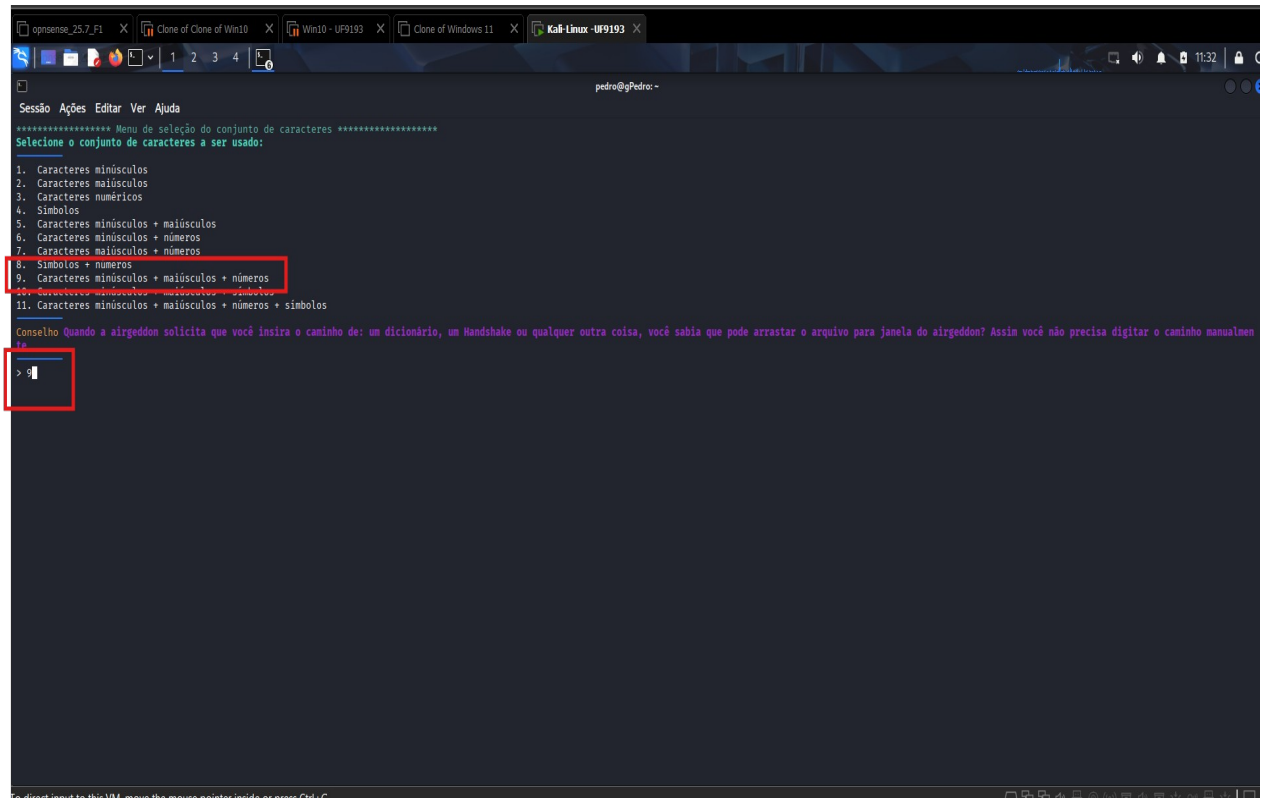
Introduza o caminho para um ficheiro de regras: /usr/share/hashcat/rules/best66.rule



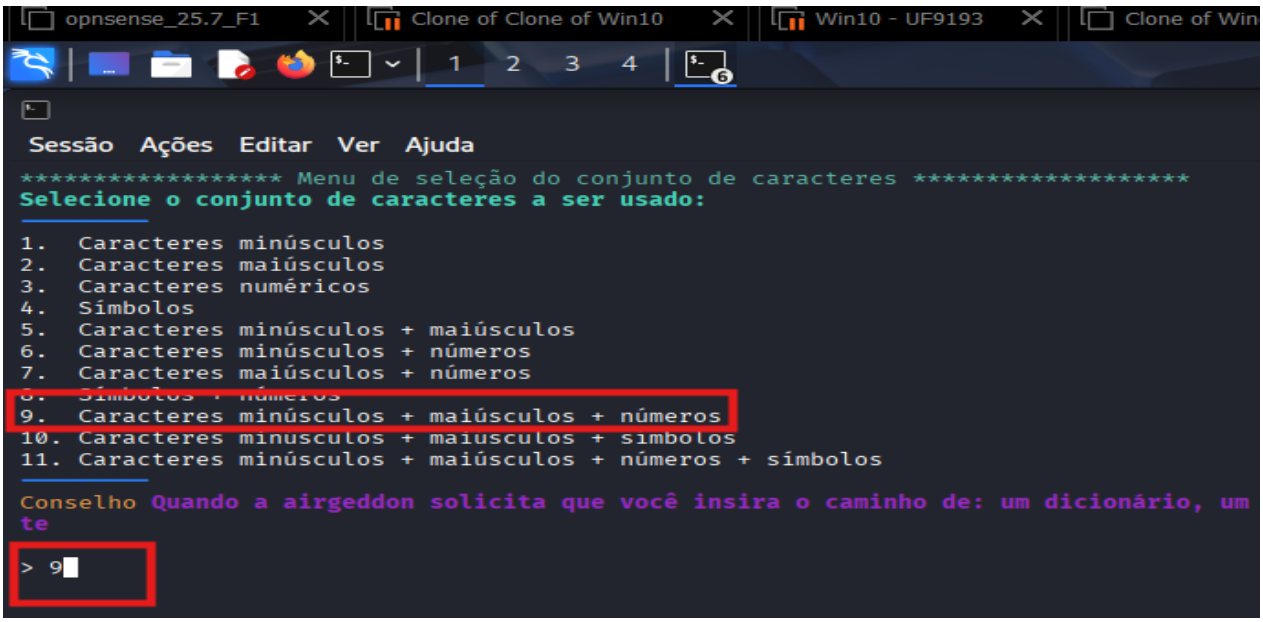
Continuação ...



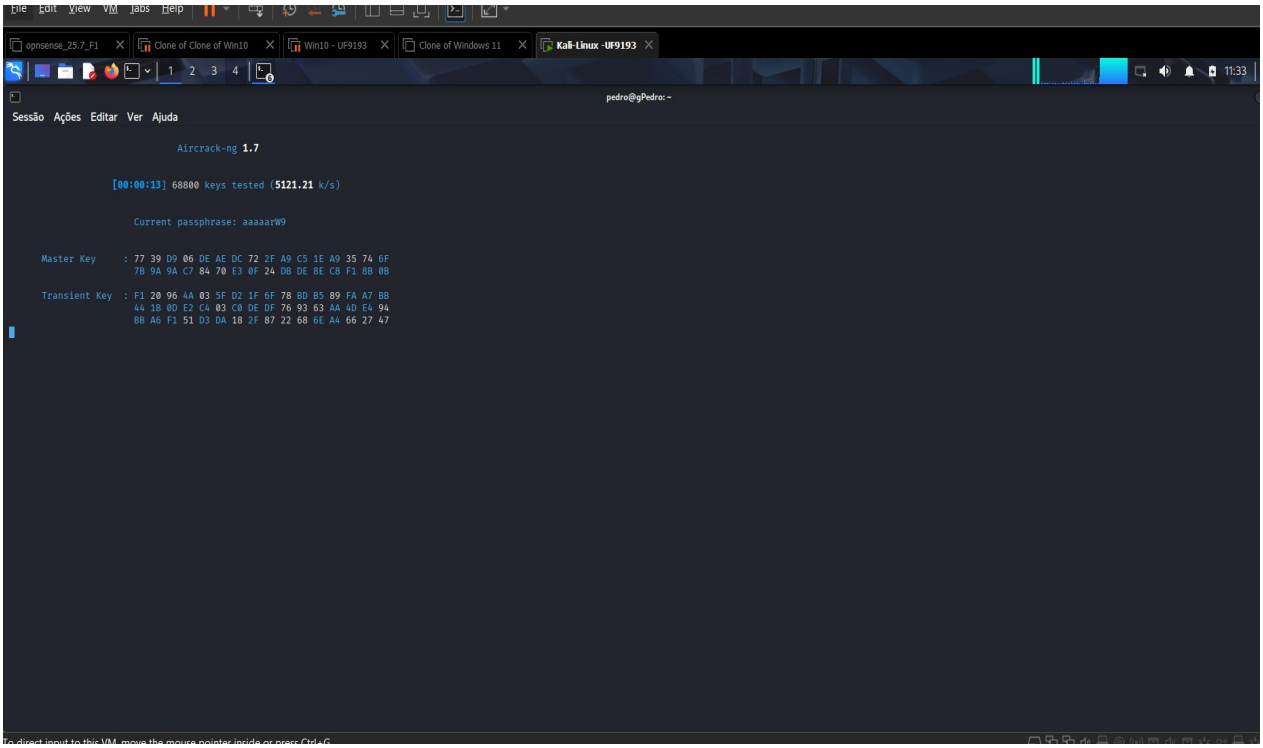
Seleciona-se o conjunto de caracteres, neste caso a opção 9, correspondente a letras minúsculas + letras maiúsculas + caracteres numéricos, que irá tentar executar um ataque de força bruta à chave Wi-Fi utilizando um conjunto de caracteres alfanuméricos. Para iniciar o ataque, pressiona-se a tecla ENTER



Continuação ...



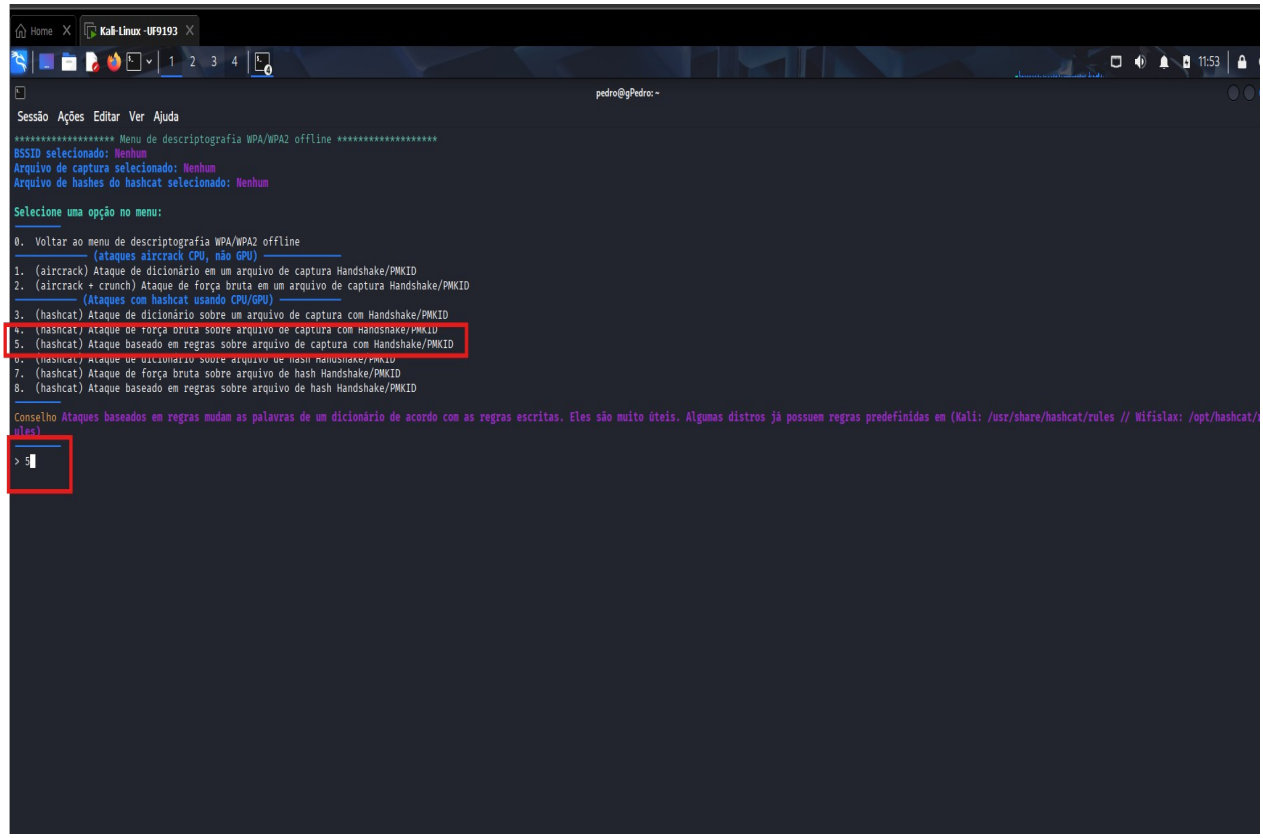
Caso a tentativa seja bem-sucedida, a palavra-passe ou chave Wi-Fi será apresentada, conforme ilustrado na figura abaixo



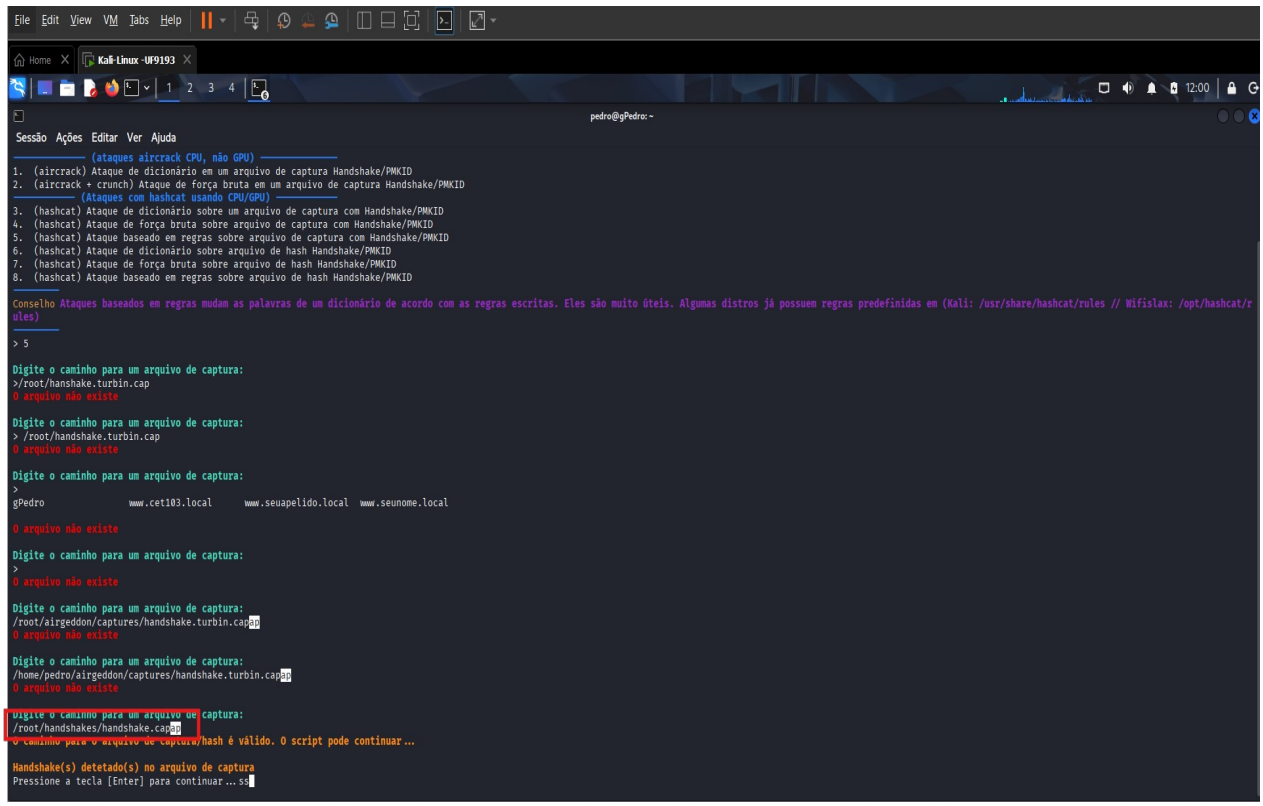
Ataque Baseado em Regras com Hashcat para Handshake WPA

Uma vez que estamos todos familiarizados com a capacidade do hashcat, o airgeddon disponibiliza a possibilidade de utilizar o hashcat para quebrar a chave Wi-Fi. Deve escolher-se a opção 5 e introduzir o caminho para o ficheiro de handshake WPA, para o dicionário ou para o ficheiro de regras a utilizar.

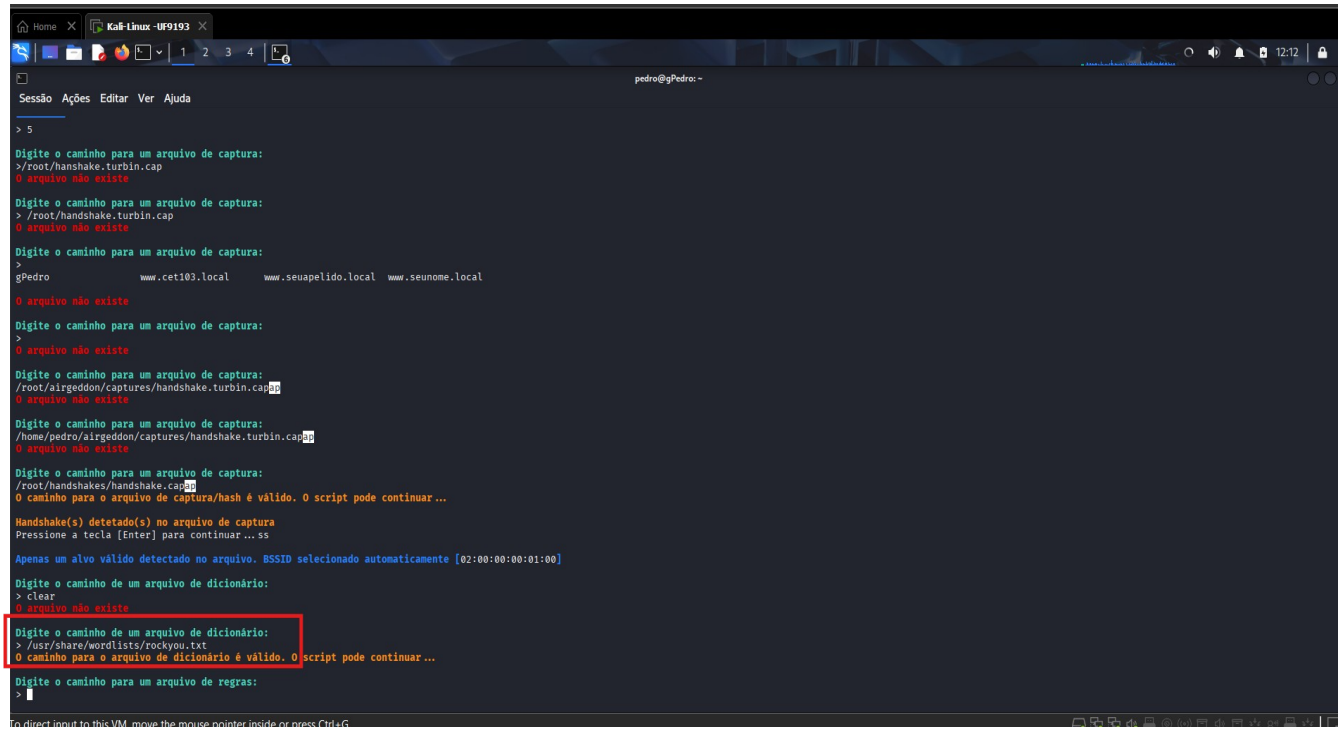
Aqui é fornecido o caminho para o ficheiro best64.rule, o qual será utilizado para realizar um ataque baseado em regras com o hashcat.



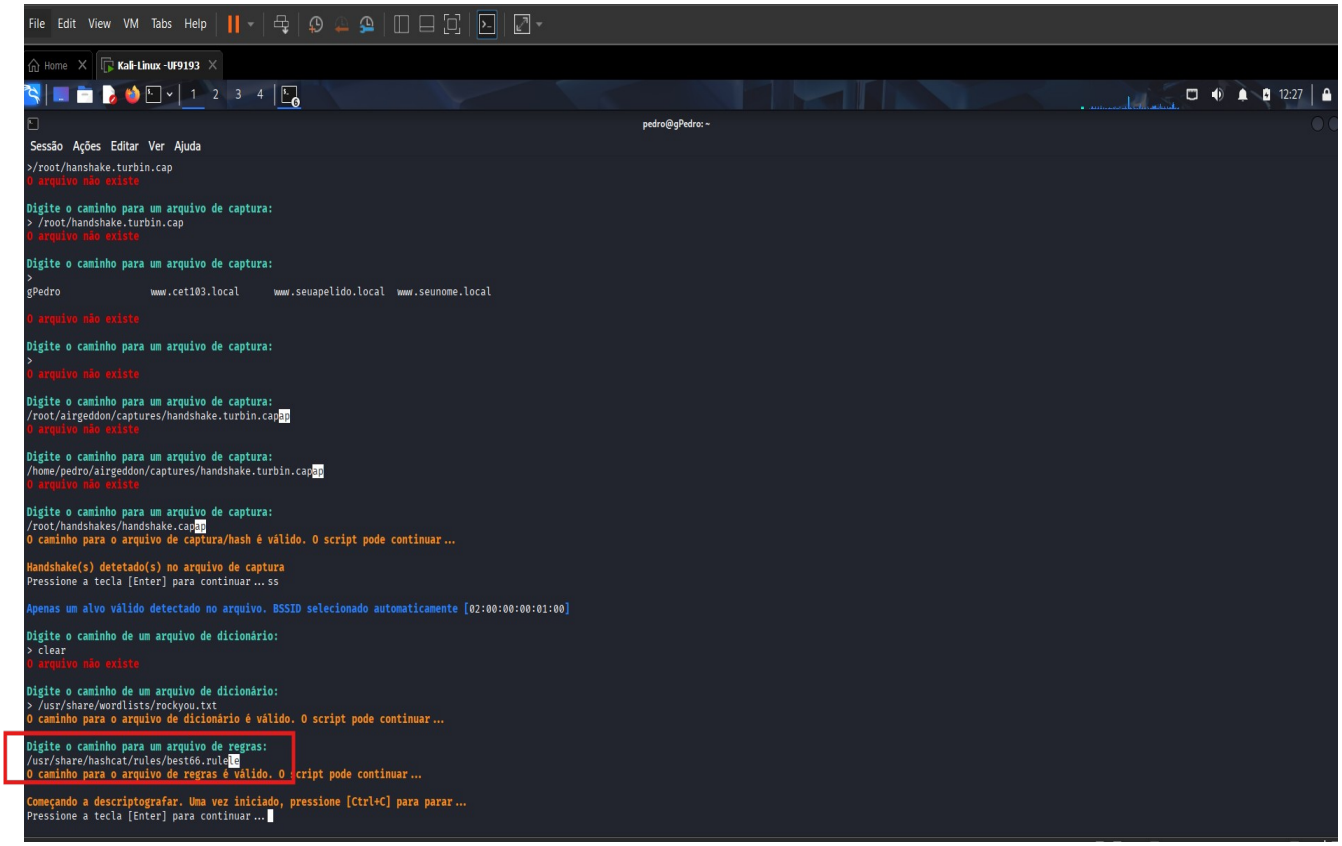
Caminho para o arquivo de captura : **/root/handshakes/handshake.cap**



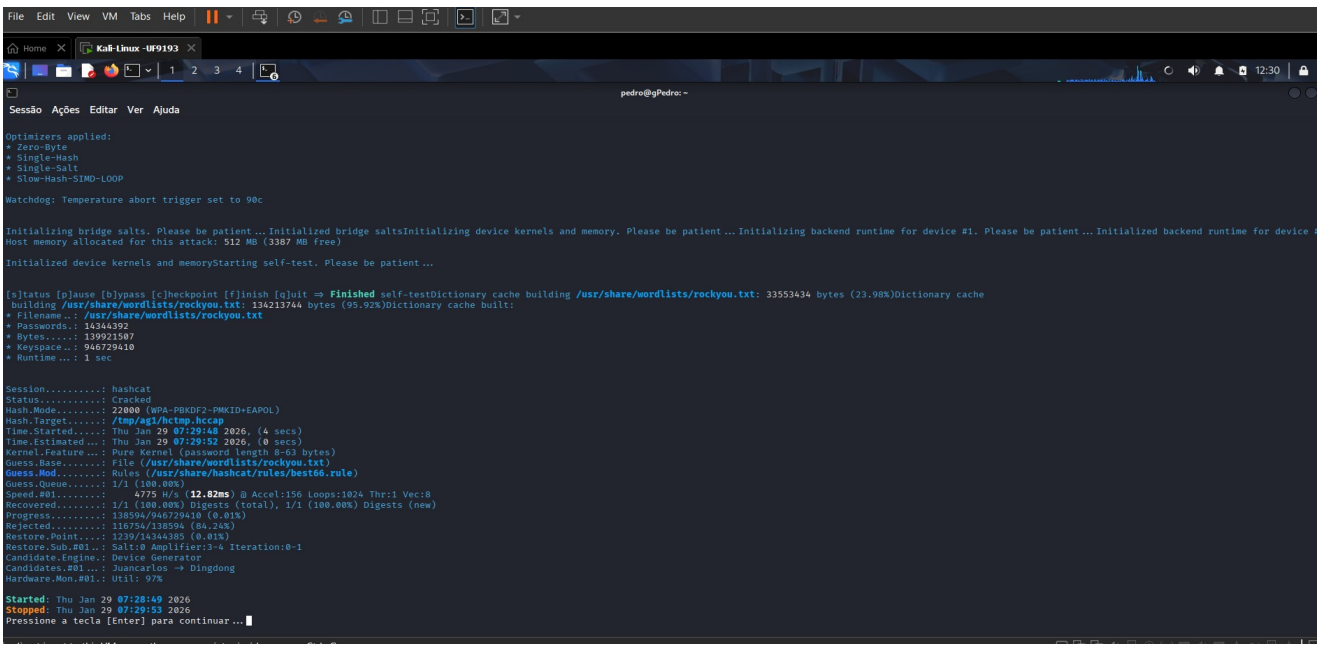
Caminho de um arquivo de dicionário:**/usr/share/wordlists/rockyou.txt**



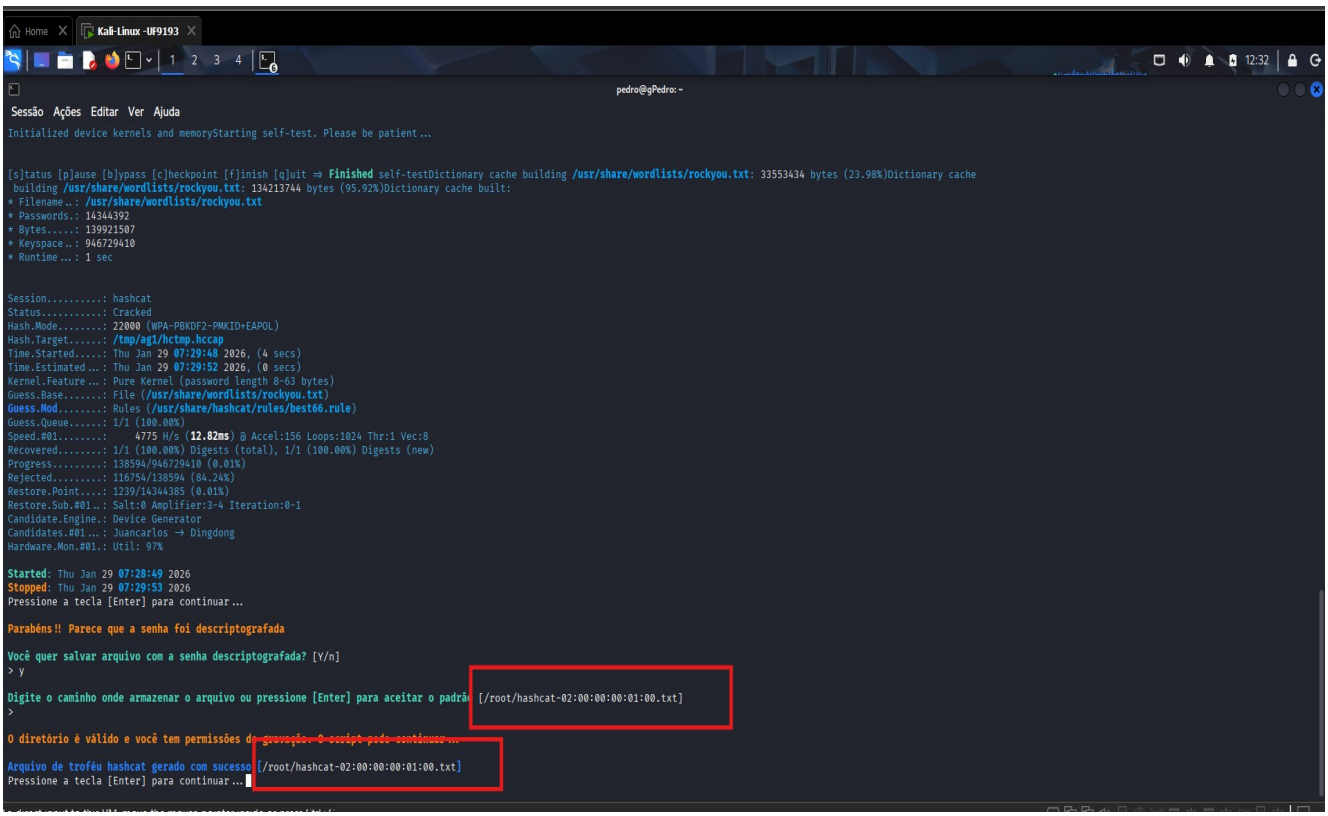
Introduzir o caminho para um ficheiro de regras: **/usr/share/hashcat/rules/best66.rule**



Pressionar ENTER para iniciar o ataque, e o sistema irá tentar desencriptar a comunicação WPA encriptada



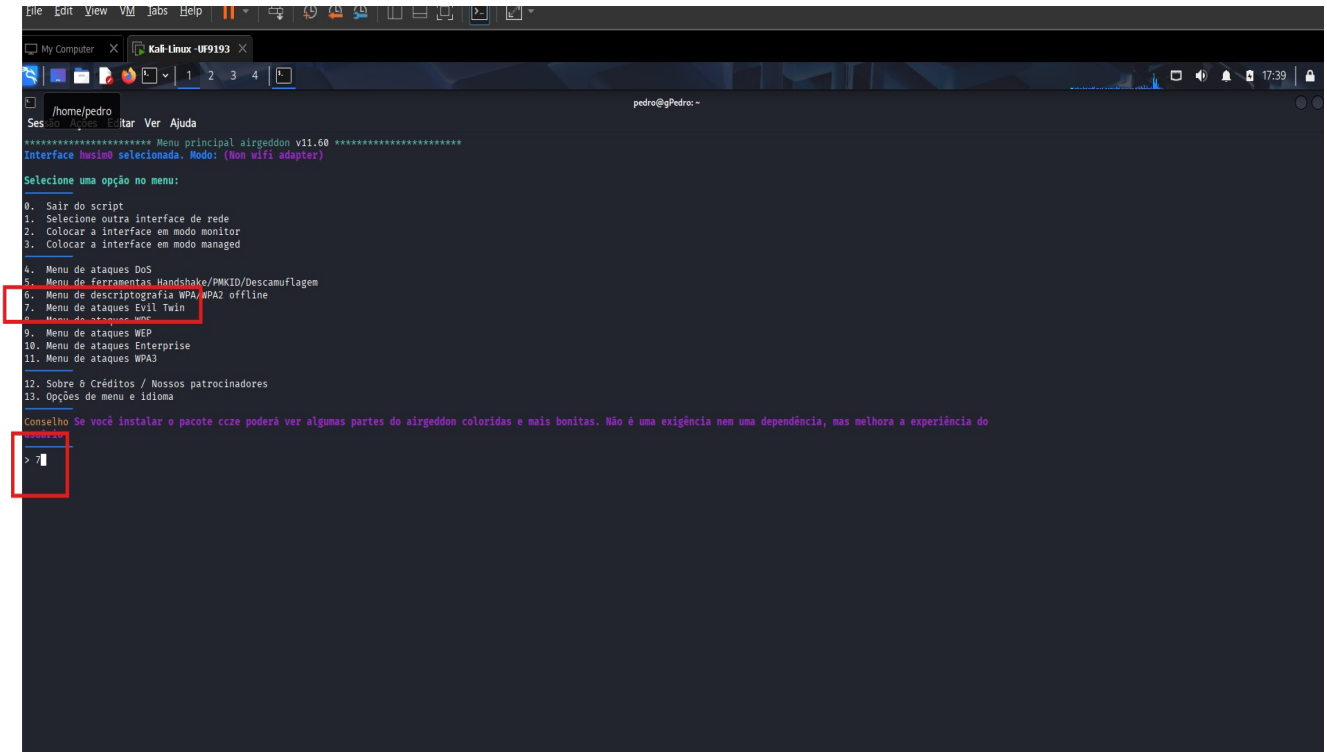
Após uma tentativa bem-sucedida, o sistema irá solicitar que seja guardado o resultado de saída. Para guardar a chave enumerada, utilize a tecla ENTER.



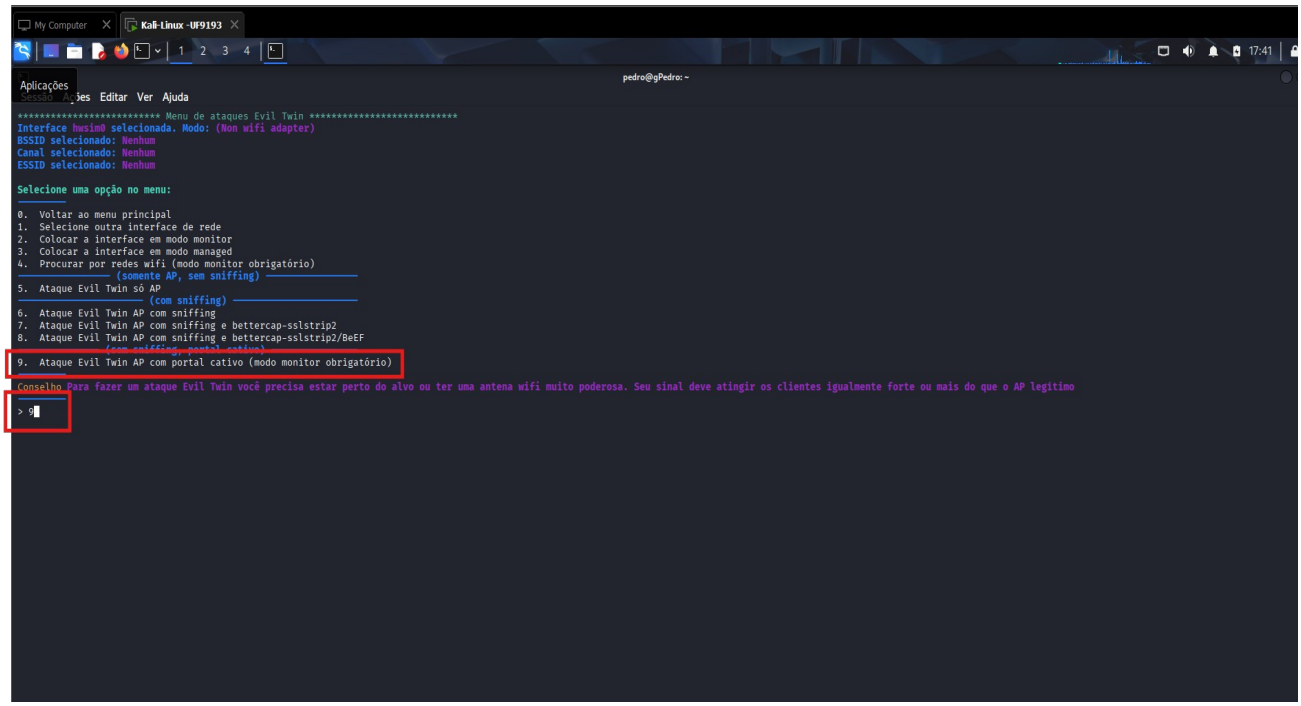
Pode aceder ao ficheiro guardado para ler a palavra-passe Wi-Fi desencriptada



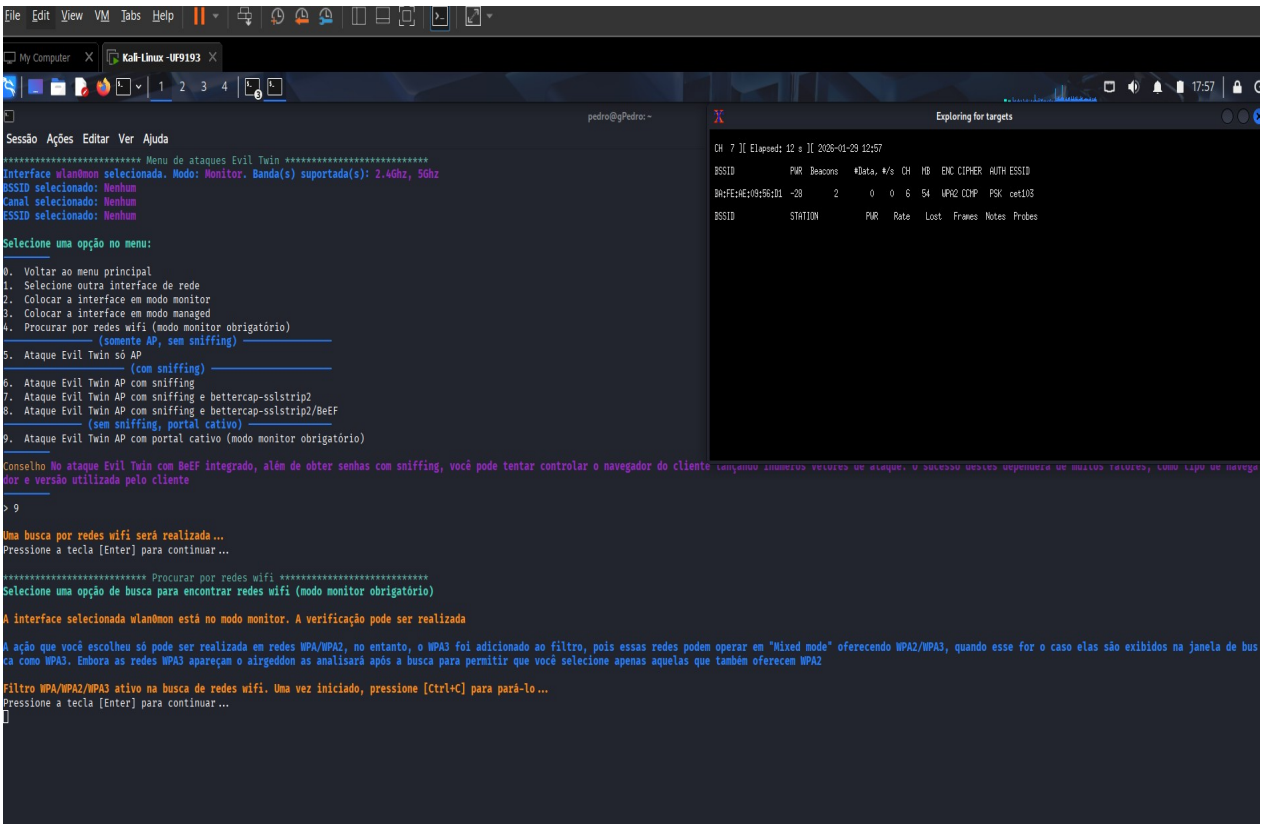
Um Evil Twin é uma falsificação de um ponto de acesso Wi-Fi (Bogus AP) que se faz passar por legítimo, mas que é criado propositadamente para escutar o tráfego sem fios. Ao criar um website falso e atrair utilizadores para o mesmo, este tipo de ataque pode ser utilizado para obter credenciais de clientes legítimos.
No menu principal, selecione a opção 7 para o ataque Evil Twin.



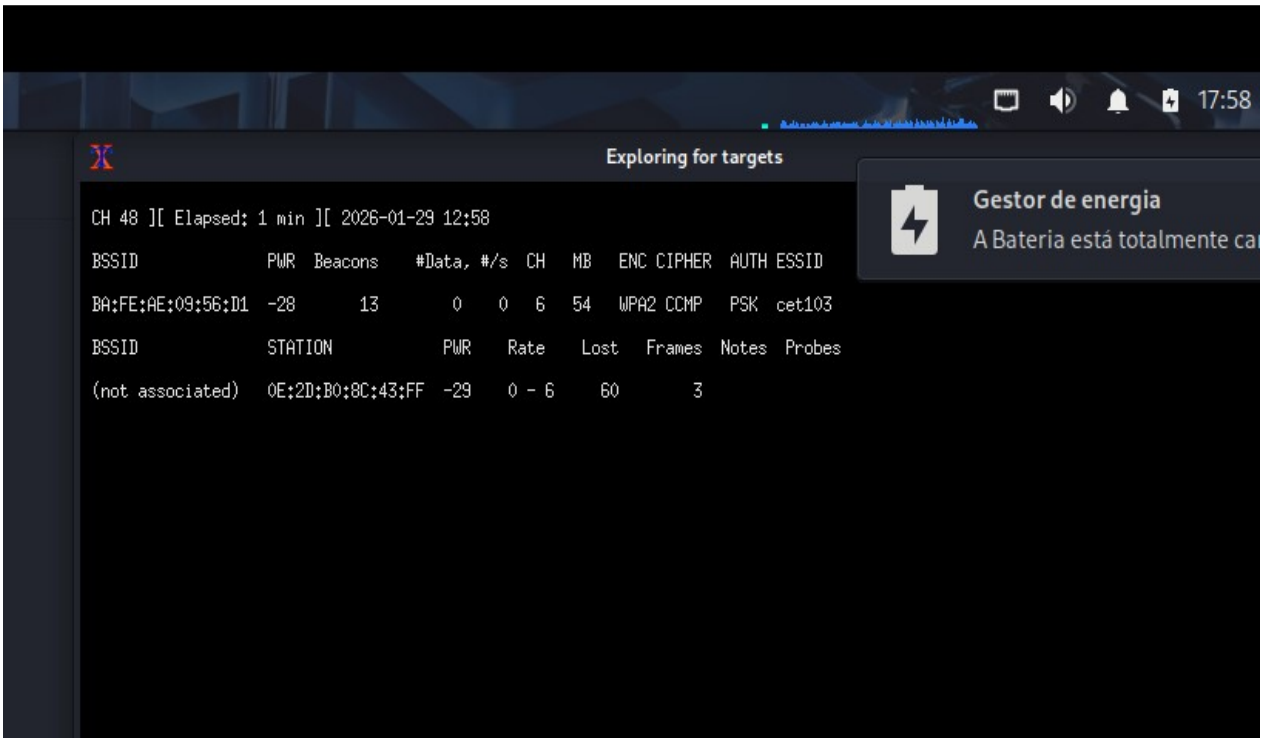
De seguida, selecione a opção 9, que irá efetuar uma análise aos Pontos de Acesso próximos.



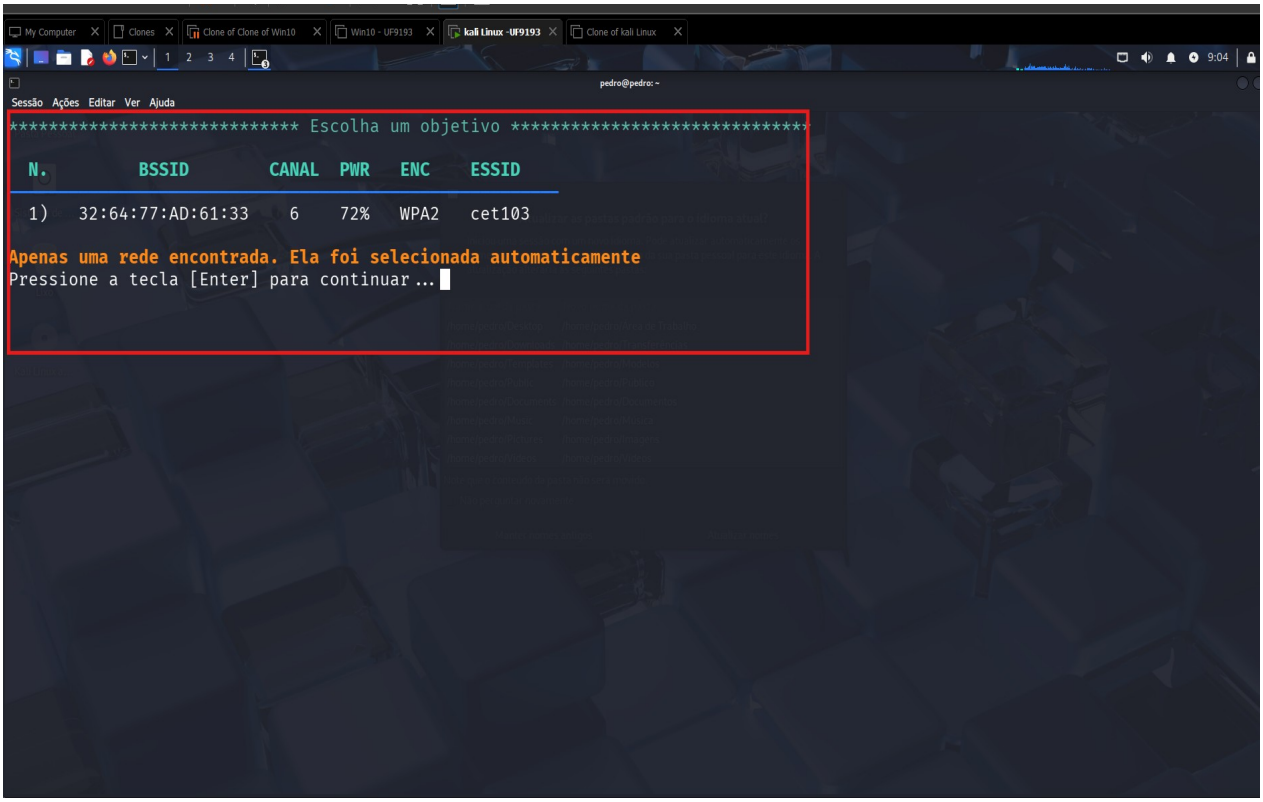
“Continuar ao pressionar a tecla ENTER, e será aberta uma janela para procurar (scan) pontos de acesso WPA/WPA2.”



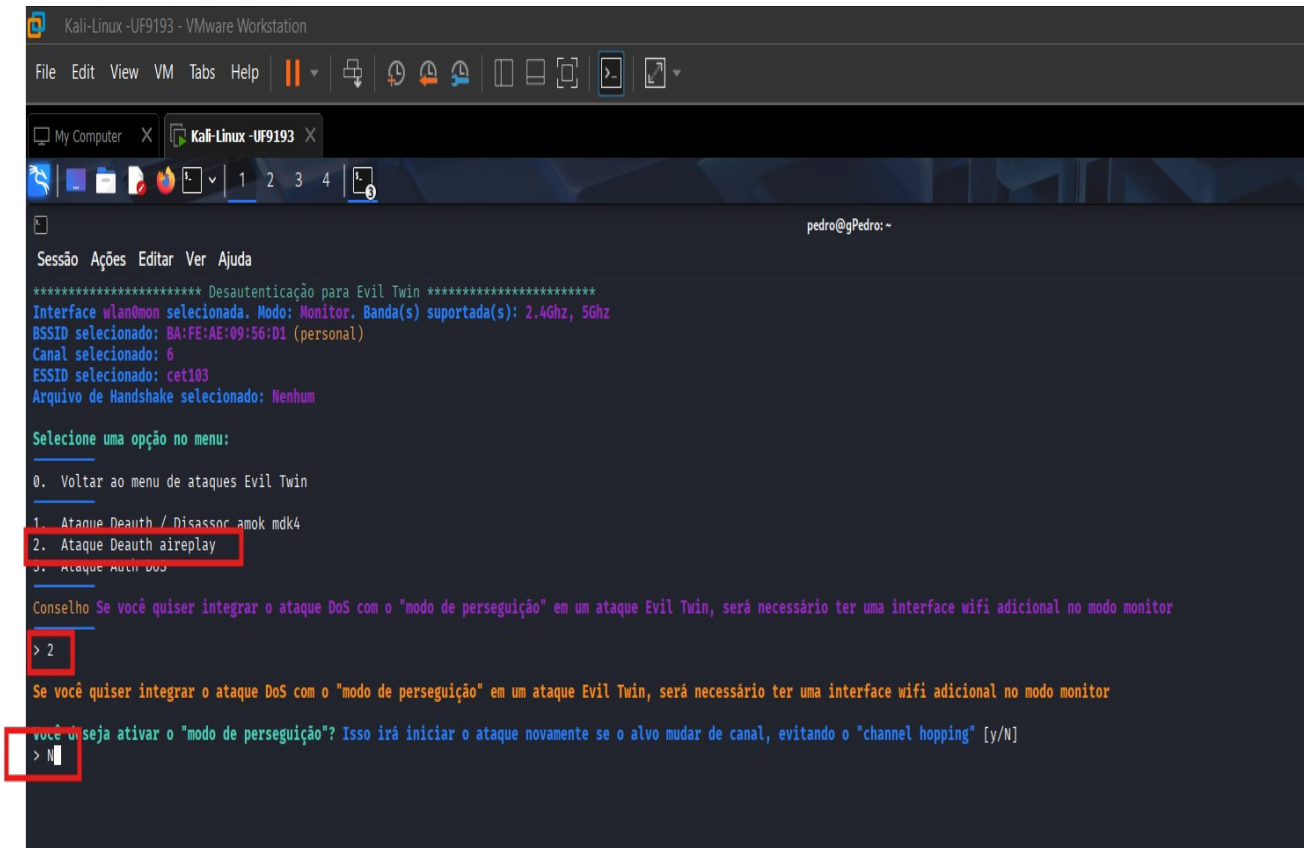
Amplificado :



Para terminar a varredura, utiliza-se **CTRL+C**, e será apresentada uma lista de todos os Pontos de Acesso que foram detetados. Deve escolher-se o AP que desperta mais curiosidade

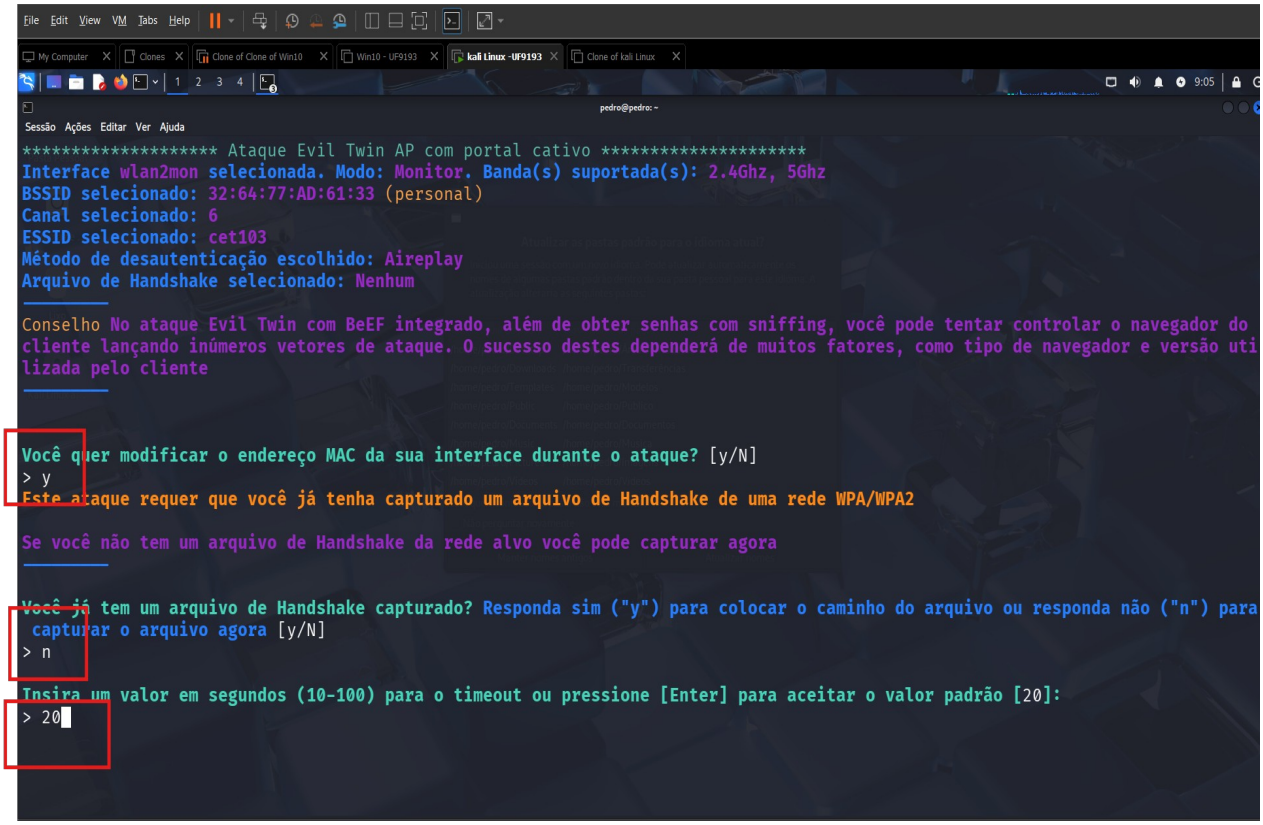


Seleciona-se a opção **2 para um ataque Deauth**, de forma a desligar o cliente do ponto de acesso selecionado.
De seguida, o sistema pode solicitar a ativação do modo **DoS pursuit,** o qual é rejeitado.

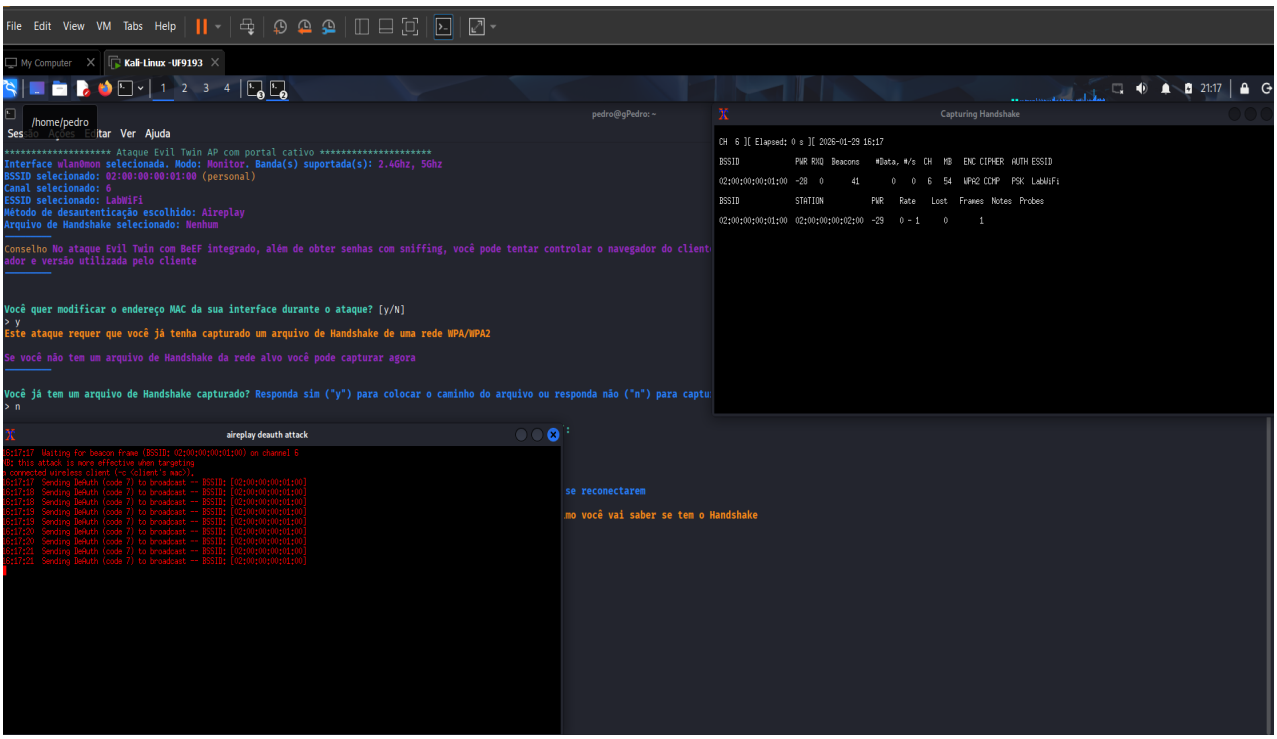


Antes de lançar o ataque de deauth e tentar capturar o handshake, serão feitas algumas perguntas, tais como:

Pretende falsificar (spoof) o seu endereço MAC durante este ataque [y/N]: y
Já possui um ficheiro capturado [y/N]: N
Valor de tempo em segundos: 20
Prima a tecla ENTER para aceitar a proposta

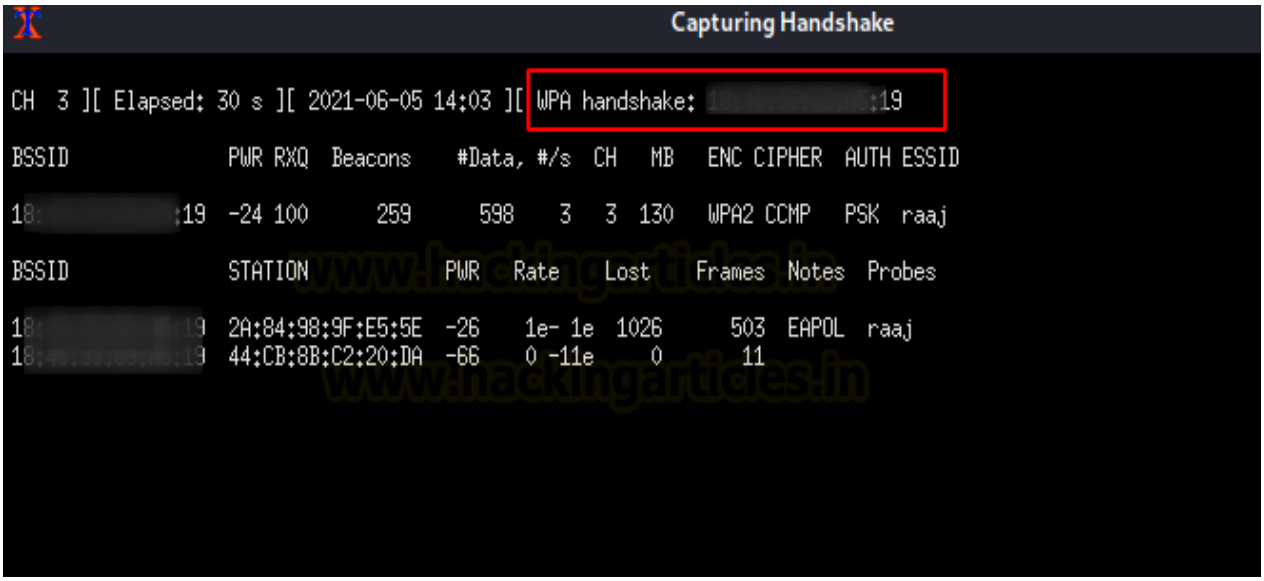


As duas janelas irão aparecer novamente. Uma irá tentar executar um ataque de deauth, enquanto a outra irá tentar capturar o handshake WPA entre o cliente e o ponto de acesso após a desautenticação



Aguardar até que o *handshake* WPA apareça no canto superior direito da janela e, de seguida,

CTRL + C..



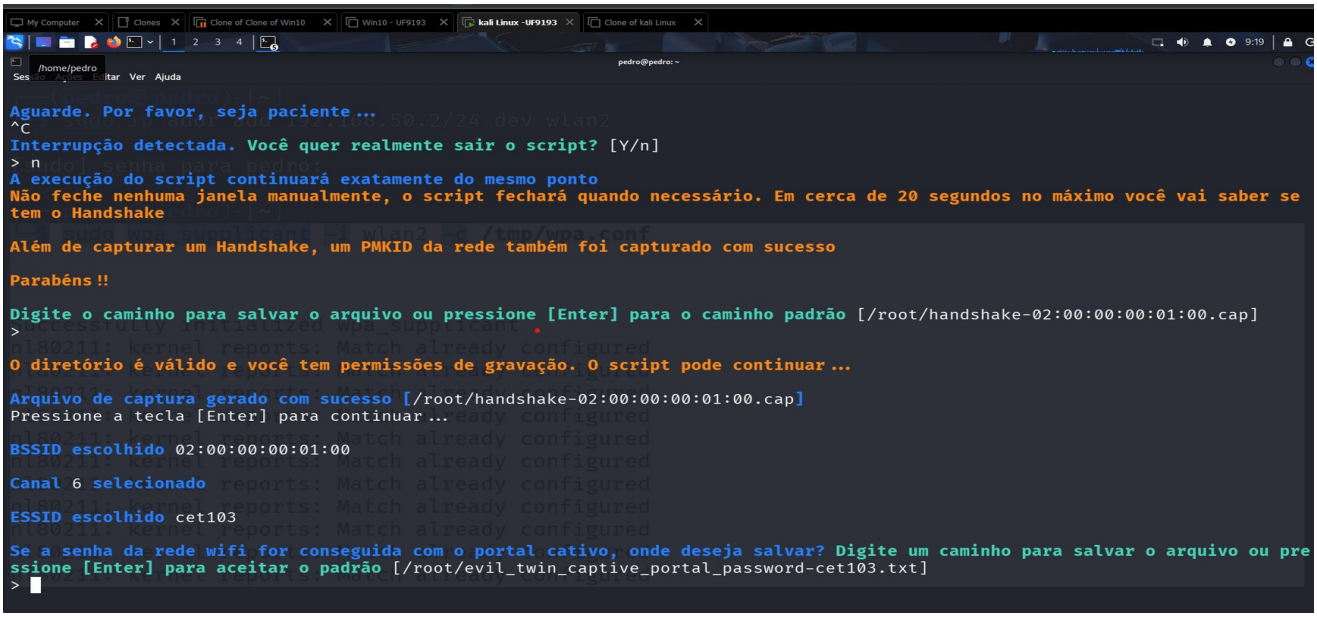
Captura do Handshake WPA e Gravação das Credenciais

Como se pode observar, estamos agora a obter o *handshake* WPA do ponto de acesso (AP) "raaj". Deve ser aceite o procedimento, guardando o ficheiro .cap no sistema e premindo a tecla ENTER.

De seguida, caso esteja a ser utilizado um portal cativo, será solicitado que se especifique o caminho para o ficheiro onde ficará guardada a palavra-passe da rede Wi-Fi.

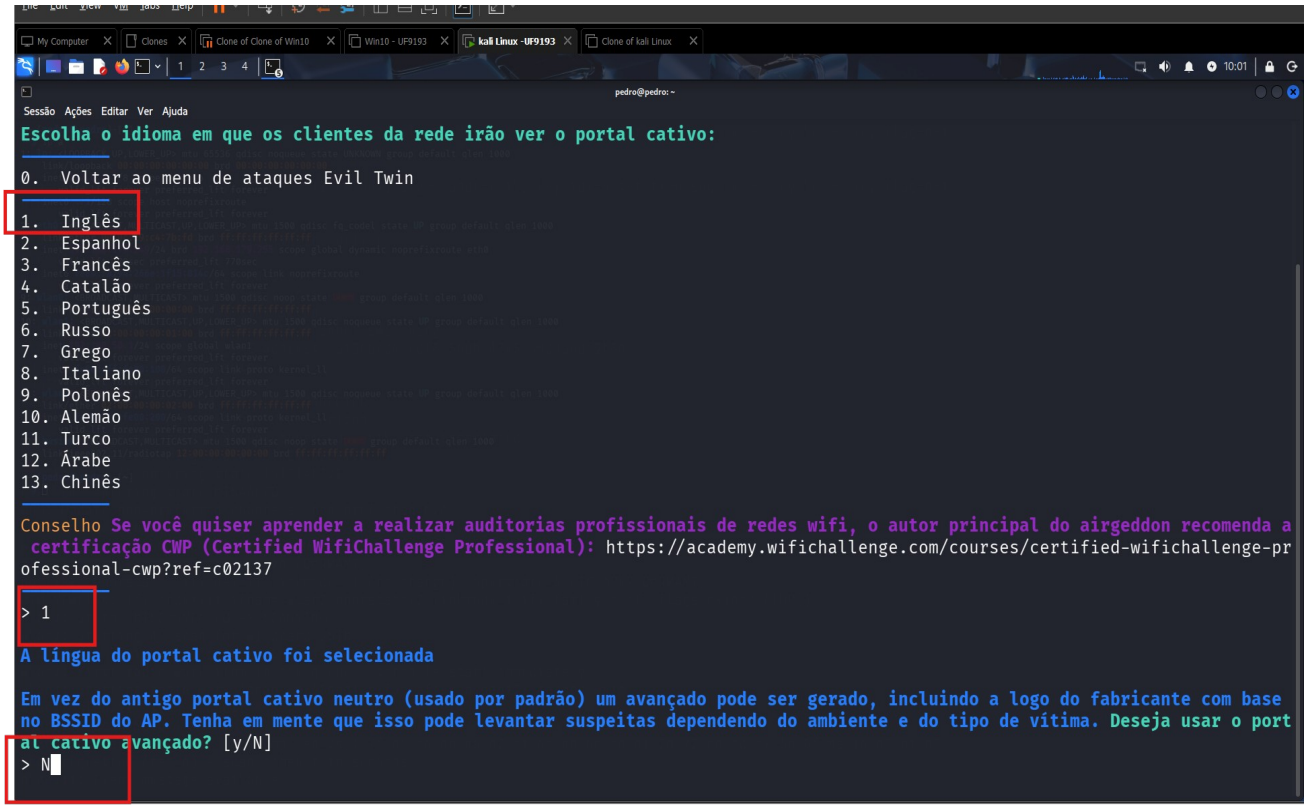
Se a palavra-passe da rede Wi-Fi for obtida através do portal cativo, deve ser definido o local onde a mesma será guardada, por exemplo:

[/root/evil_twin_captive_portal.password.txt]

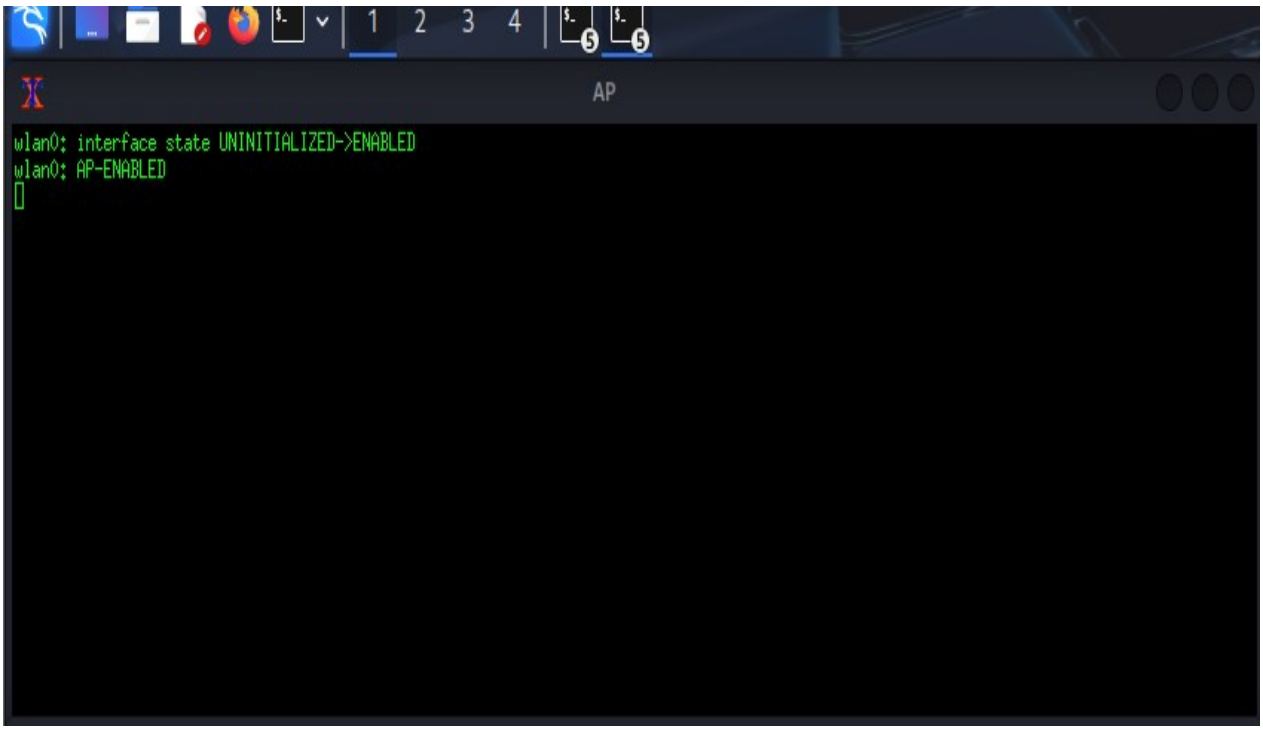


Configuração do Portal Cativo

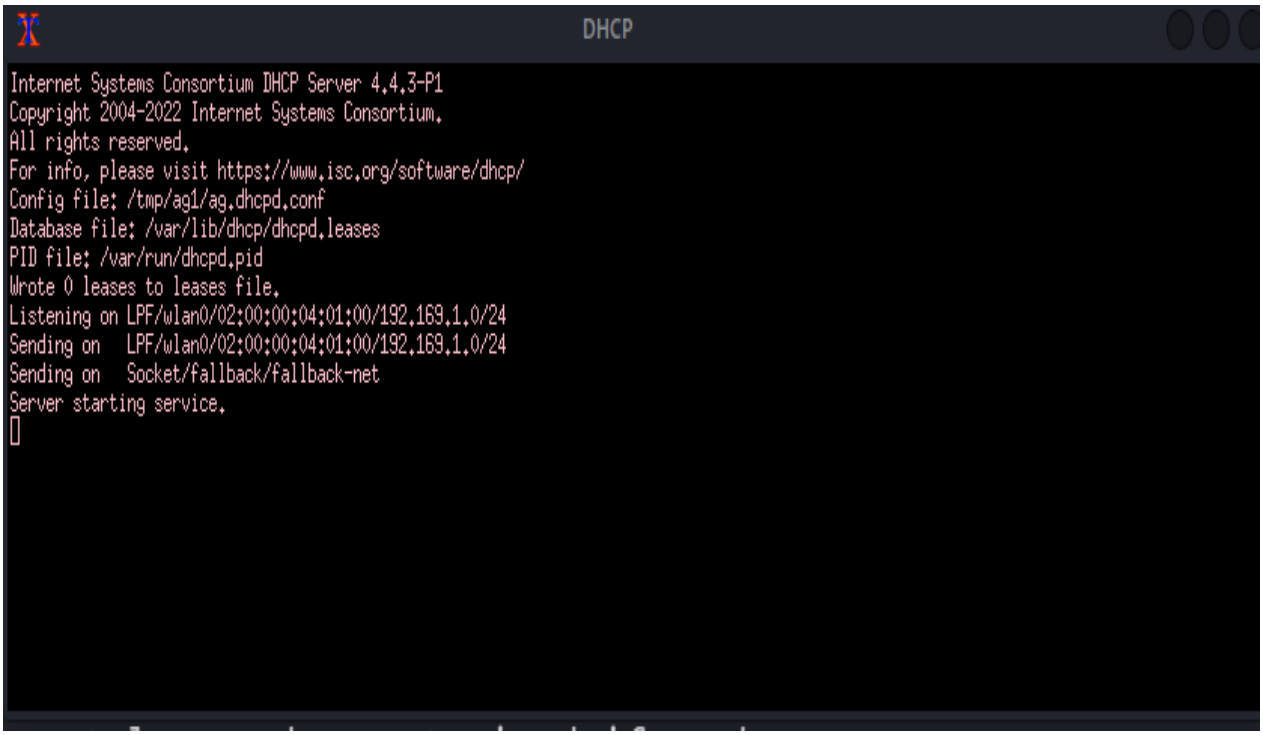
Criar um **portal cativo** para **realizar phishing ao cliente** e selecionar o **idioma** em que o portal web será apresentado ao utilizador.
Para **Inglês**, foi escolhida a **opção 1**. Assim que a opção selecionada for submetida, **serão abertas seis janelas** automaticamente



AP: criar um **ponto de acesso (AP) falso** para o cliente



DHCP: iniciar um **serviço DHCP fraudulento** para **fornecer um endereço IP malicioso ao cliente**.

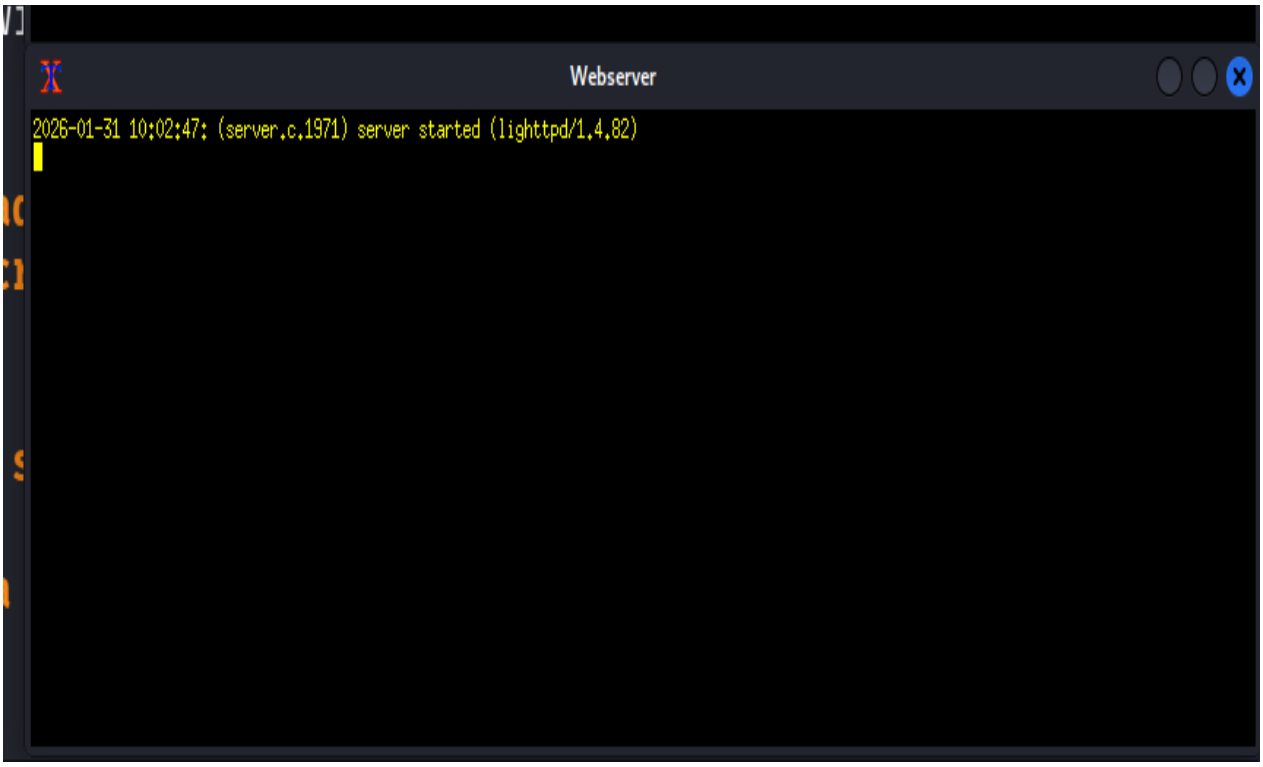


DNS: iniciar com a **consulta DNS maliciosa**.

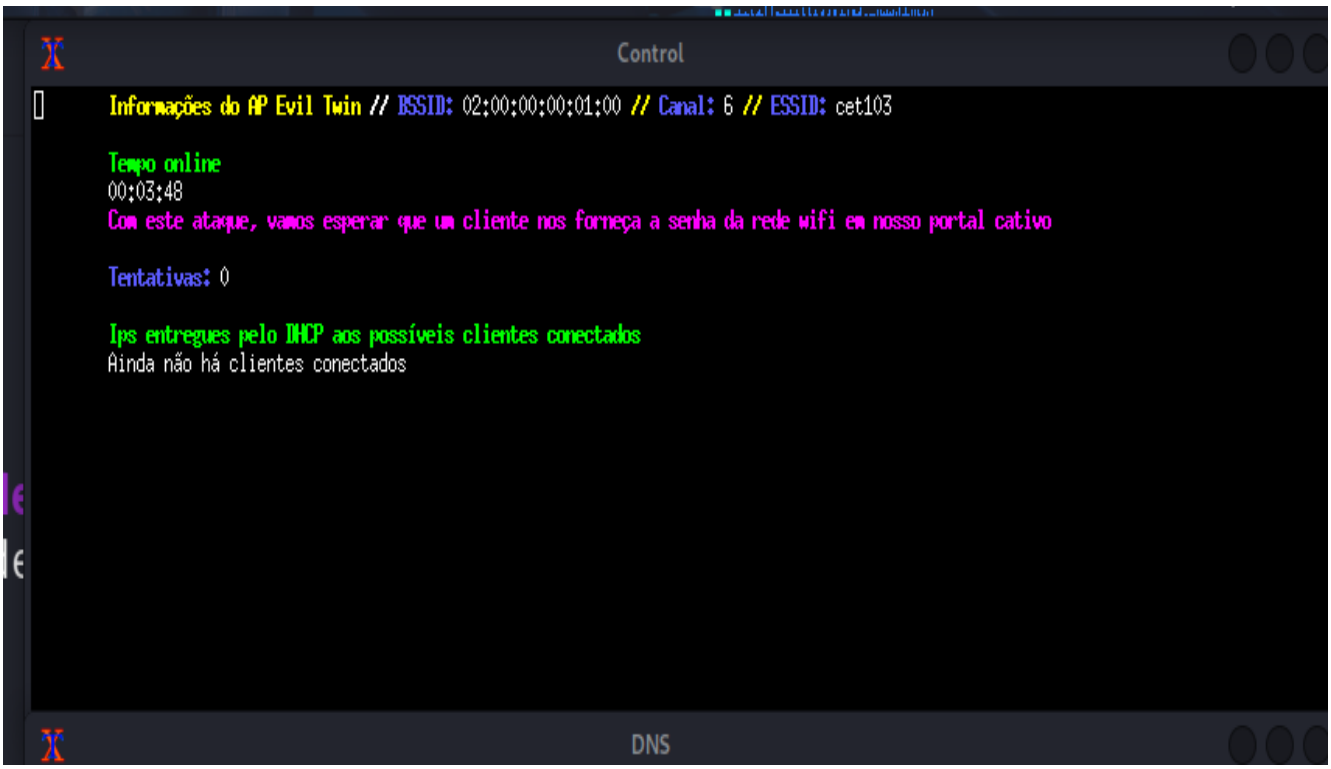


Deauth: desautenticar o cliente do **AP original**.

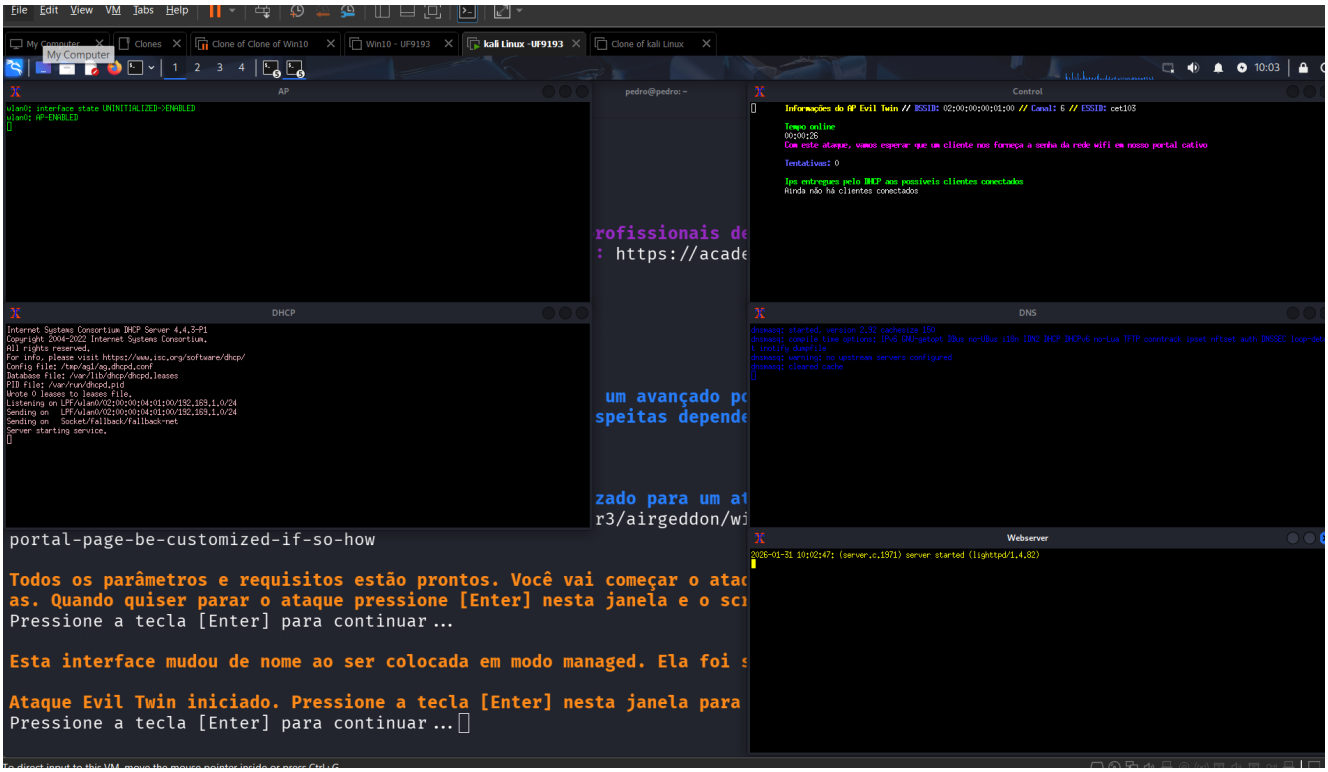
Servidor Web-Webserver: iniciar um **serviço para alojar o portal cativo**.



Controlo: tentar capturar a palavra-passe Wi-Fi assim que o cliente se ligar a um AP falso.
Nota: não fechar as janelas; estas encerram automaticamente após a palavra-passe ser capturada

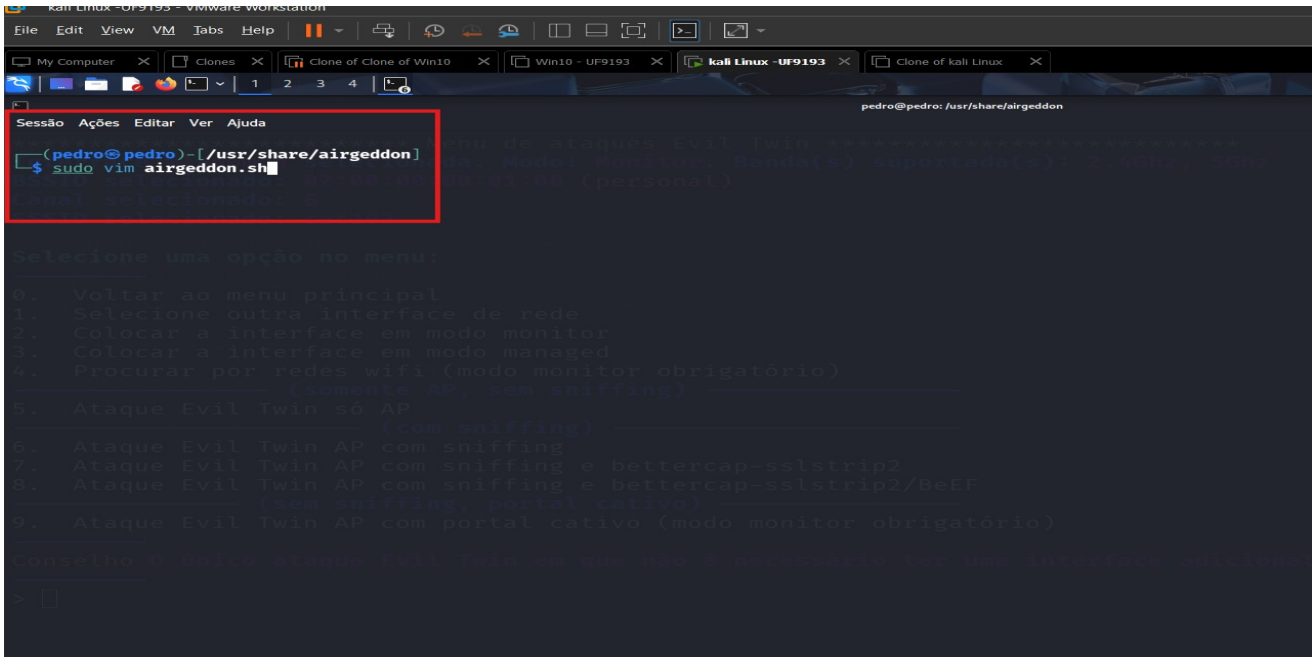


Continuação ...

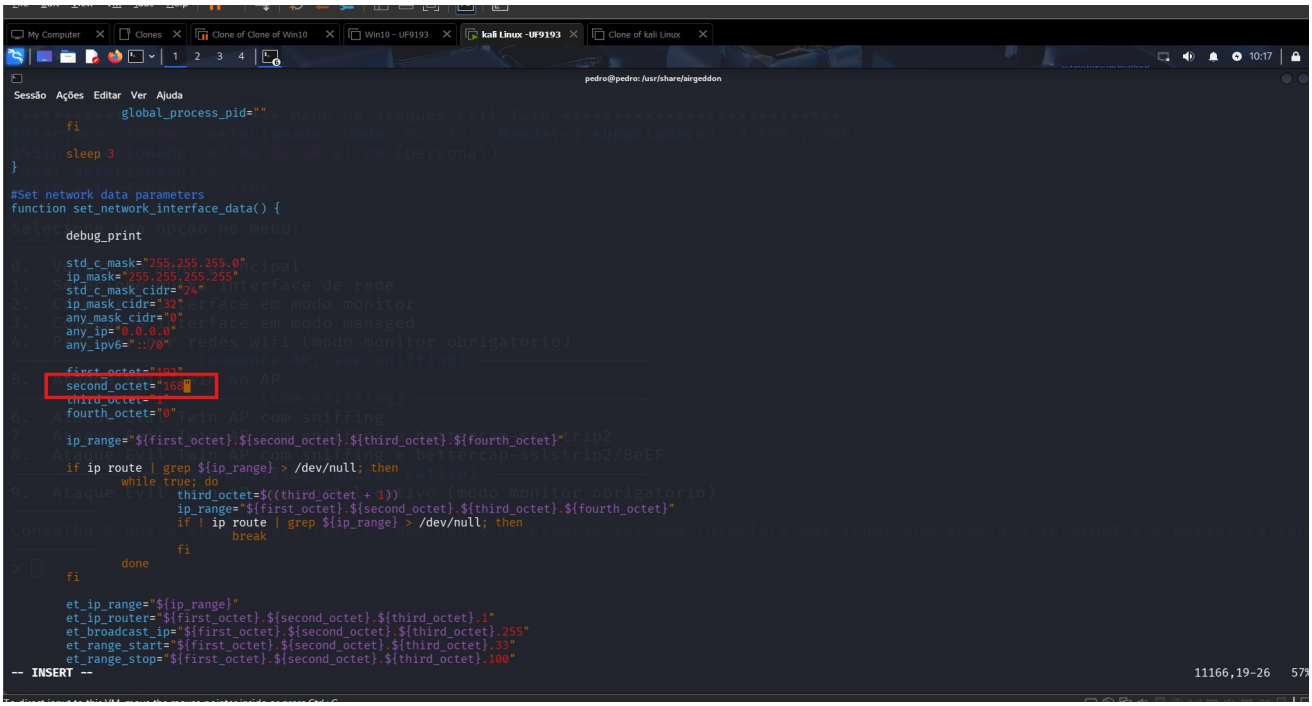


Todos os clientes que estejam ligados ao AP original serão desligados e, ao tentarem reconectar-se, irão encontrar dois APs com o mesmo nome.Quando o cliente se liga ao AP fraudulento, é redirecionado para o portal cativo.

Edição do ficheiro “airgeddon.sh”



Alterar linha :**second_octet=”168”**



O portal web cativo solicita ao cliente a introdução da palavra-passe da rede Wi-Fi para obter acesso à Internet. Caso o cliente introduza a palavra-passe correta, esta é capturada em texto simples pelo script e guardada automaticamente no ficheiro previamente definido, concluindo assim com sucesso o ataque Evil Twin.

Ataque PMKID

O PMKID (Pairwise Master Key Identifier) é o identificador único utilizado pelo ponto de acesso (AP) para controlar a PMK associada a um determinado cliente. Este identificador resulta da combinação do

endereço MAC do AP, do endereço MAC do cliente, da PMK e do respetivo nome, permitindo a sua obtenção sem que seja necessário capturar um handshake completo nem existir um cliente ativamente ligado à rede.

Para efetuar a captura do PMKID, executa-se novamente o script airgeddon e seleciona-se, no menu principal, a opção 5 - Handshake/PMKID tools menu.

[Inserir aqui captura de ecrã: menu principal do airgeddon com a opção 5 selecionada]

De seguida, seleciona-se novamente a opção 5 - Capture PMKID - momento em que o script inicia a pesquisa (scan) das redes WPA/WPA2 disponíveis nas proximidades.

[Inserir aqui captura de ecrã: seleção da opção "Capture PMKID" e scan em curso]

Terminada a pesquisa, é apresentada uma lista com as redes detetadas (BSSID, canal, potência do sinal, tipo de encriptação e ESSID). Deve selecionar-se a rede alvo introduzindo o respetivo número de série e, de seguida, definir um valor de timeout, em segundos, para o tempo de espera antes da tentativa de captura - por exemplo, 25 segundos.

[Inserir aqui captura de ecrã: lista de redes detetadas e seleção do alvo]

Caso a capture seja bem-sucedida, o PMKID da rede alvo é apresentado no ecrã, confirmando a obtenção do identificador necessário para o ataque offline.

[Inserir aqui captura de ecrã: PMKID capturado com sucesso]

Desencriptação do PMKID

O ficheiro do PMKID capturado pode ser guardado no formato .cap, respondendo afirmativamente (Y) à proposta do script e indicando o caminho pretendido para o ficheiro.

[Inserir aqui captura de ecrã: gravação do ficheiro PMKID em formato .cap]

Com o aircrack-ng integrado no próprio script, é possível proceder à quebra da chave diretamente a partir do ficheiro .cap gerado, sem sair do airgeddon. Para tal, no menu de desencriptação offline WPA/WPA2, seleciona-se a opção 1 - (aircrack) Dictionary attack against Handshake/PMKID capture file -, confirma-se a utilização do ficheiro de captura e do BSSID previamente selecionados e indica-se o caminho para o dicionário a utilizar.

Caminho do dicionário: /usr/share/wordlists/rockyou.txt

[Inserir aqui captura de ecrã: configuração do ataque de dicionário ao ficheiro PMKID]

Caso a palavra-passe conste do dicionário utilizado, esta é apresentada no ecrã assim que for encontrada, concluindo com sucesso o ataque PMKID.

[Inserir aqui captura de ecrã: palavra-passe encontrada (KEY FOUND)]

📋 **Ficha Técnica — Módulo 6**

Recolha e Análise de Informação (Sniffing)

Campo	Valor
Módulo	6 - Recolha e análise de informação (Sniffing)
Atacante / Ponto de captura	Kali Linux — 192.168.56.102
Alvo	Windows Server — 192.168.56.103
Objetivo	Capturar e analisar o tráfego de rede trocado com o alvo, identificando protocolos em uso, dados transmitidos em texto simples e informação potencialmente sensível
Ferramentas	*(ex: Wireshark, tcpdump, Ettercap, Bettercap...)*
Modo de captura	*(ex: passivo / ativo com ARP Spoofing e Man-in-the-Middle)*
Protocolos analisados	*(ex: HTTP, FTP, SMB, DNS...)*
Resultado esperado	Identificação de credenciais, comandos ou dados sensíveis visíveis em texto simples no tráfego capturado

📋 **Ficha Técnica — Módulo 7**

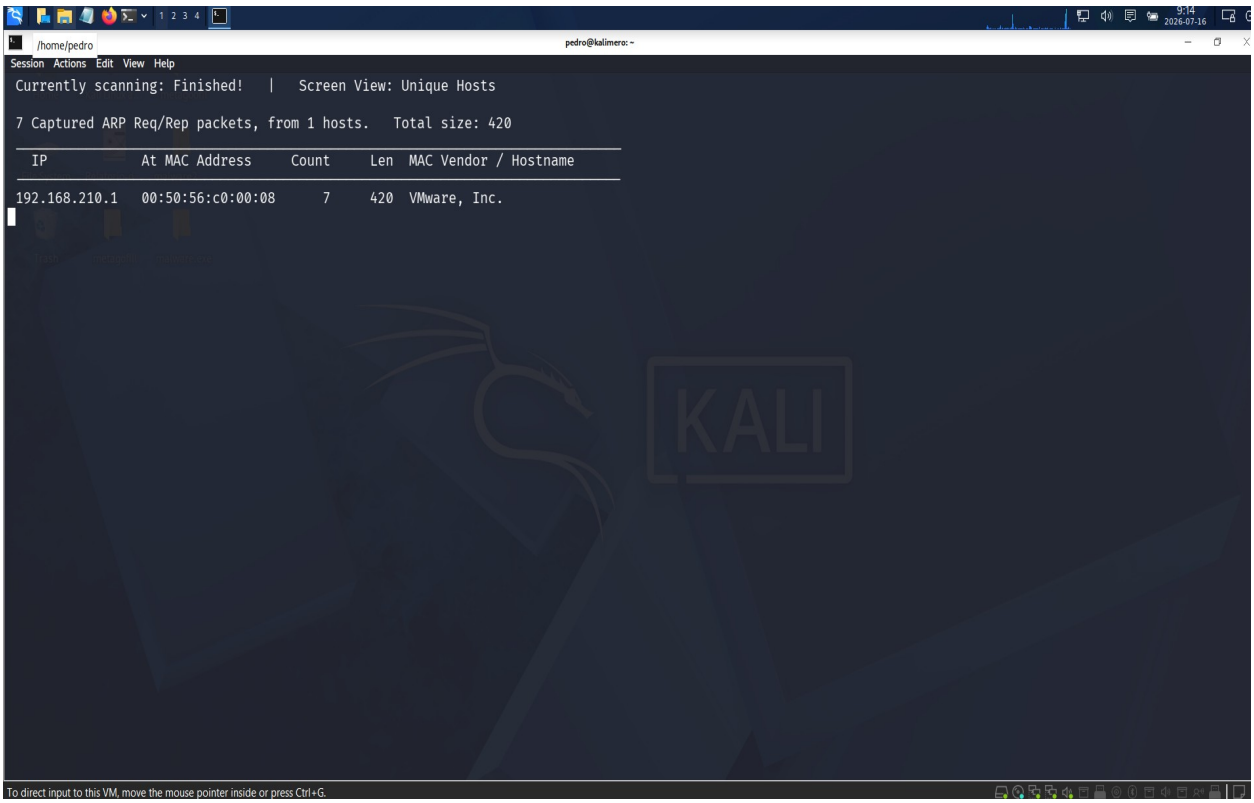
Análise de Sistemas e Protocolos (Scanning e Enumeration)

Campo	Valor
Módulo	7 – Análise de sistemas e protocolos (Scanning e Enumeration)
Atacante	Kali Linux — 192.168.56.102
Alvo	Windows Server — 192.168.56.103
Objetivo	Identificar hosts ativos, portas e serviços abertos, versões de software e recursos partilhados expostos pelo alvo
Ferramentas	*(ex: Nmap, enum4linux-ng, smbclient, rpcclient, smbmap...)*
Fases	1. Scanning – deteção de host, portas e serviços 2. Enumeration – extração detalhada de shares, utilizadores, grupos, versões de serviço
Portas/Serviços relevantes	*(ex: 445/SMB, 139/NetBIOS, 3389/RDP, 53/DNS...)*
Resultado esperado	Mapeamento da superfície de ataque do Windows Server: serviços expostos e possíveis vetores de exploração

Descoberta / Mapeamento de rede

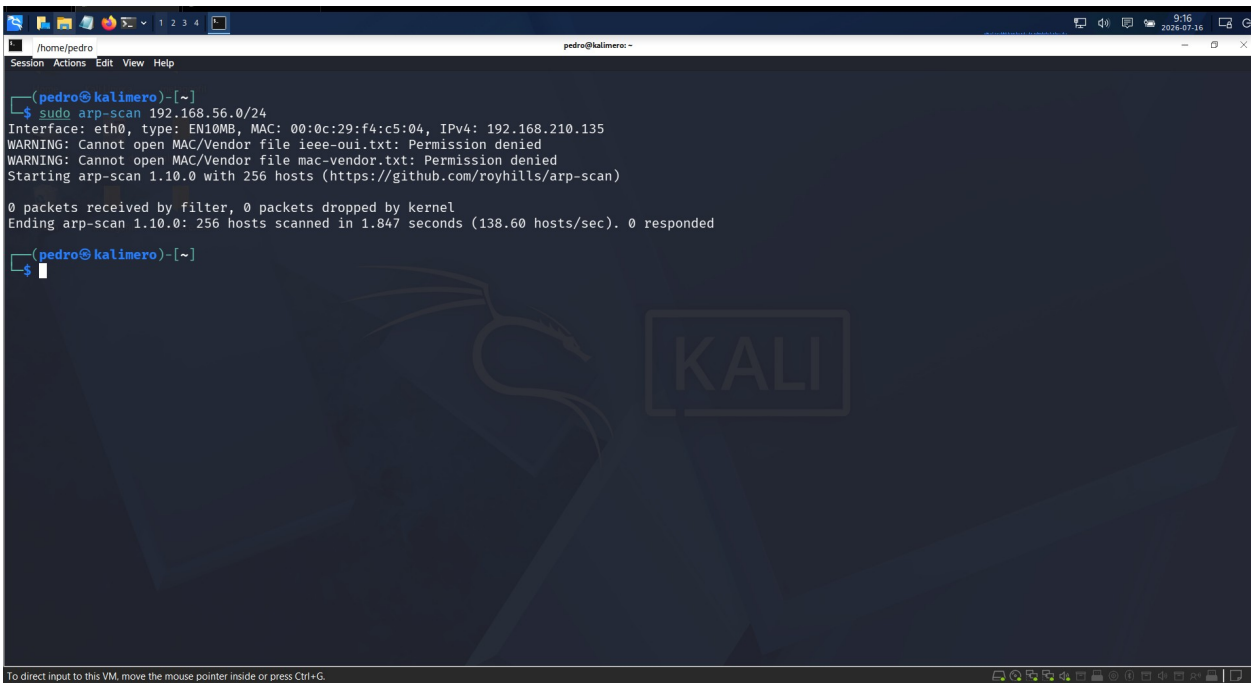
Netdiscover (rede /24 assumindo a sub-rede do host-only)

sudo netdiscover -r 192.168.56.0/24



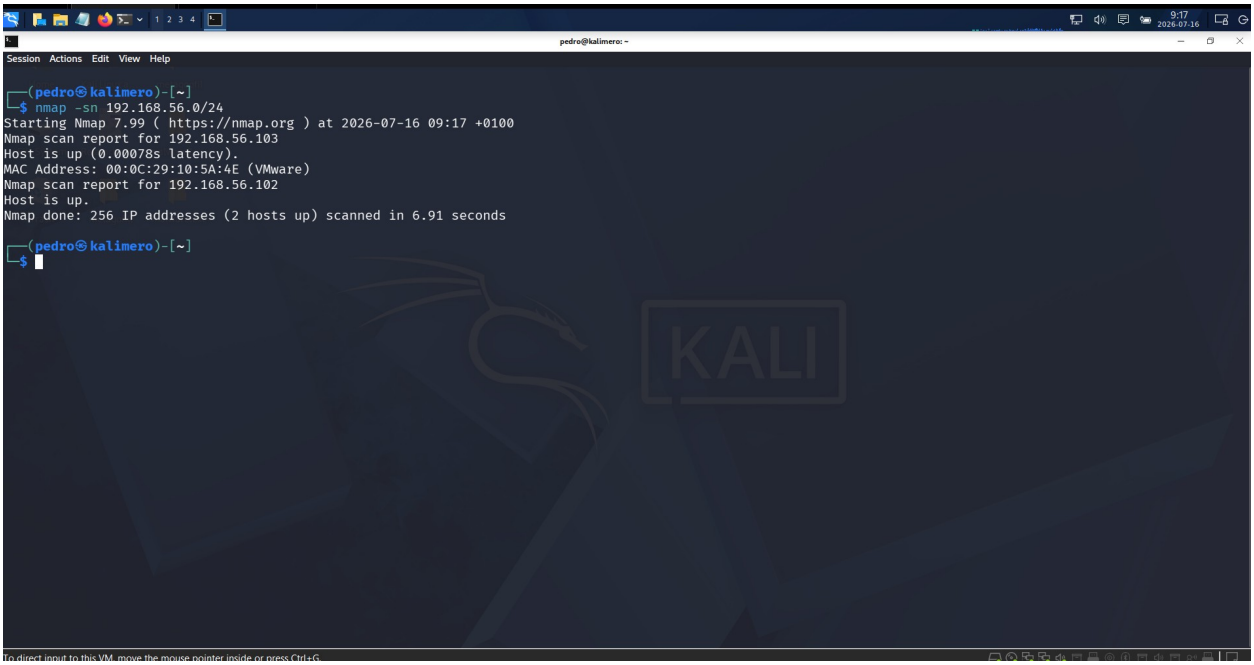
Arp-scan

sudo arp-scan 192.168.56.0/24



Nmap - ping scan (descoberta de hosts)

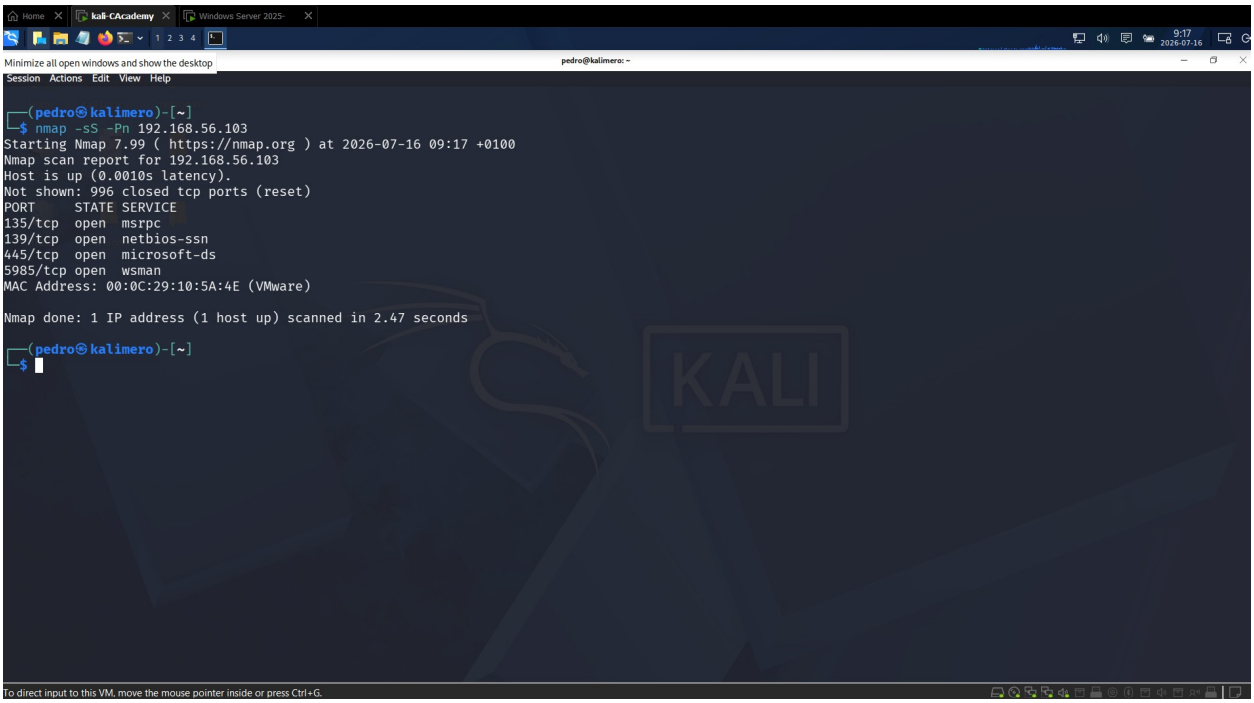
nmap -sn 192.168.56.0/24



Scanning de portas (nmap)

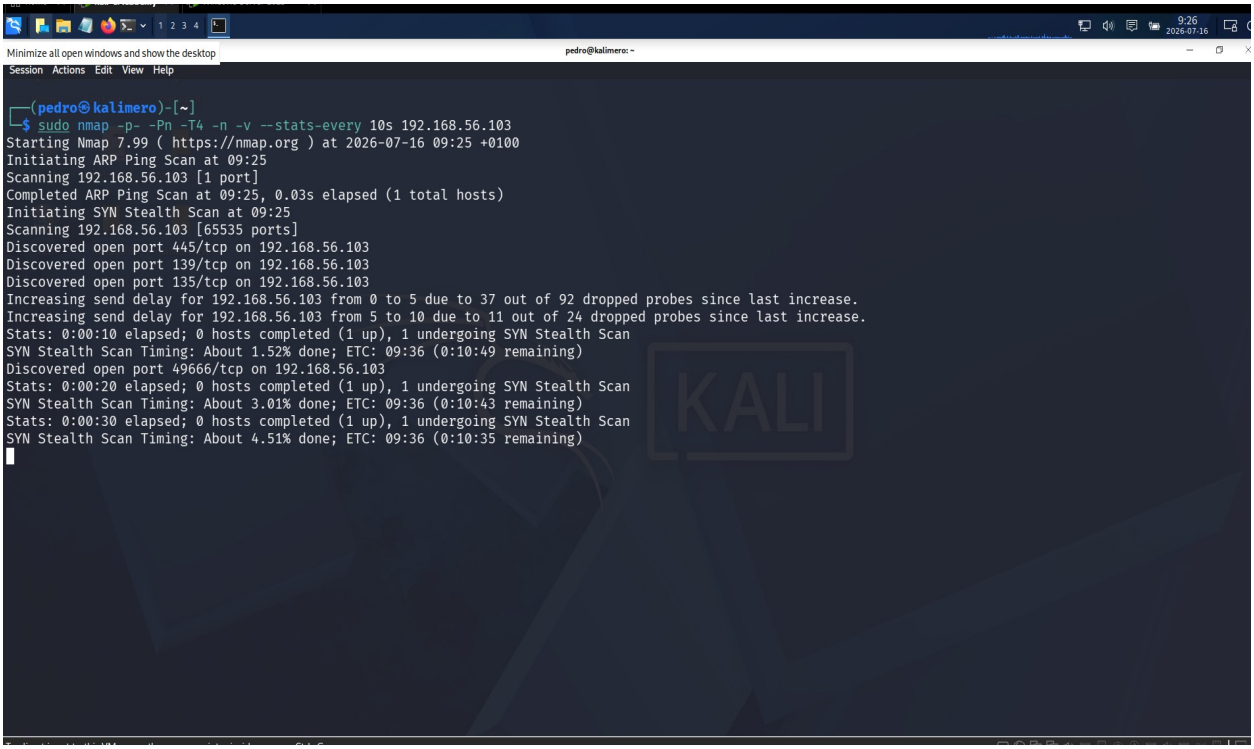
Scan básico TCP ao Windows Server

nmap -sS -Pn 192.168.56.103



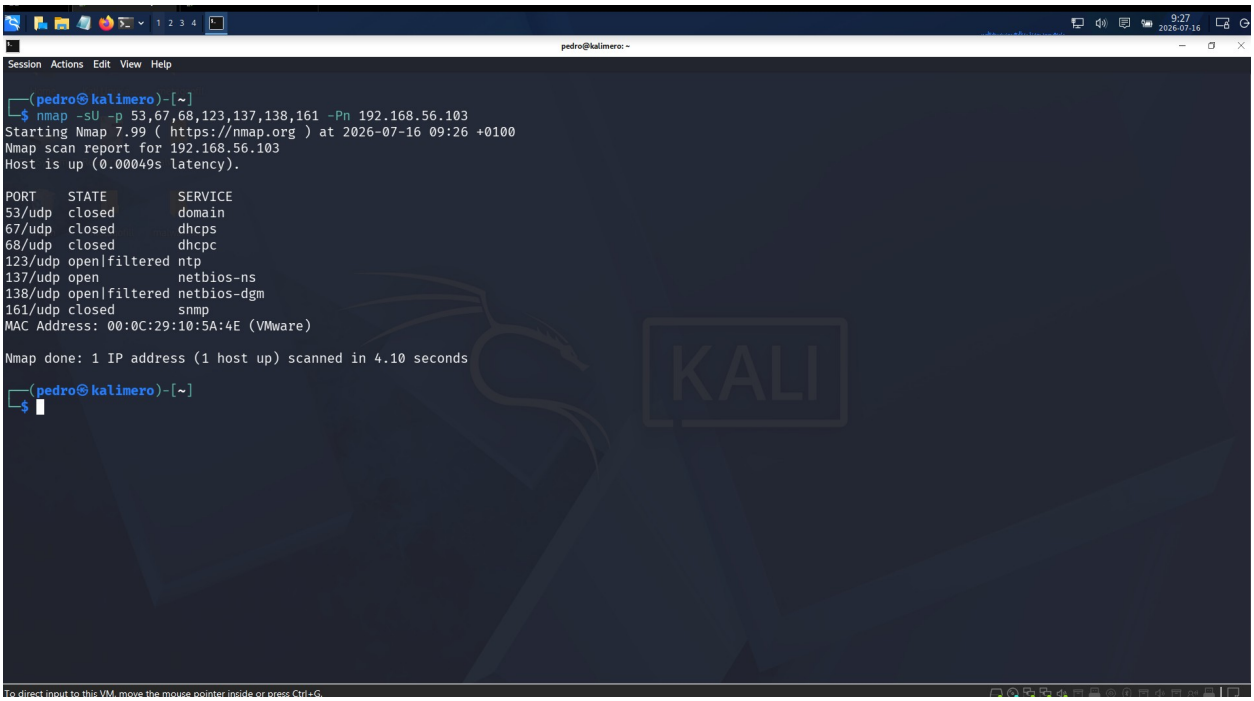
Todas as portas TCP

sudo nmap -p- -Pn -T4 -n -v --stats-every 10s 192.168.56.103



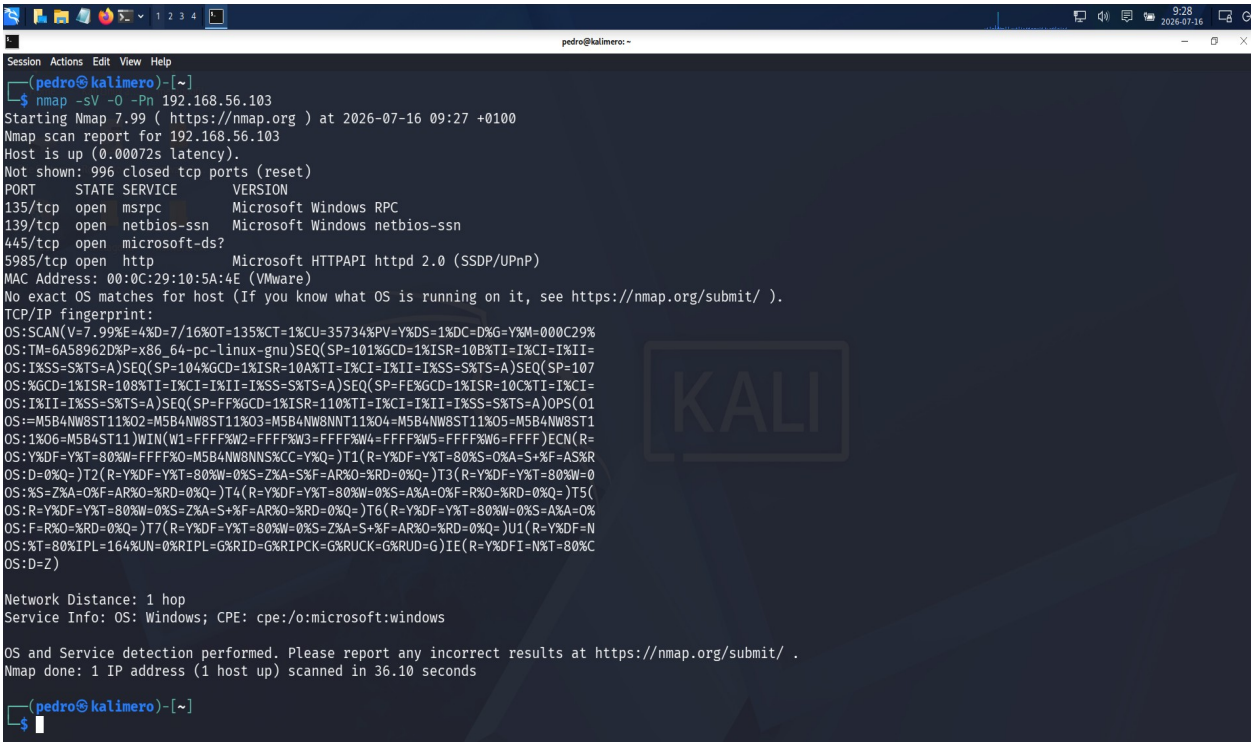
UDP (mais lento, escolher portas comuns)

nmap -sU -p 53,67,68,123,137,138,161 -Pn 192.168.56.103



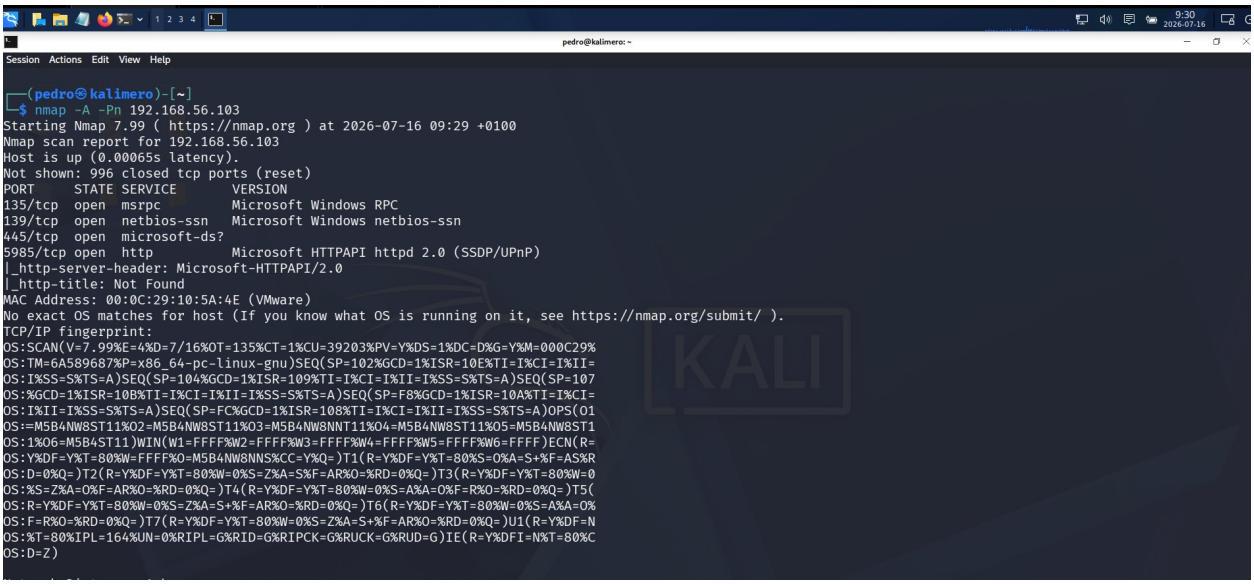
Scan com deteção de versão e SO

nmap -sV -O -Pn 192.168.56.103



Scan agressivo (versões + SO + scripts default + traceroute)

nmap -A -Pn 192.168.56.103



Continucao ...

```
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

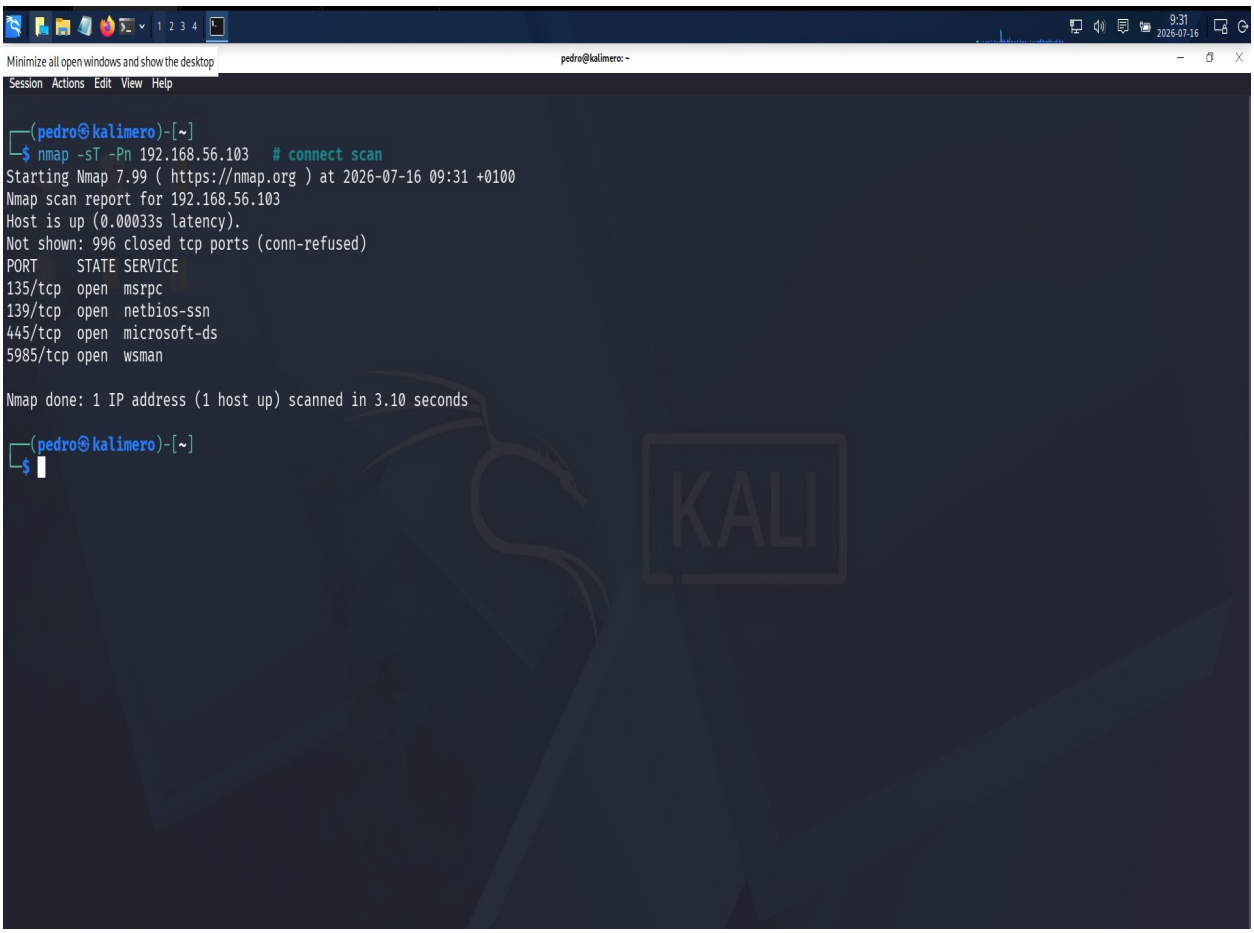
Host script results:
|_nbstat: NetBIOS name: WIN-KIT0B2F912N, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:10:5a:4e (VMware)
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
| smb2-time:
|   date: 2026-07-16T08:29:54
|_  start_date: N/A

TRACEROUTE
HOP RTT     ADDRESS
1   0.65 ms 192.168.56.103

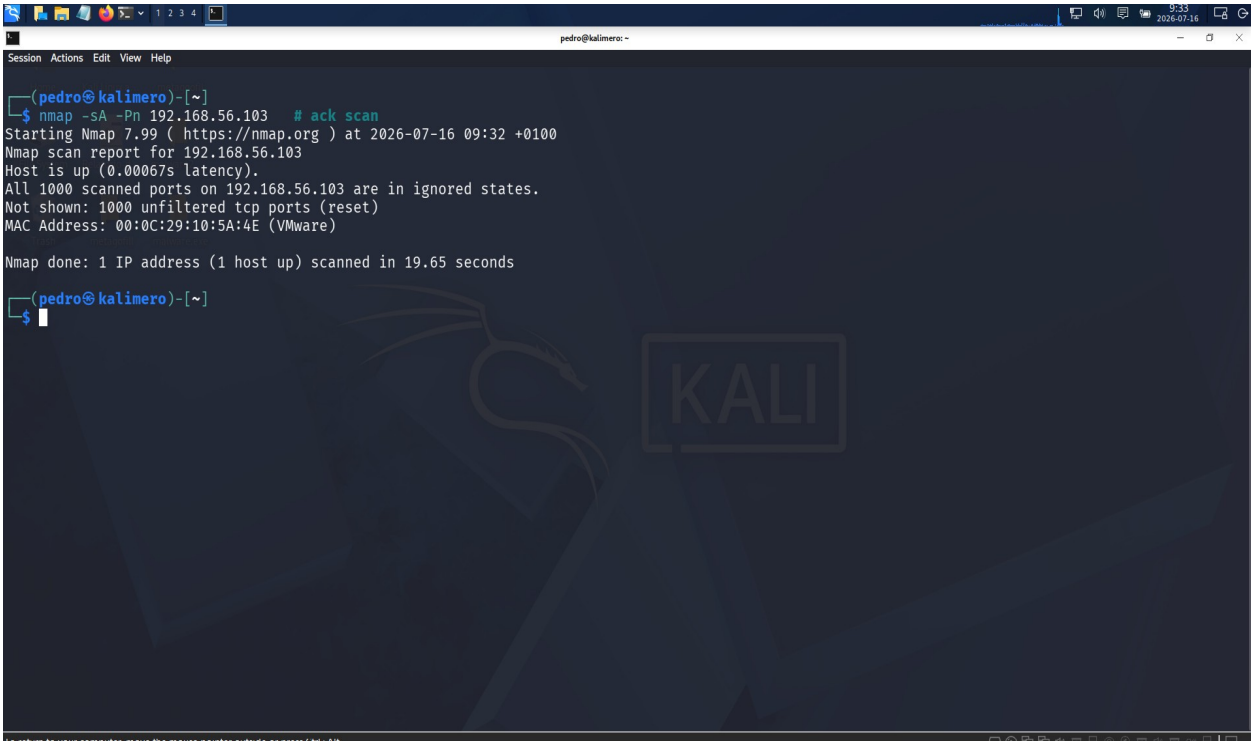
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.93 seconds
```

Scans com flags TCP diferentes (testar firewall/comportamento)

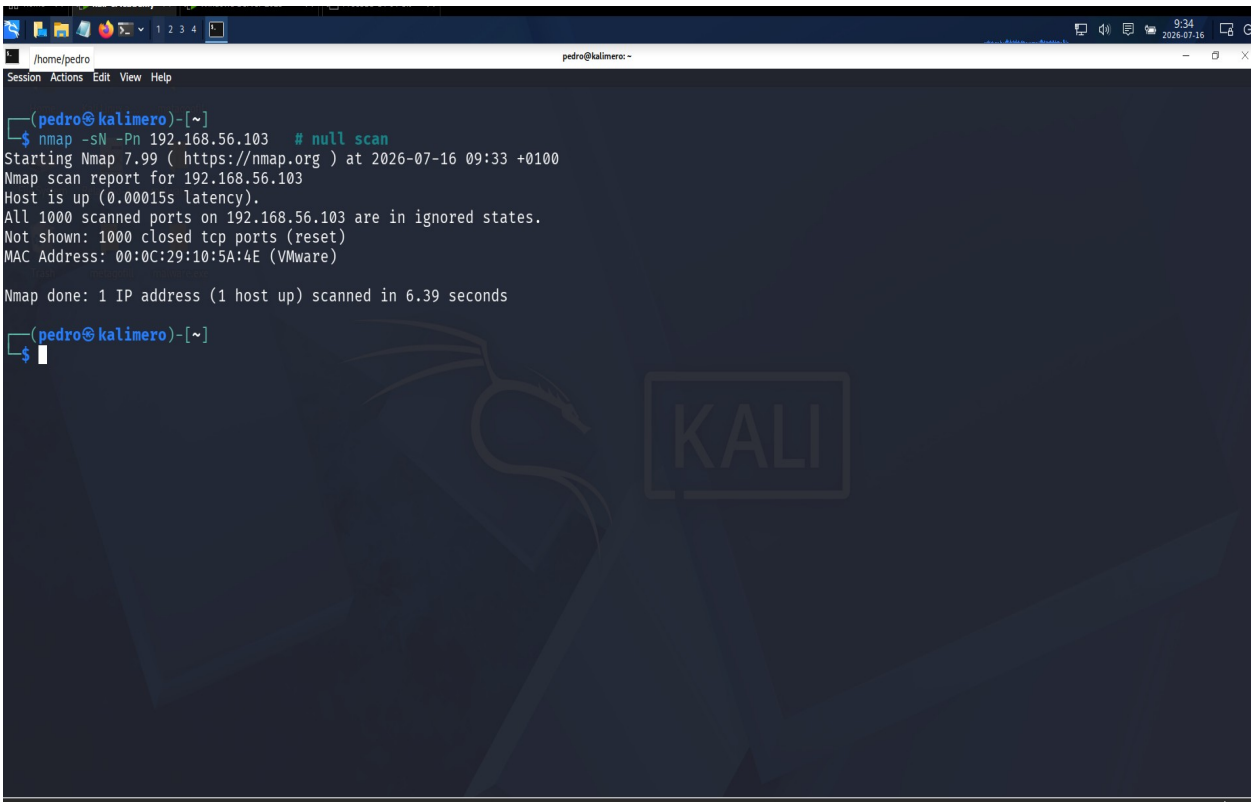
nmap -sT -Pn 192.168.56.103 # connect scan



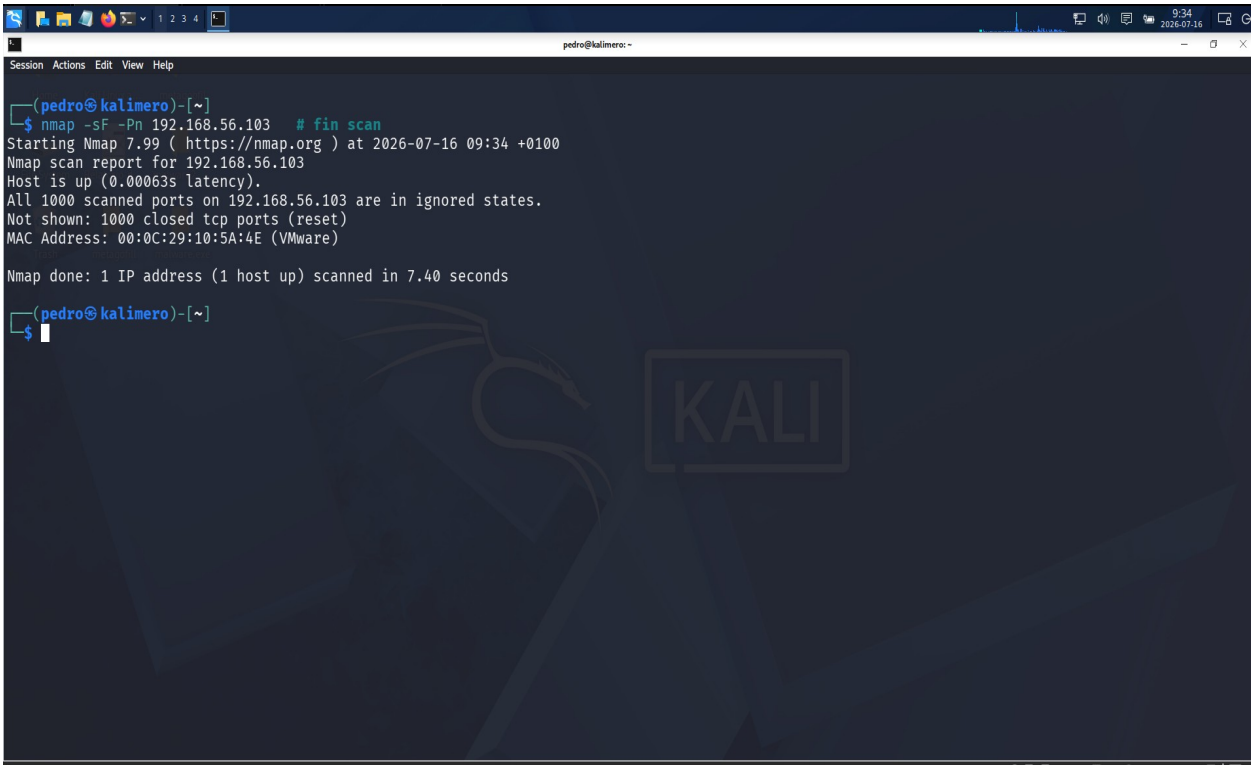
nmap -sA -Pn 192.168.56.103 # ack scan



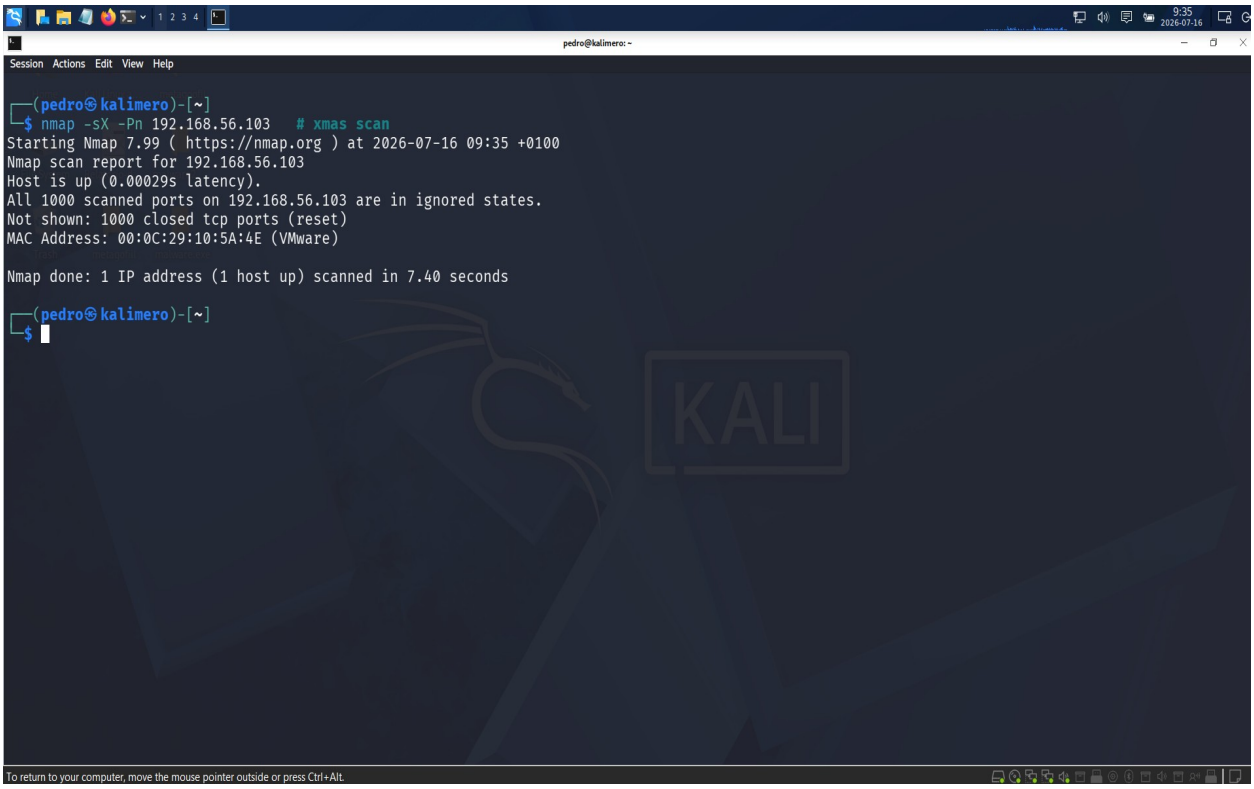
nmap -sN -Pn 192.168.56.103 # null scan



nmap -sF -Pn 192.168.56.103 # fin scan

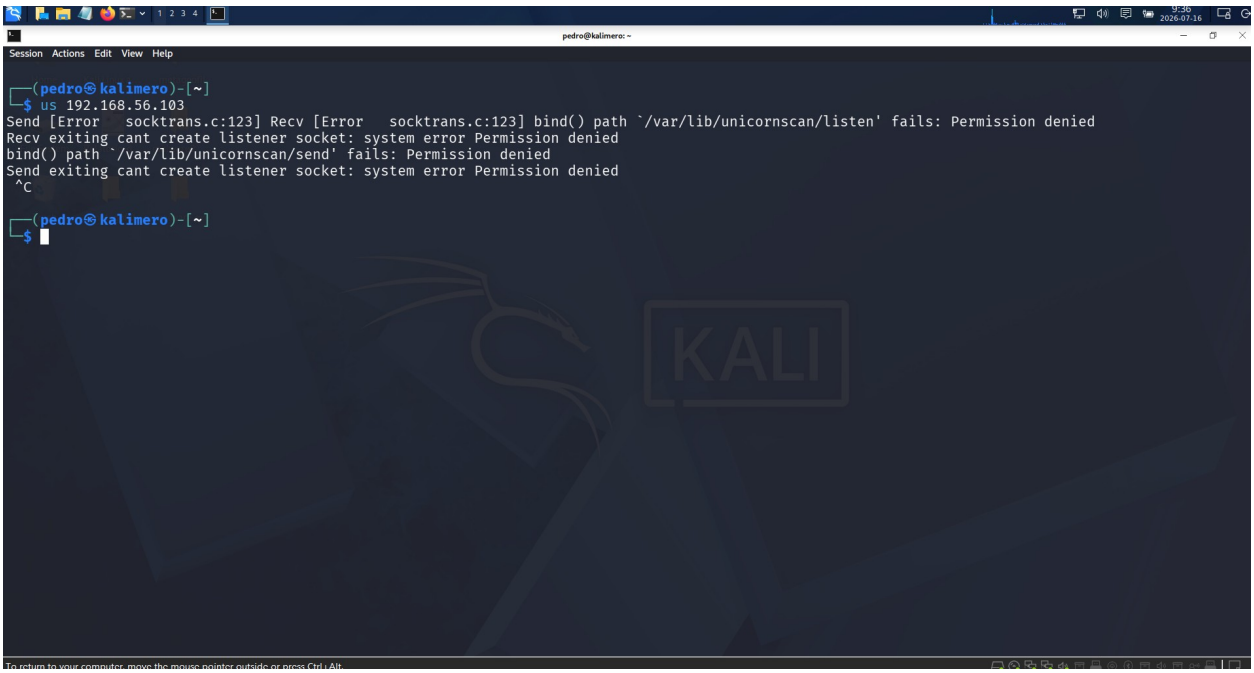


nmap -sX -Pn 192.168.56.103 # xmas scan

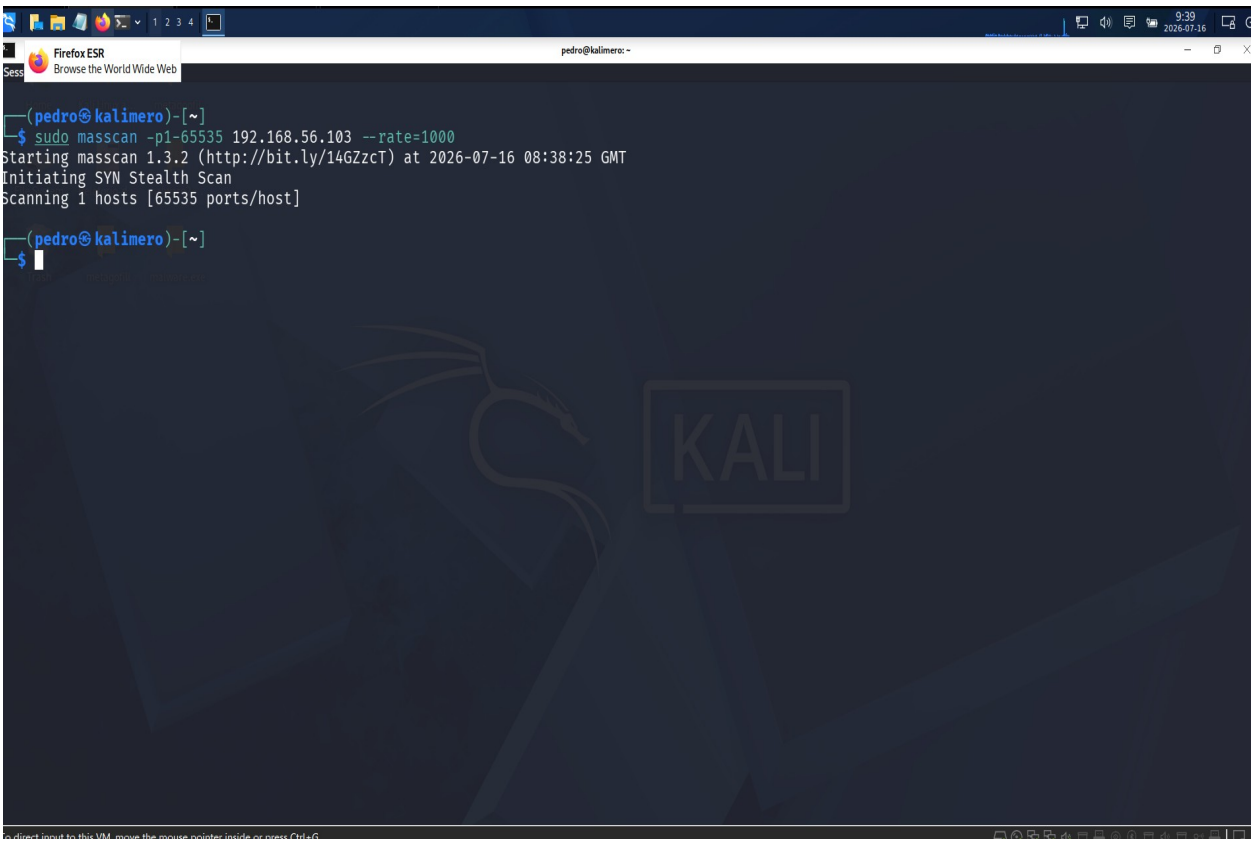


Unicornscan / Masscan / Hping3

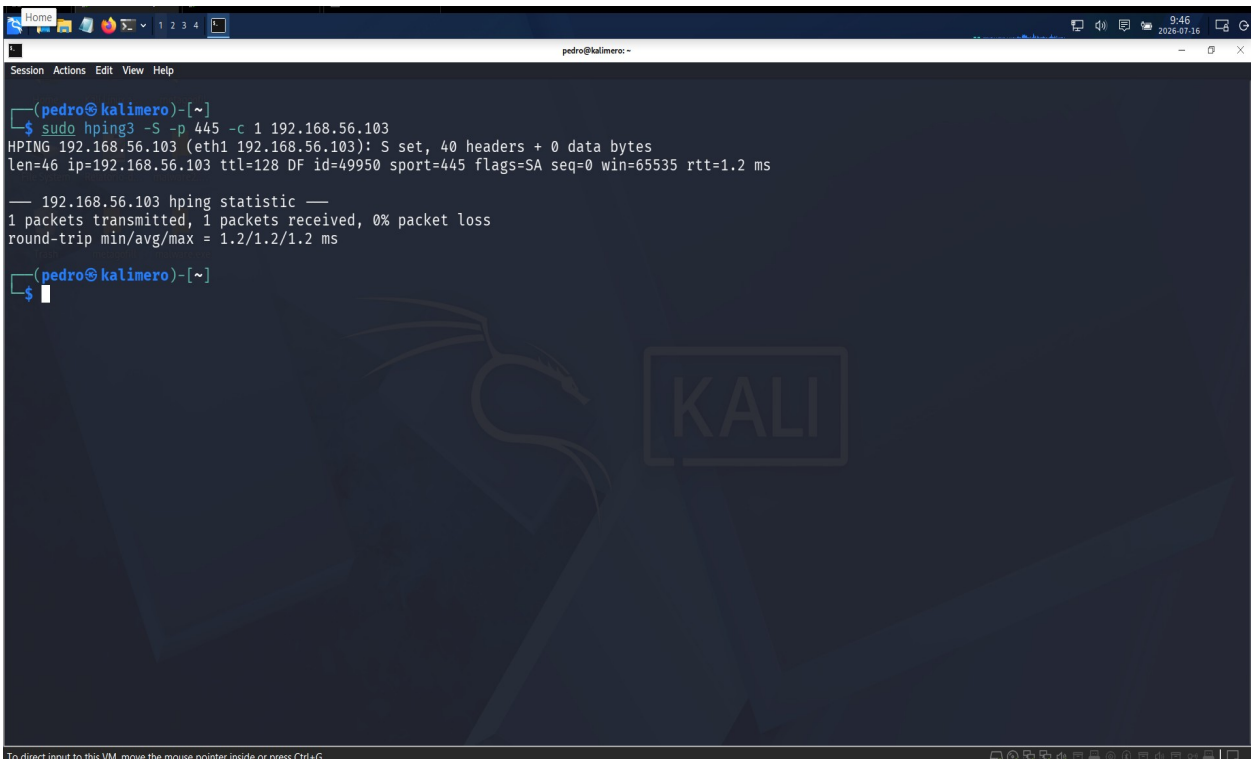
us 192.168.56.103



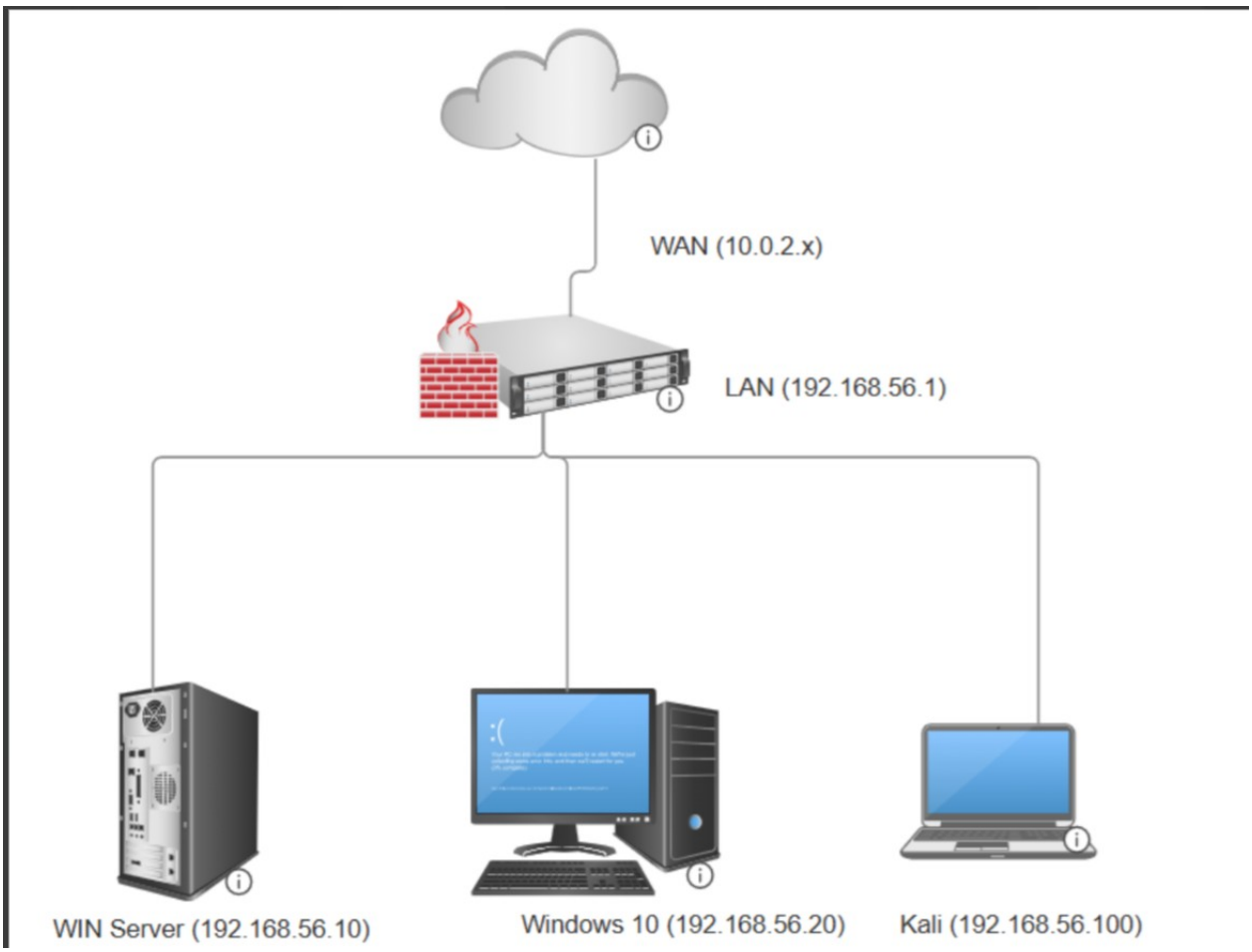
sudo masscan -p1-65535 192.168.56.103 --rate=1000



sudo hping3 -S -p 445 -c 1 192.168.56.103



Enumeration — banner grabbing e SO



topologia:

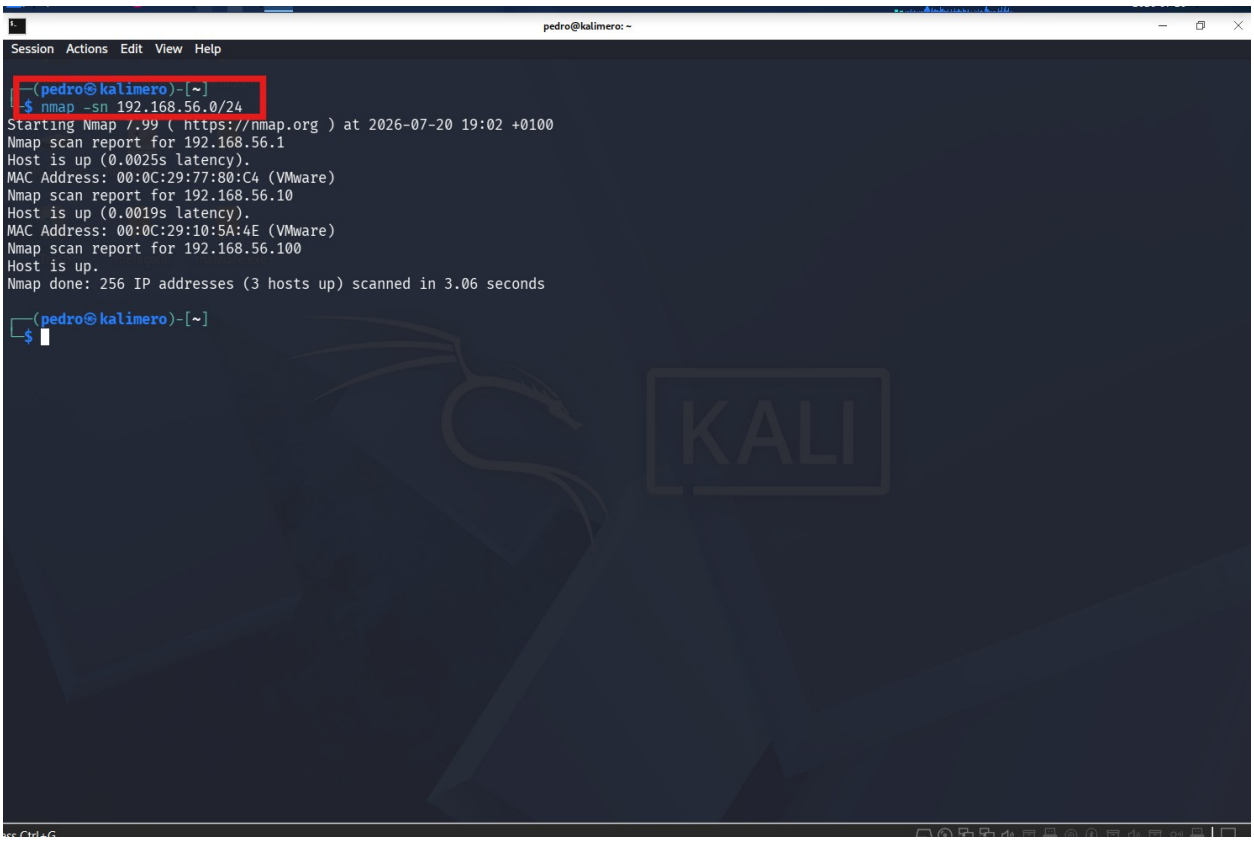
- **Atacante (Kali): 192.168.56.100**
- **Alvo 1 (WIN Server): 192.168.56.10**
- **Alvo 2 (Windows 10): 192.168.56.20**
- **Firewall/Gateway (LAN): 192.168.56.1**

Todos os comandos abaixo correm a partir do Kali.

1. Descoberta inicial da rede

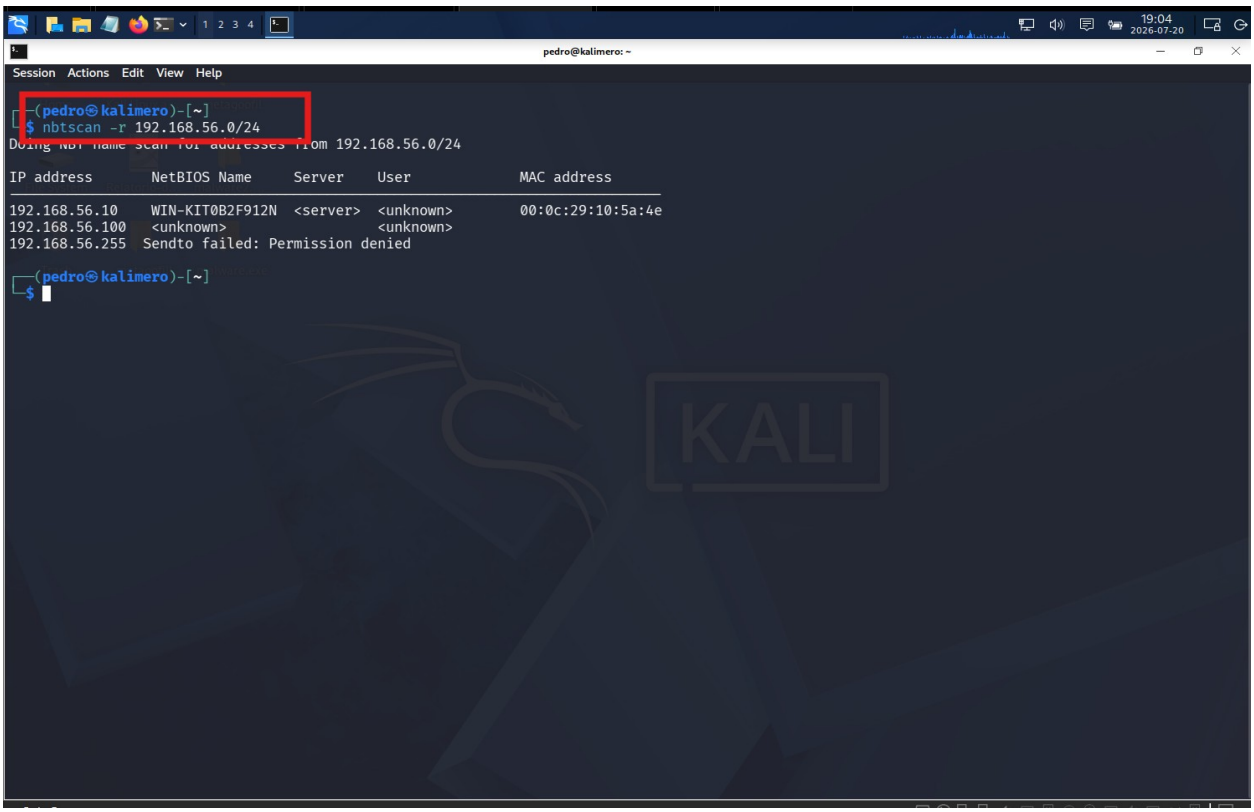
Descobrir hosts ativos na LAN

nmap -sn 192.168.56.0/24



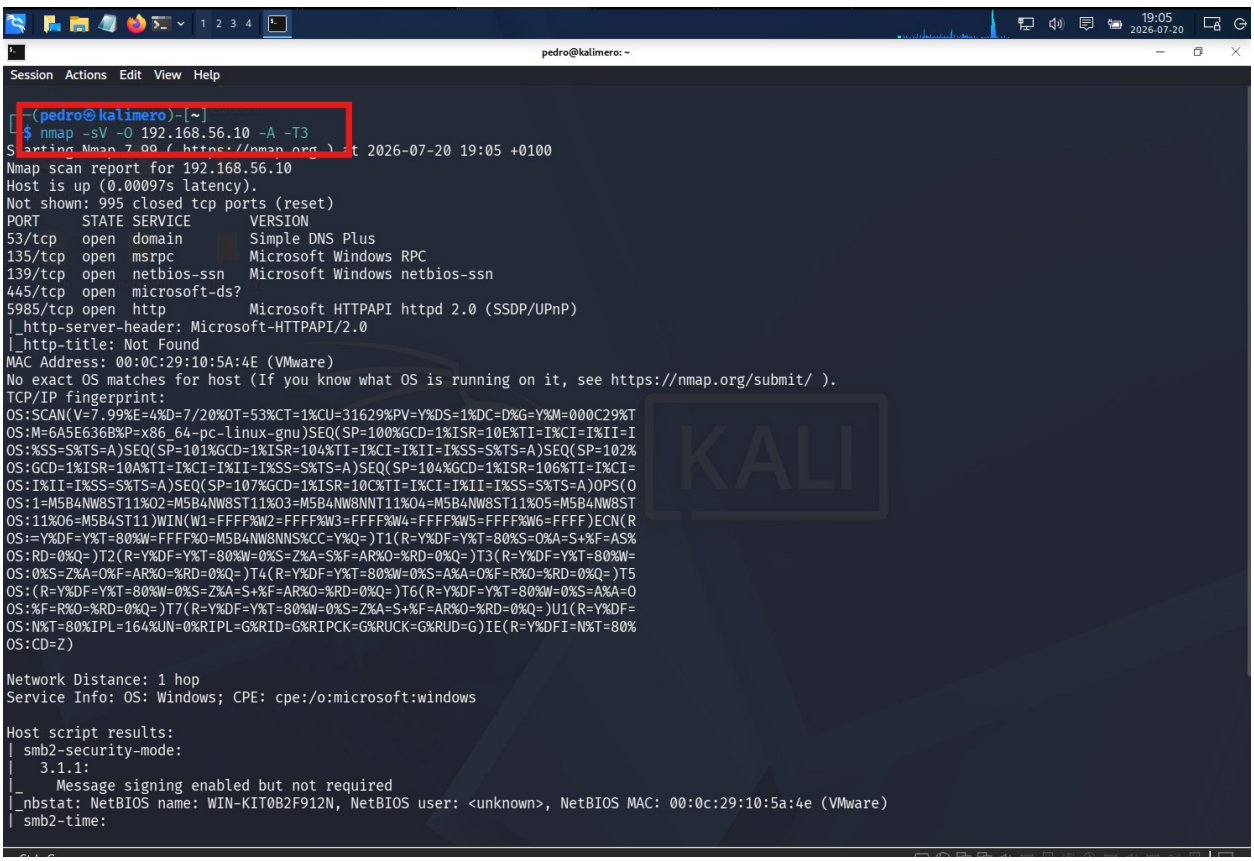
NBTScan para identificar nomes NetBIOS

nbtscan -r 192.168.56.0/24



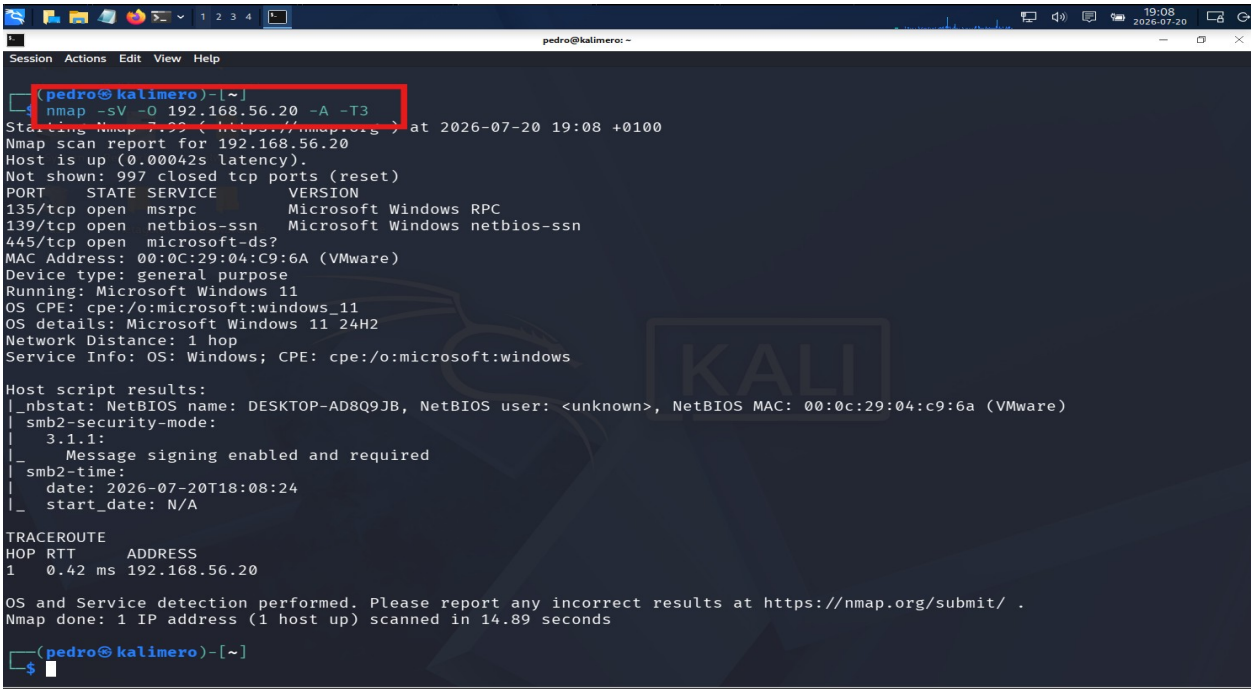
2. Banner grabbing / SO / portas — WIN Server (.10)

nmap -sV -O 192.168.56.10 -A -T3



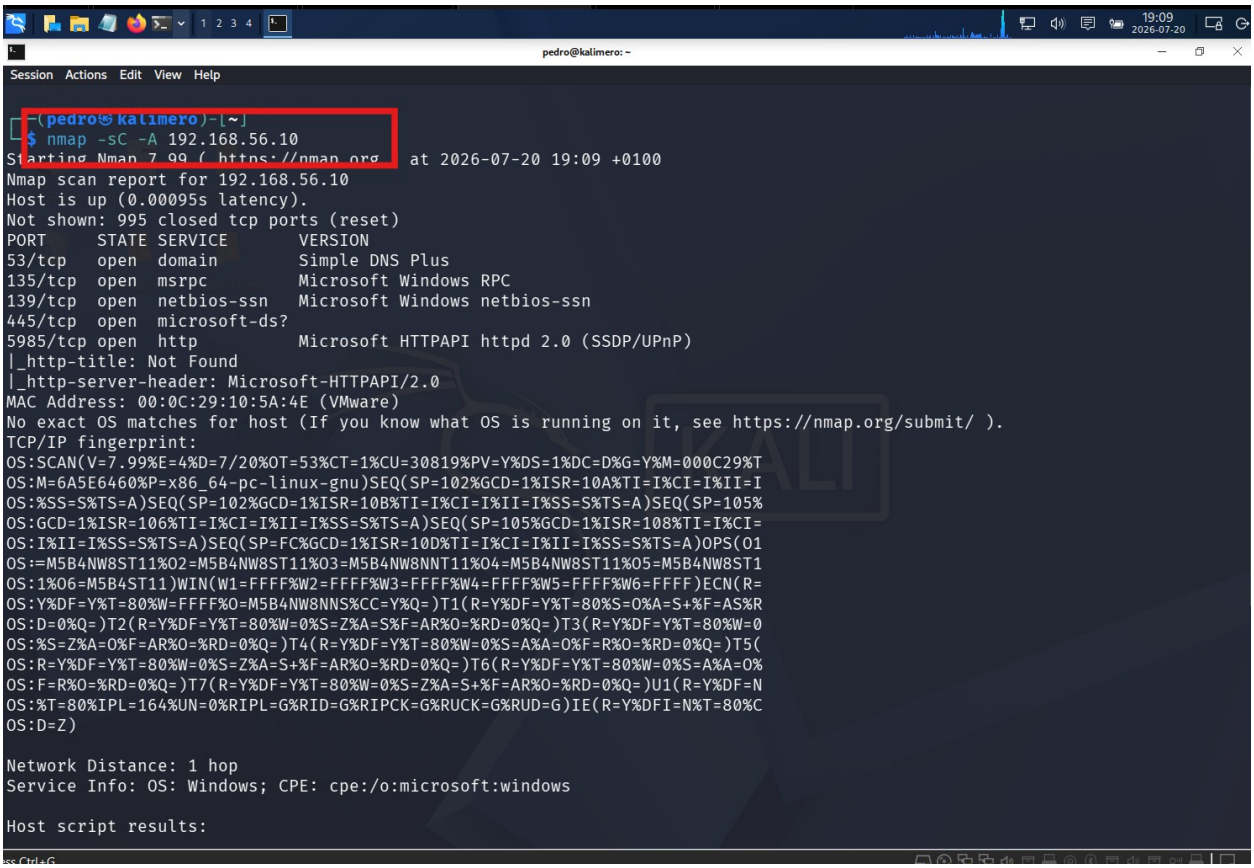
3. Banner grabbing / SO / portas — Windows 11 (.20)

nmap -sV -O 192.168.56.20 -A -T3

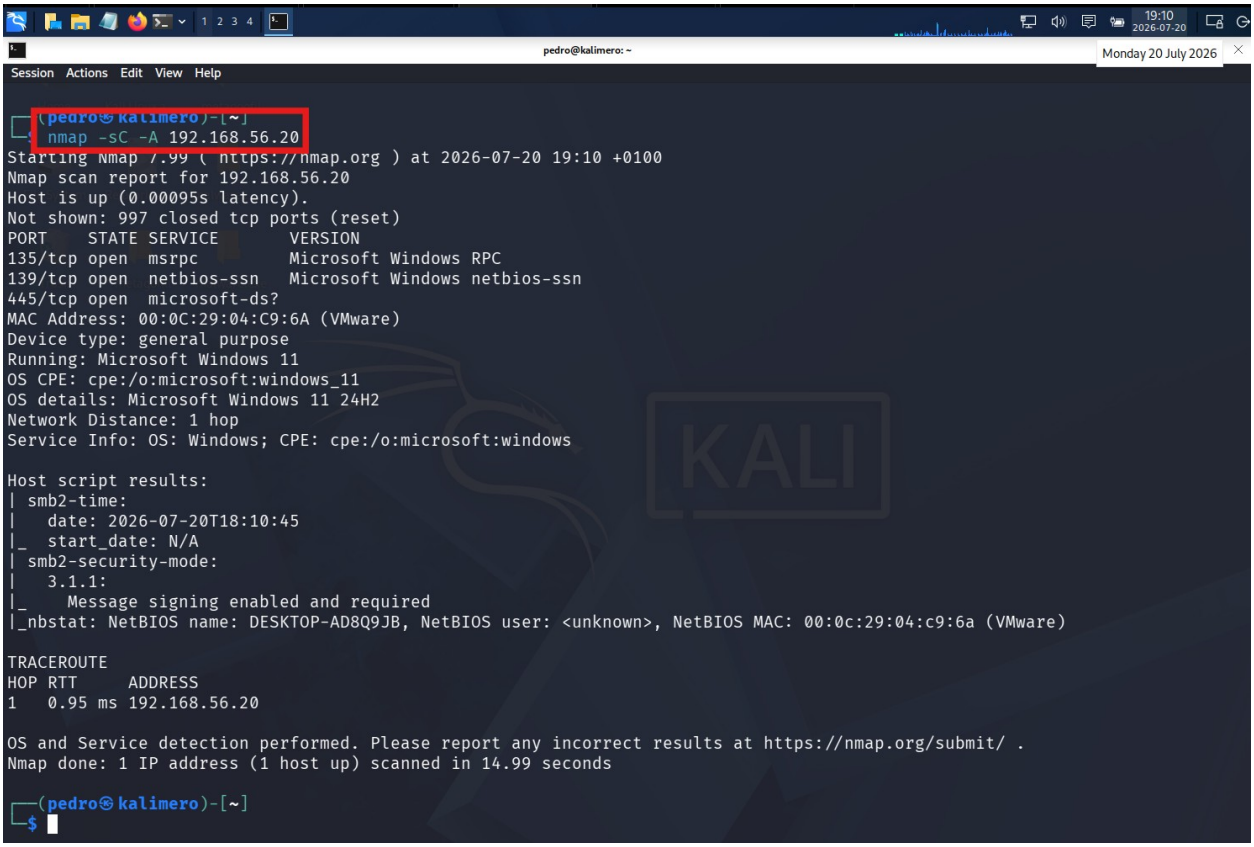


4. Scripts nmap por categoria (correr em ambos os alvos)

nmap -sC -A 192.168.56.10

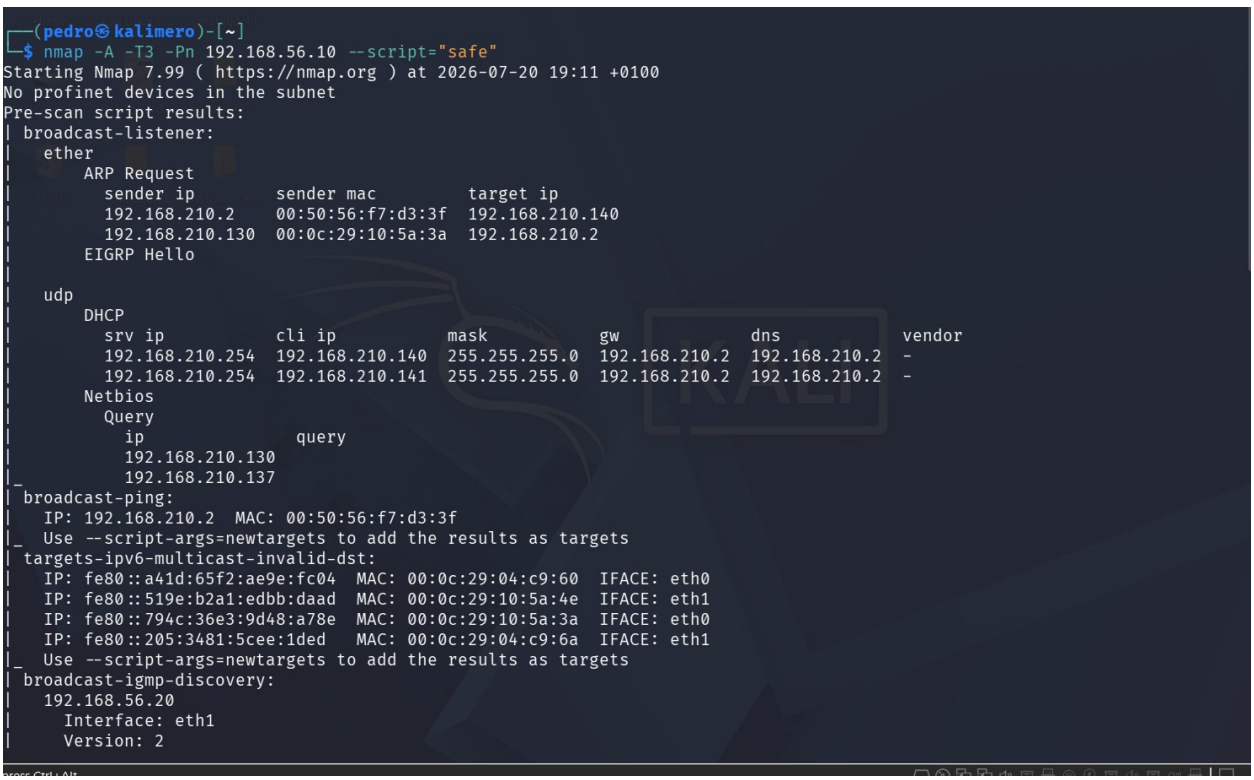


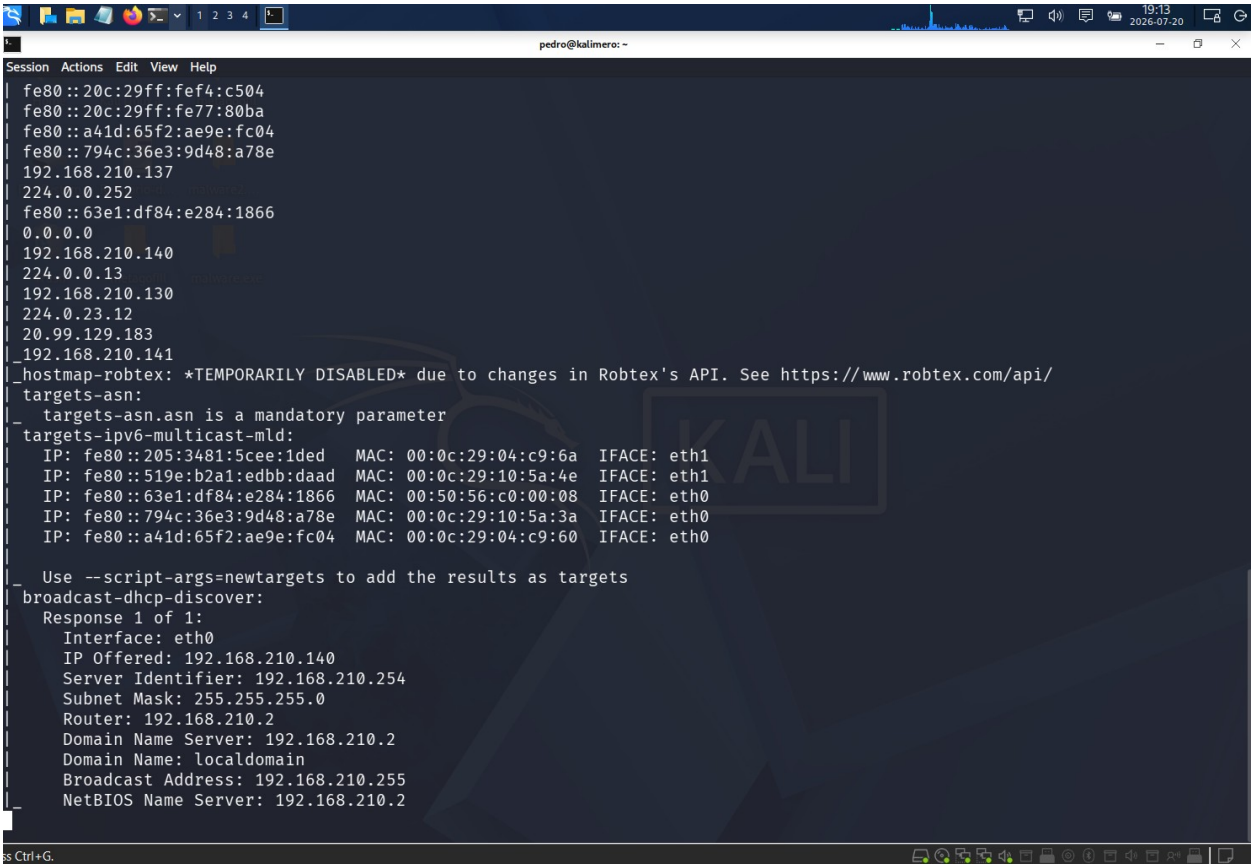
nmap -sC -A 192.168.56.20



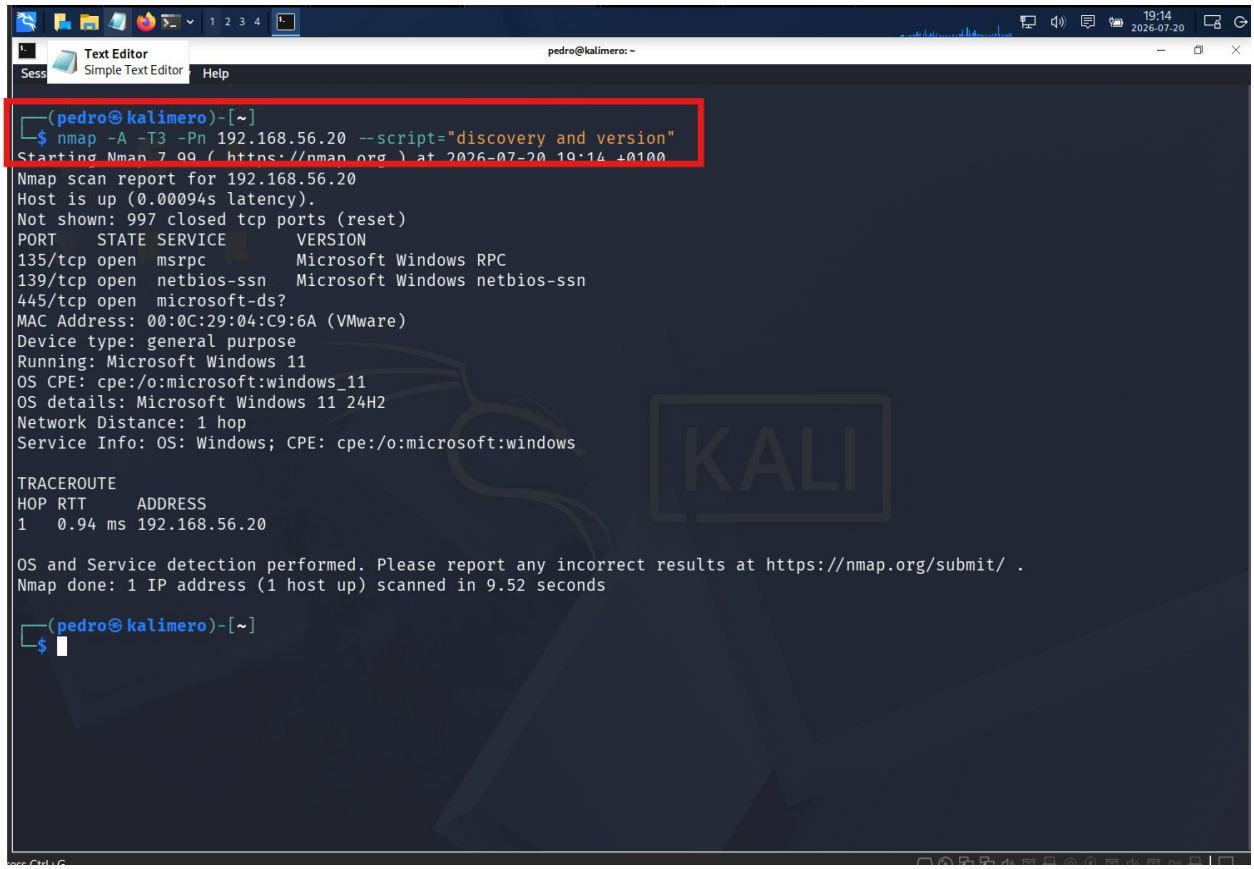
scripts safe/discovery, por exemplo

nmap -A -T3 -Pn 192.168.56.10 --script="safe"





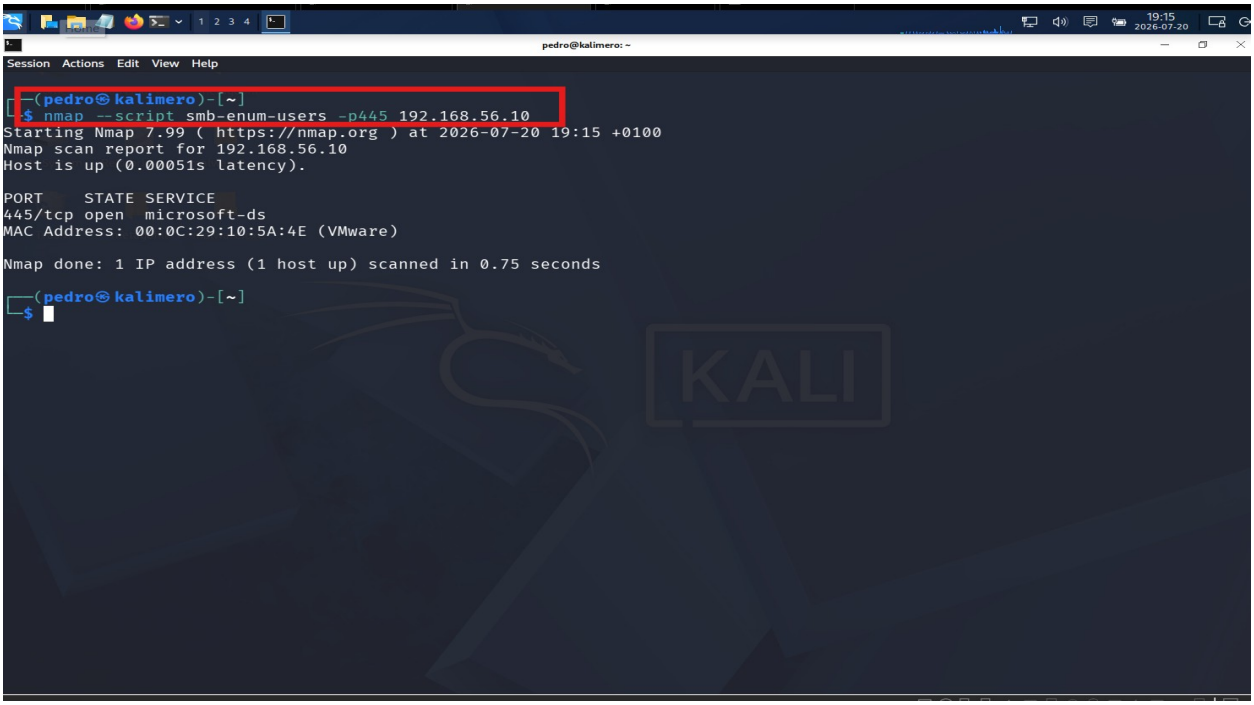
nmap -A -T3 -Pn 192.168.56.20 --script="discovery and version"



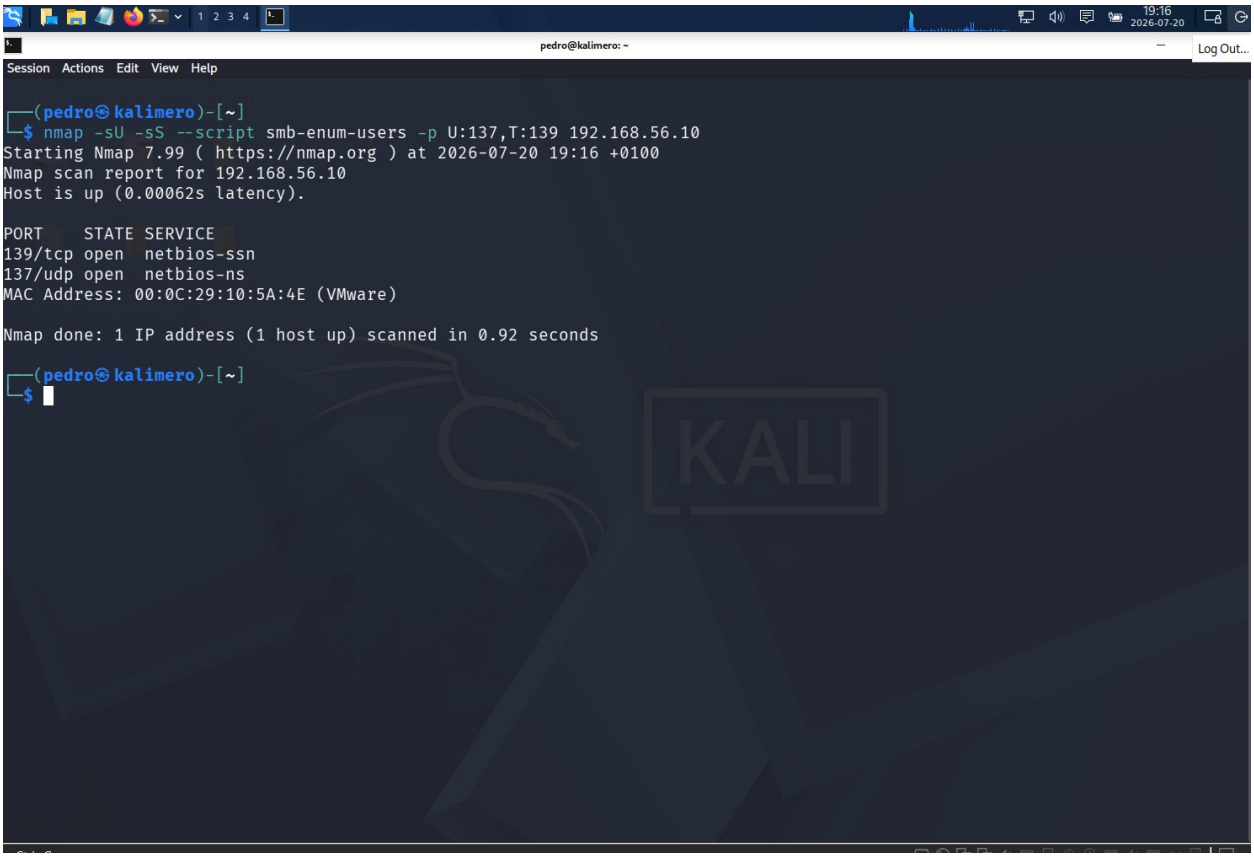
5. Enumeração SMB (muito relevante para WIN Server, provável DC/fileserver)

nmap

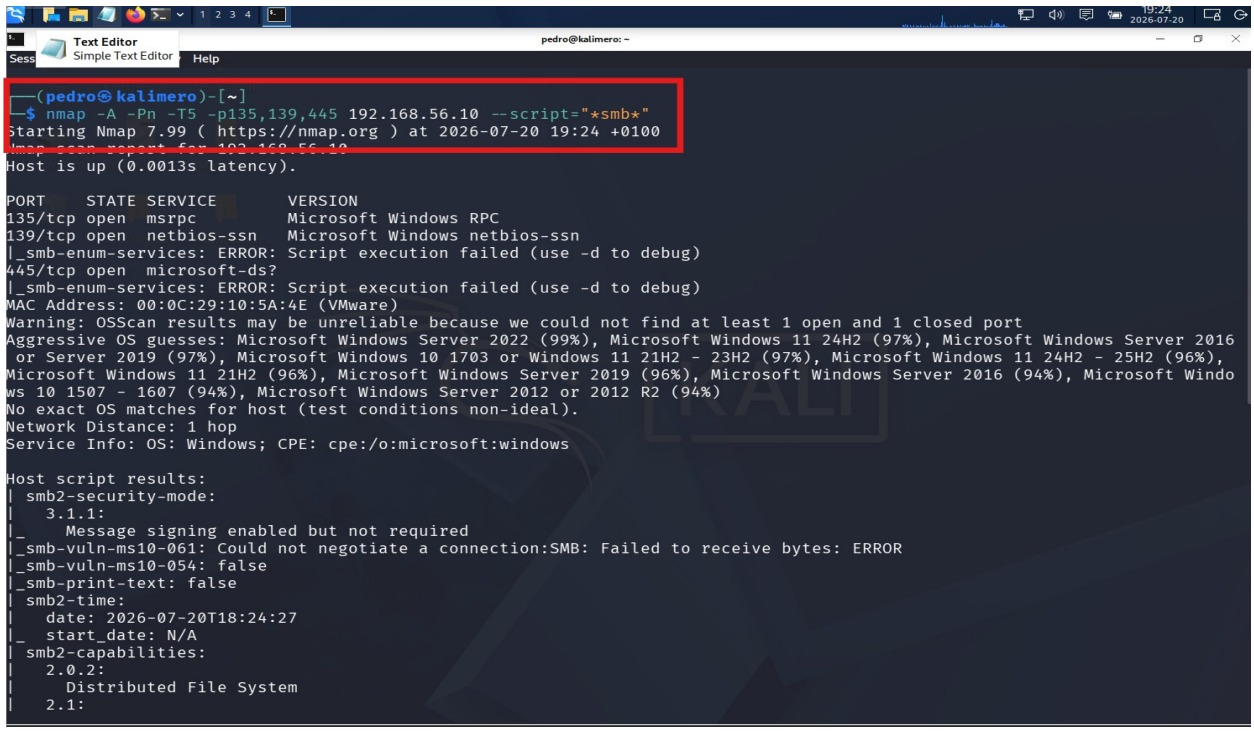
nmap --script smb-enum-users -p445 192.168.56.10



nmap -sU -sS --script smb-enum-users -p U:137,T:139 192.168.56.10

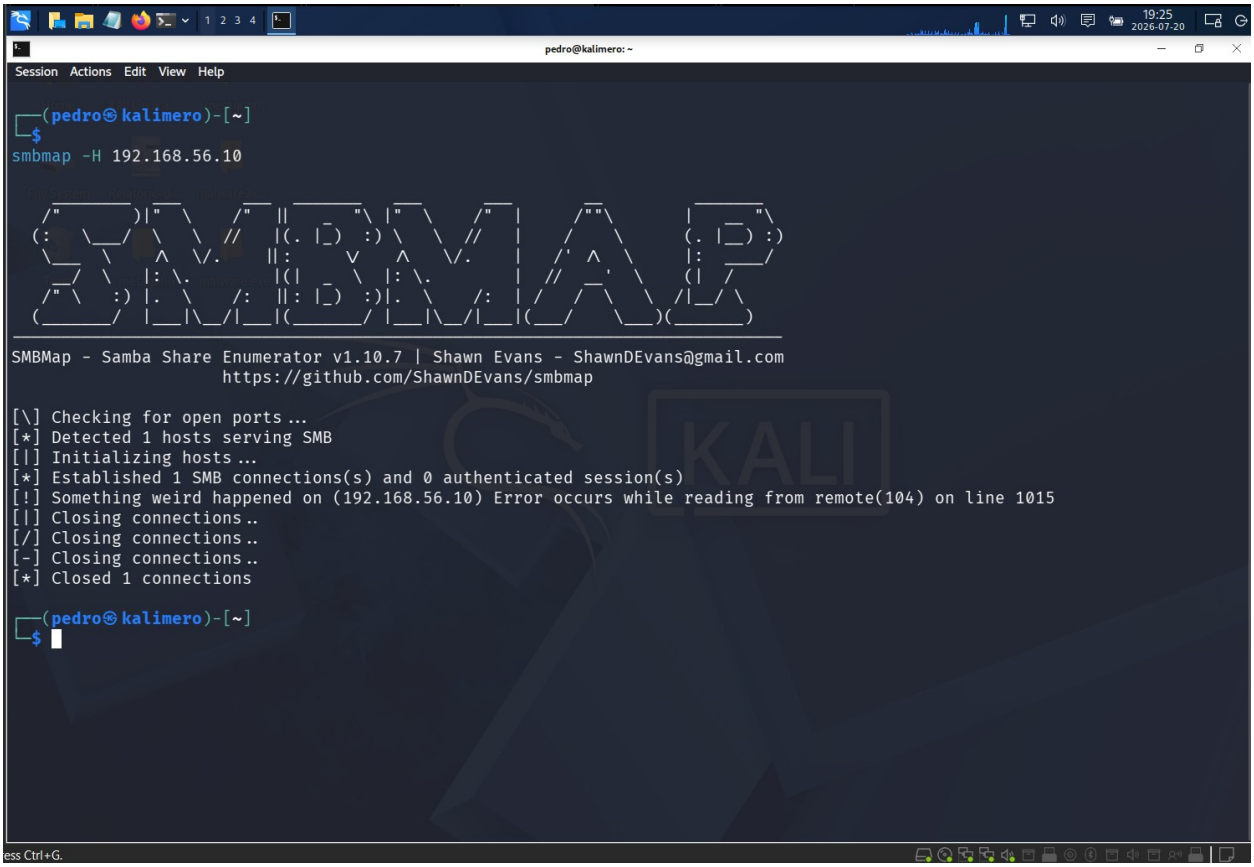


nmap -A -Pn -T5 -p135,139,445 192.168.56.10 --script="*smb*"

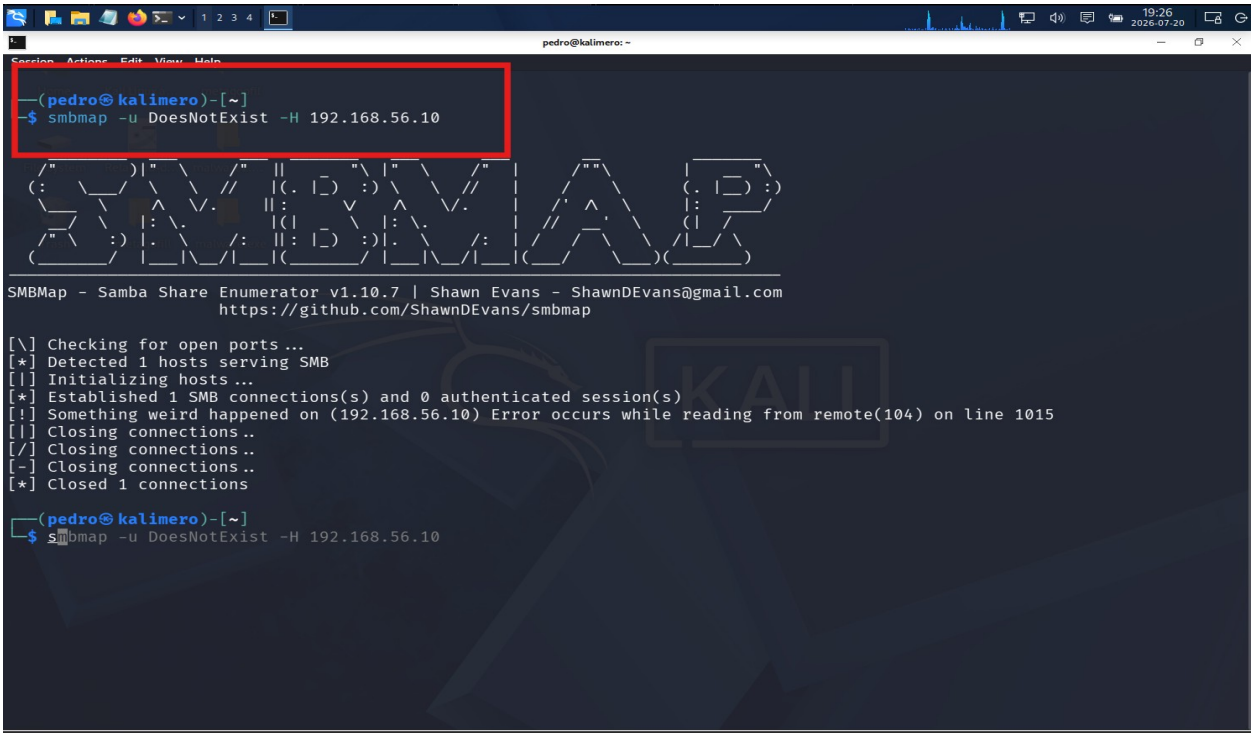


smbmap

smbmap -H 192.168.56.10

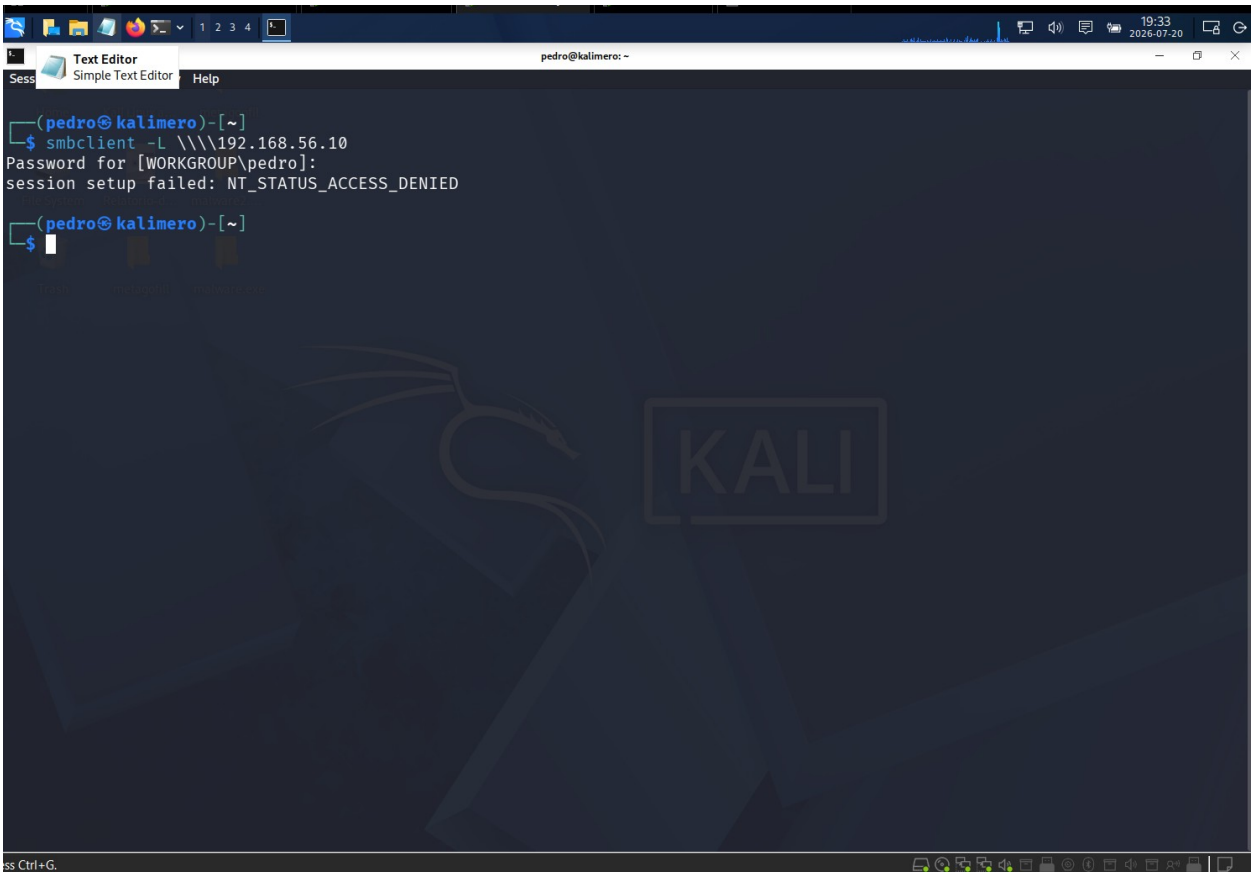


smbmap -u DoesNotExist -H 192.168.56.10

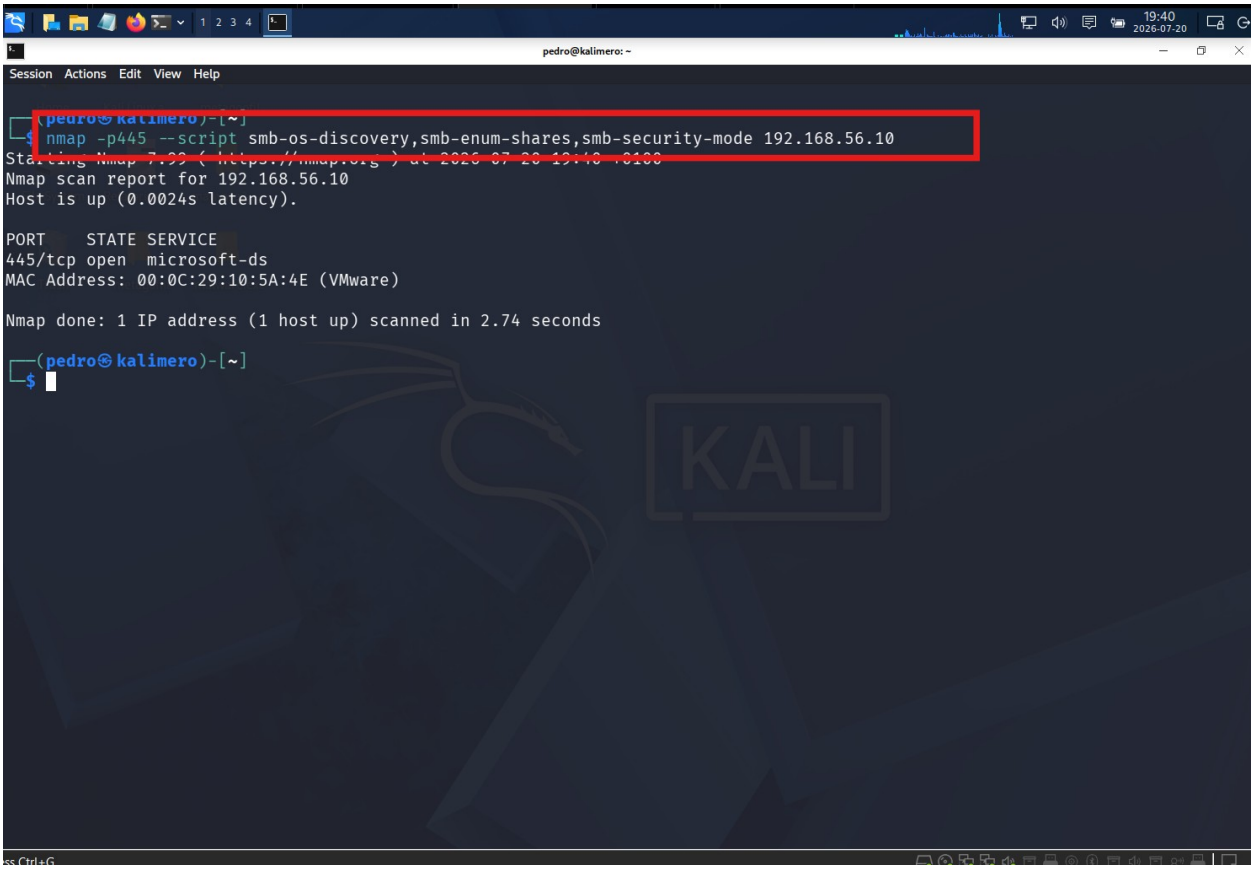


smbclient

smbclient -L \\\\192.168.56.10

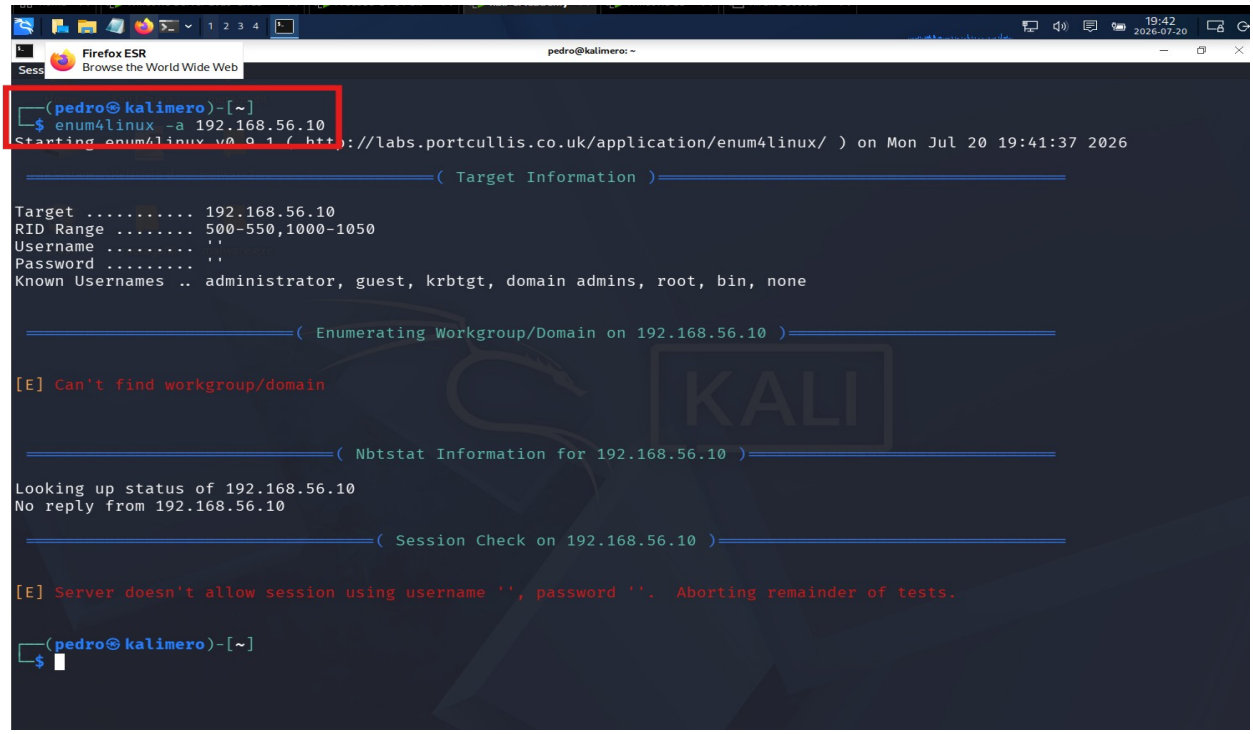


nmap -p445 --script smb-os-discovery,smb-enum-shares,smb-security-mode 192.168.56.10



enum4linux

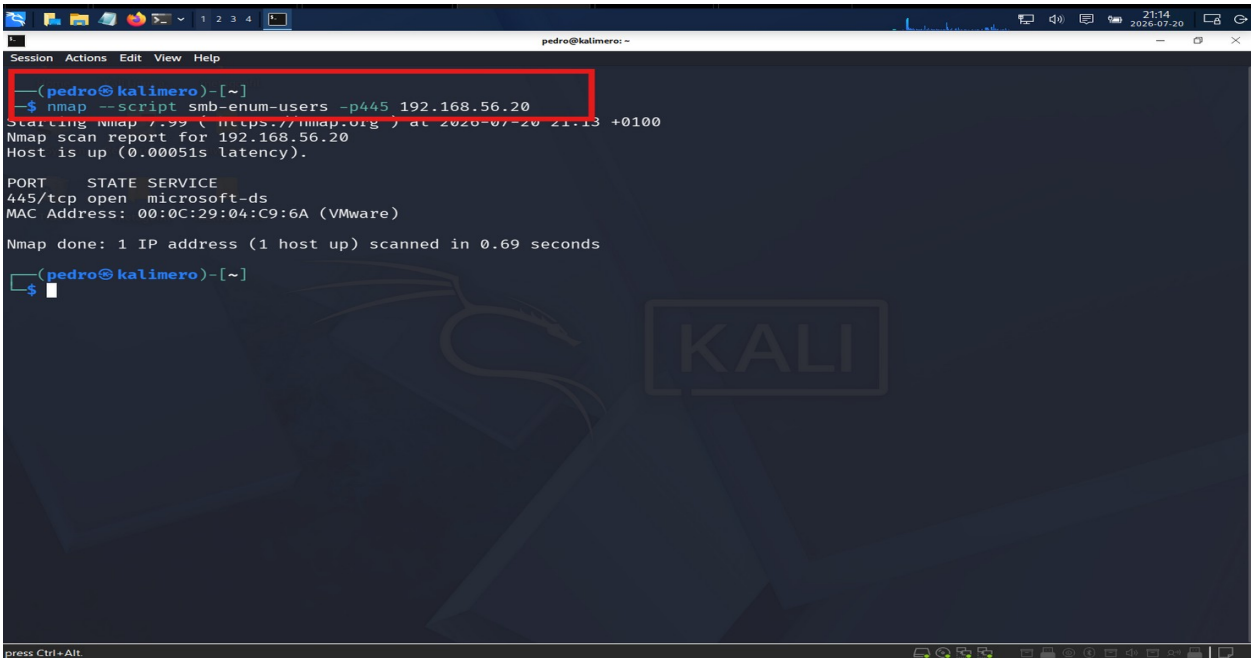
enum4linux -a 192.168.56.10



Repetir os mesmos comandos apontados a 192.168.56.20 se o Windows 11 também tiver partilhas SMB expostas.

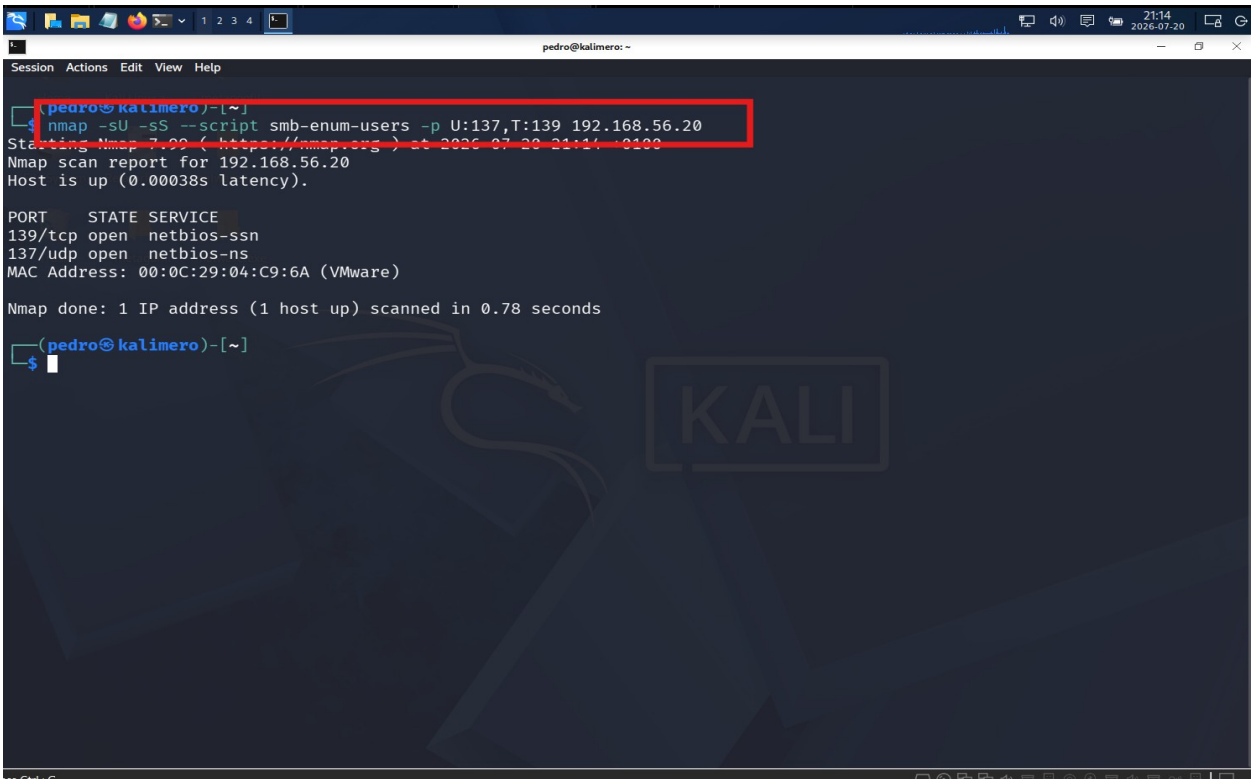
1. Enumeração de utilizadores SMB

nmap --script smb-enum-users -p445 192.168.56.20



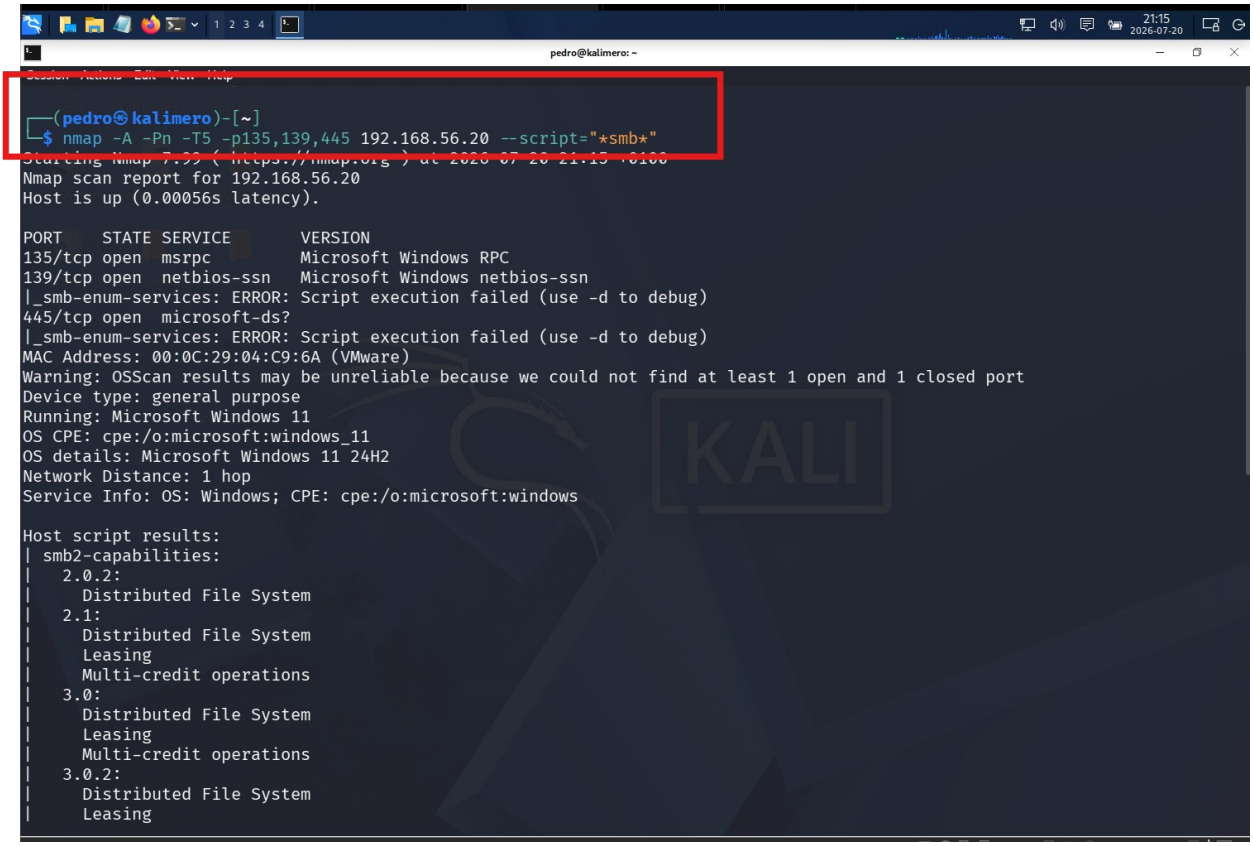
2. Enumeração via UDP 137 + TCP 139

nmap -sU -sS --script smb-enum-users -p U:137,T:139 192.168.56.20



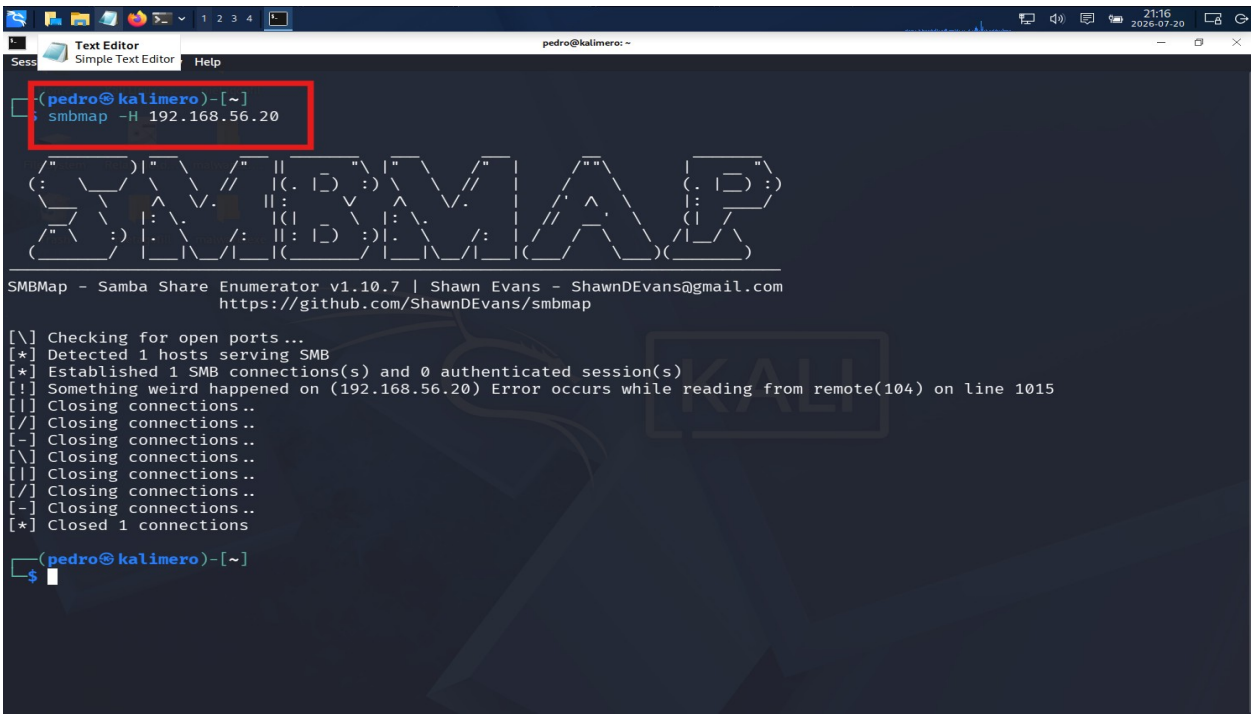
3. Scan amplo com todos os scripts SMB

nmap -A -Pn -T5 -p135,139,445 192.168.56.20 --script="*smb*"



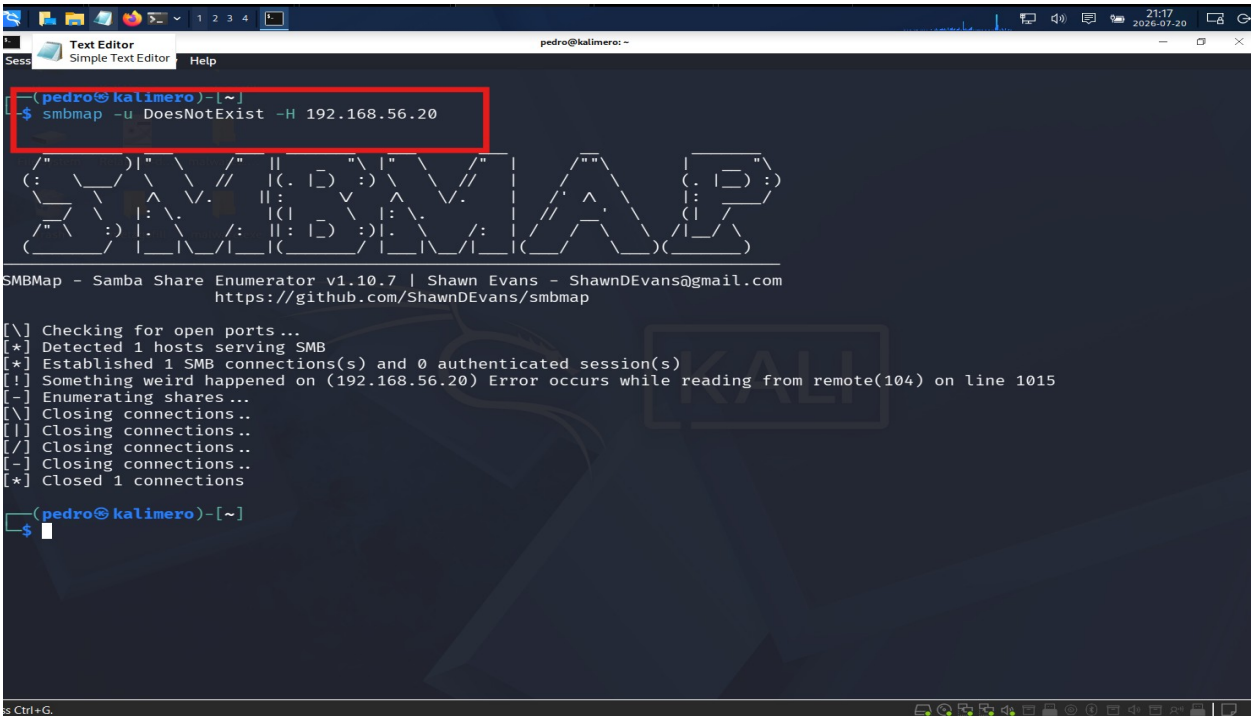
4. SMBMap — informação geral do host

smbmap -H 192.168.56.20



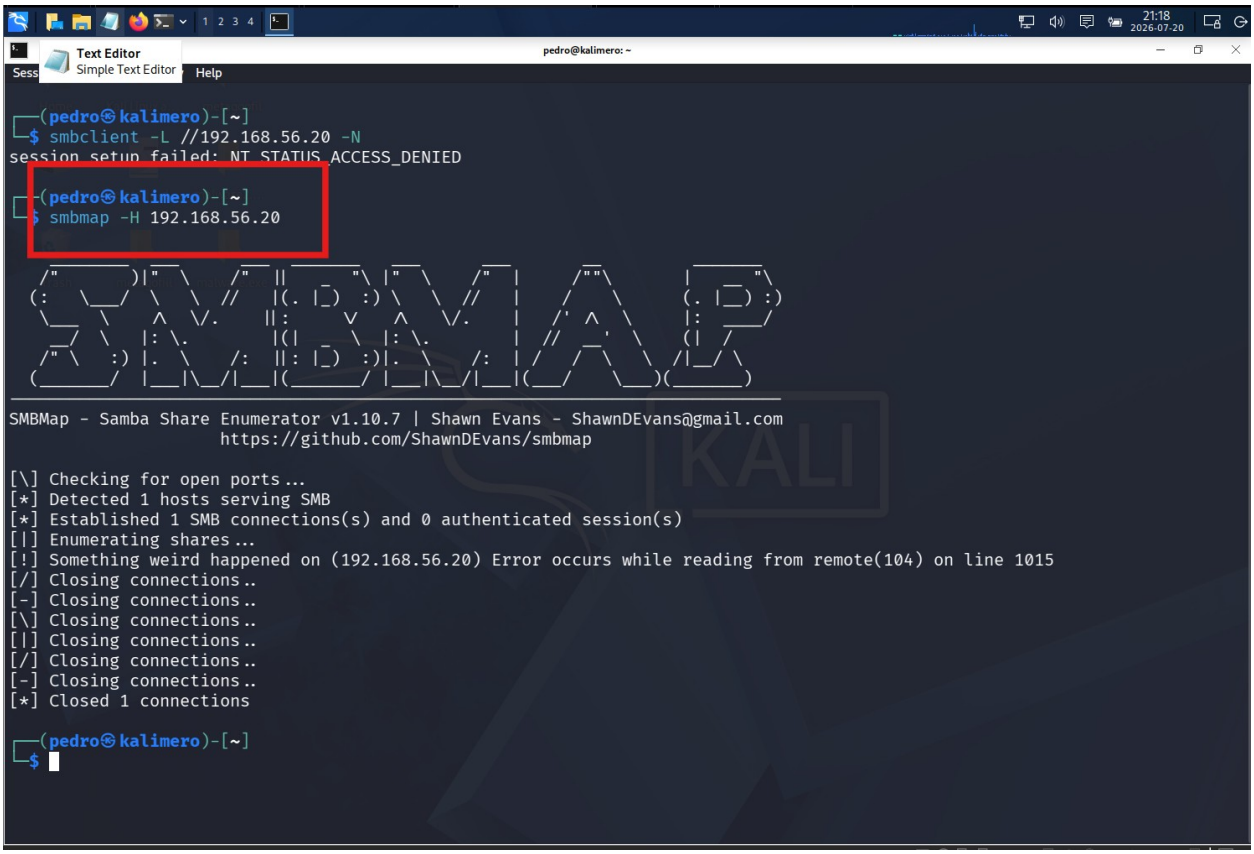
5. SMBMap — testar utilizador inexistente (confirma comportamento de autenticação)

smbmap -u DoesNotExist -H 192.168.56.20

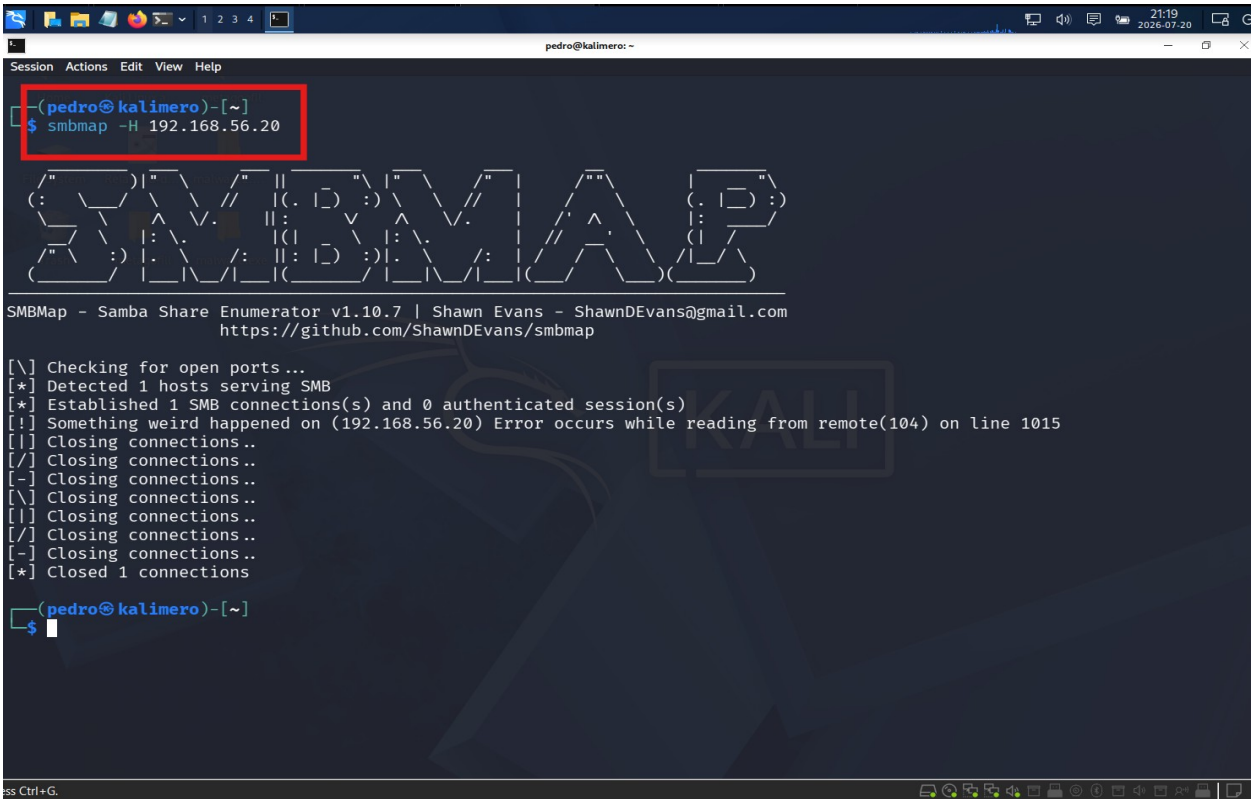


6. SMBClient — listar partilhas (já testado, mas incluído para completar a lista)

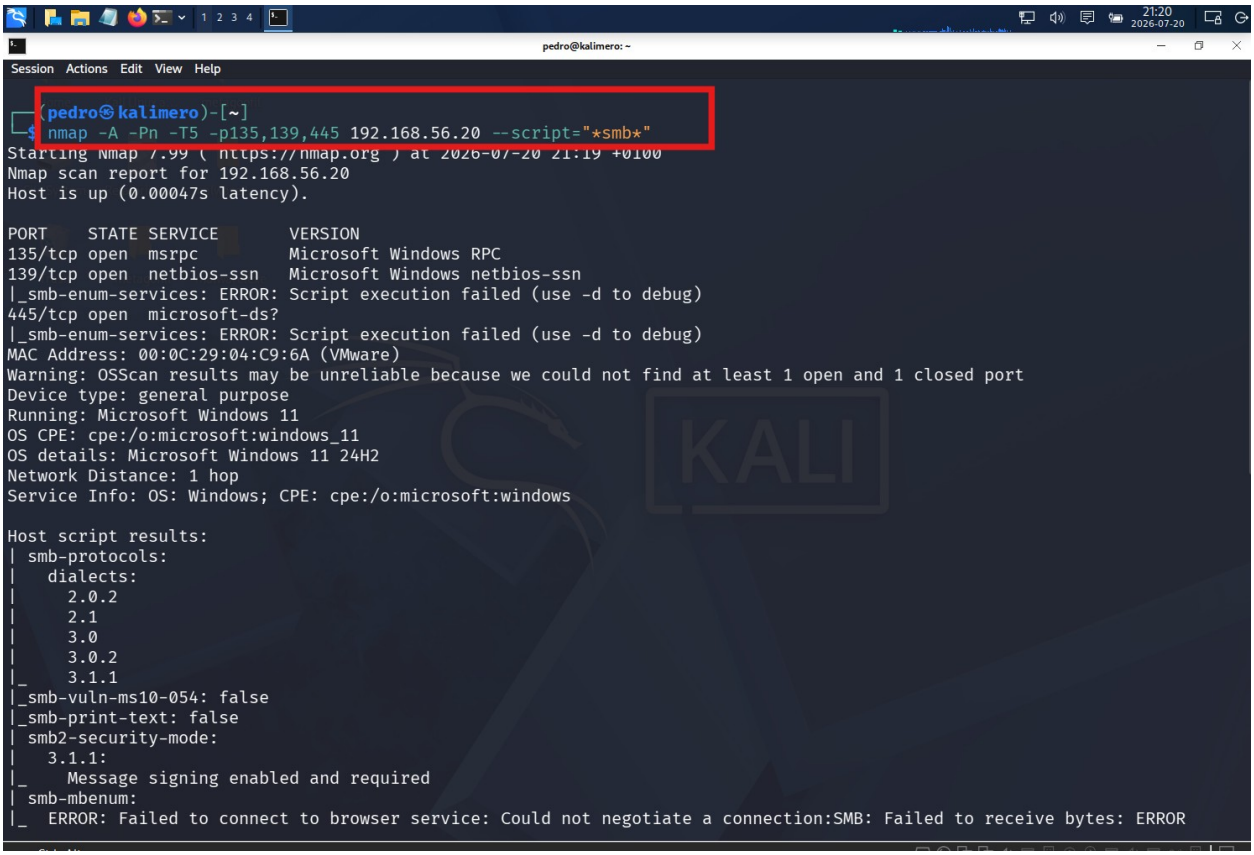
smbclient -L //192.168.56.20 -N



smbmap -H 192.168.56.20

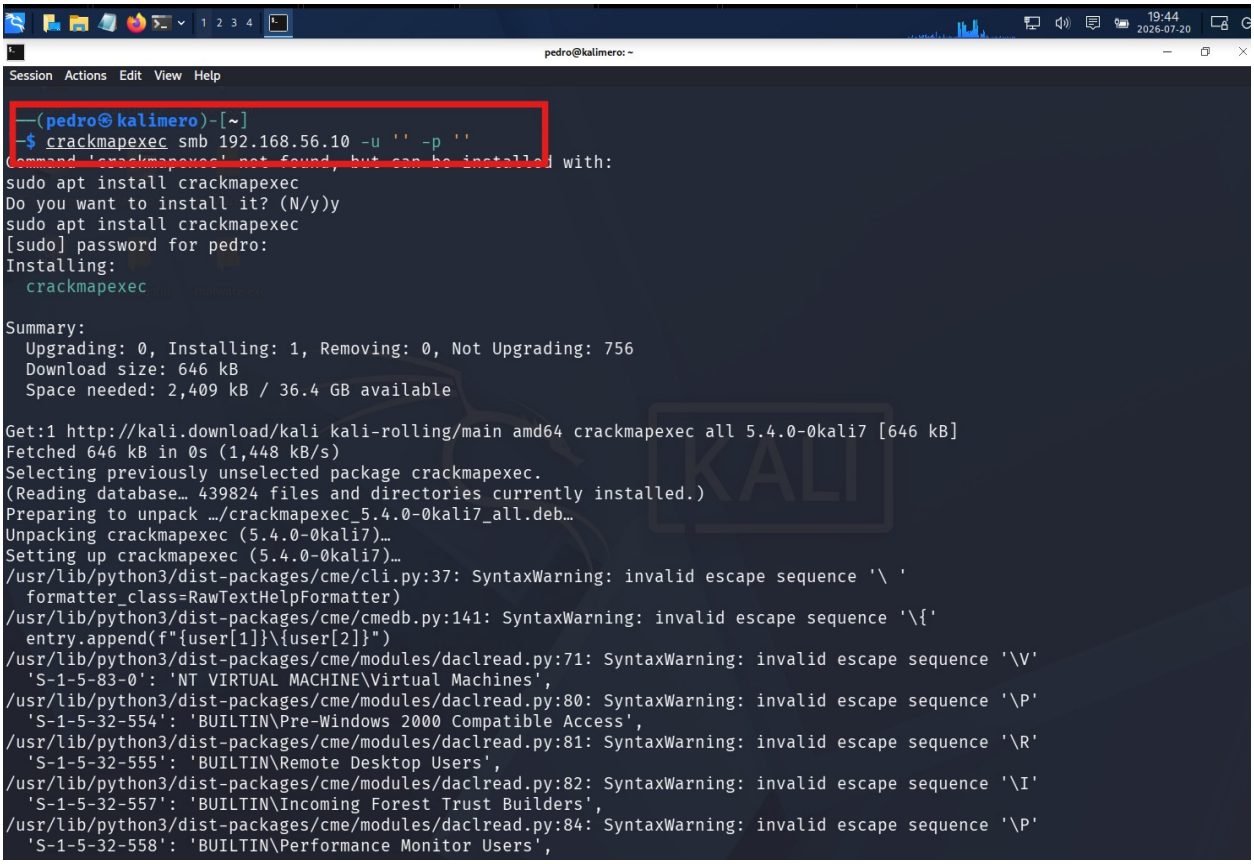


nmap -A -Pn -T5 -p135,139,445 192.168.56.20 --script="*smb*"

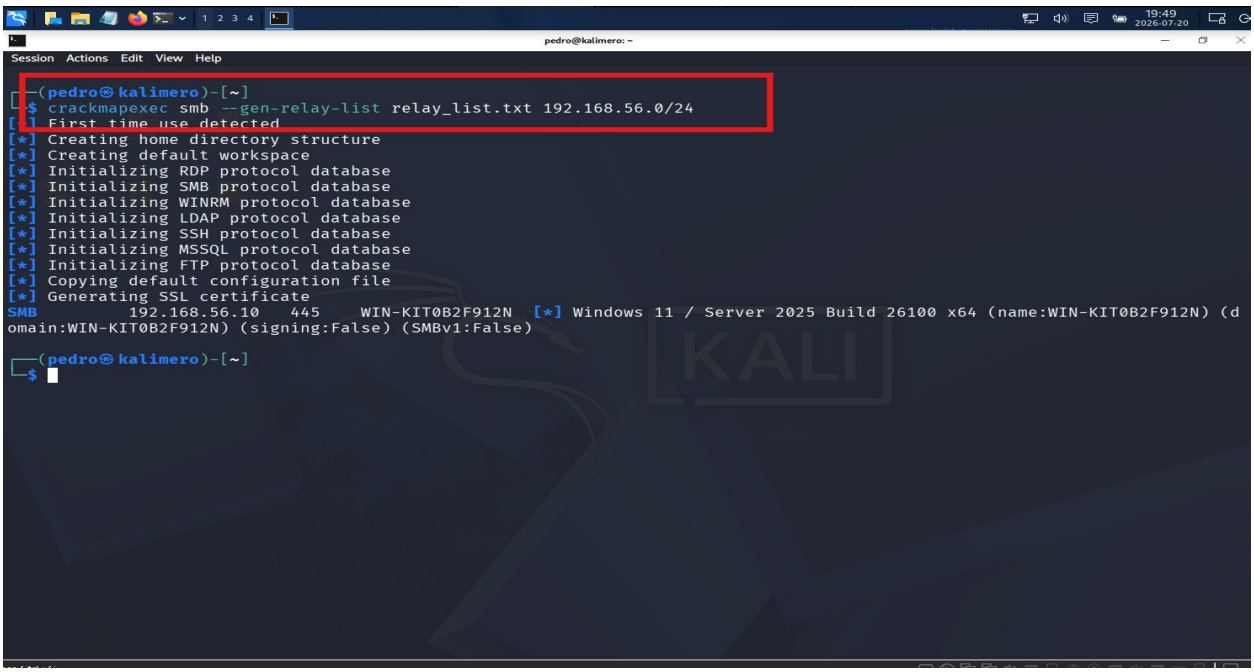


6. Active Directory (assumindo que o WIN Server é um DC)

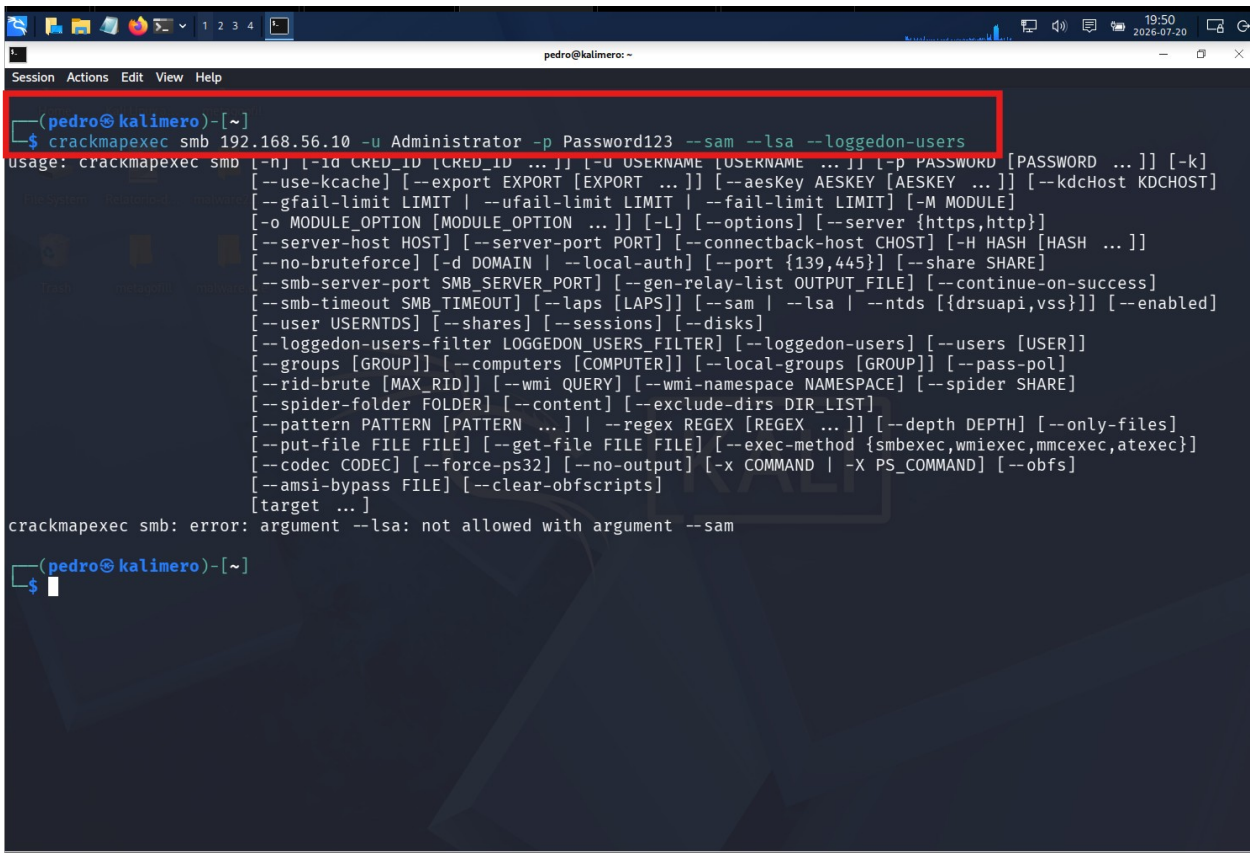
crackmapexec smb 192.168.56.10 -u '' -p ''



crackmapexec smb --gen-relay-list relay_list.txt 192.168.56.0/24

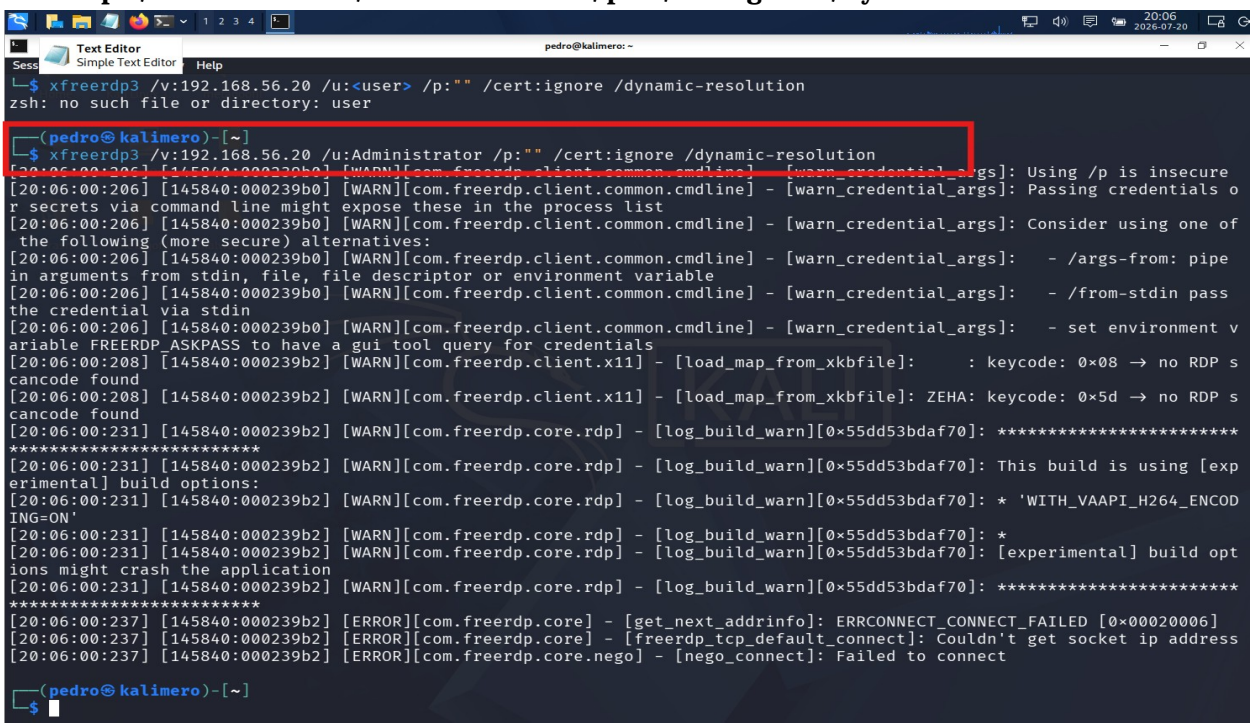


crackmapexec smb 192.168.56.10 -u <user> -p '' --sam --lsa --loggedon-users



RDP para o Windows 10, se exposto

xfreerdp3 /v:192.168.56.20 /u:Administrator /p:"" /cert:ignore /dynamic-resolution



7. Metasploit — módulos auxiliares gerais

msfconsole

search type:auxiliary smb

search type:auxiliary rdp

use <módulo escolhido>

show options

set RHOSTS 192.168.56.10

run

sf > use auxiliary/scanner/smb/smb_version

msf auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT		no	The target port (TCP)
THREADS	1	yes	The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.56.10

RHOSTS => 192.168.56.10

msf auxiliary(scanner/smb/smb_version) > run

/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression

[*] 192.168.56.10:445 - SMB Detected (versions: 2, 3) (preferred dialect: SMB 3.1.1) (compression capabilities: LZNT1, Pattern_V1) (encryption capabilities: AES-256-GCM) (signatures: optional) (guid: {137c99b3-754d-4665-b7da-823eecebcccc}) (authentication domain: WIN-KIT0B2F912N)

[+] 192.168.56.10:445 - Host is running Version 10.0.26100 (likely Windows 11 version 24H2/Windows Server 2025)

[*] 192.168.56.10:445 - SMB signing is not required

[*] 192.168.56.10 - Scanned 1 of 1 hosts (100% complete)

[*] Auxiliary module execution completed

msf auxiliary(scanner/smb/smb_version) > search type:auxiliary rdp

Matching Modules

==========

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/scanner/http/wp_abandoned_cart_sqli	2020-11-05	normal	No	Abandoned Cart for WooCommerce SQLi Scanner
1	auxiliary/admin/ldap/bad_successor	2025-05-21	normal	Yes	BadSuccessor: dMSA abuse to Escalate Privileges in Windows Active Directory
2	_ action: CREATE_DMSA	.	.	.	Create a dMSA account which impersonates a high privilege user
3	_ action: GET_TICKET	.	.	.	Requests a series of tickets to give the user a ticket which can be used in the context of whomst the dMSA account impersonates
4	auxiliary/scanner/rdp/cve_2019_0708_bluekeep	2019-05-14	normal	Yes	CVE-2019-0708 BlueKeep Microsoft Remote Desktop RCE Check
5	_ action: Crash	.	.	.	Trigger denial of service vulnerability
6	_ action: Scan	.	.	.	Scan for exploitable targets
7	auxiliary/scanner/kademlia/server_info	.	normal	No	Gather Kademlia Server Information
8	_ action: BOOTSTRAP	.	.	.	Use a Kademlia2 BOOTSTRAP
9	_ action: PING	.	.	.	Use a Kademlia2 PING
10	auxiliary/scanner/http/icinga_static_library_file_directory_traversal	2022-05-09	normal	Yes	Icingaweb Directory Traversal in Static Library File Requests
11	auxiliary/scanner/rdp/rdp_scanner	.	normal	No	Identify endpoints speaking the Remote Desktop Protocol (RDP)
12	auxiliary/scanner/rdp/ms12_020_check	.	normal	Yes	MS12-020 Microsoft Remote Desktop Checker
13	auxiliary/dos/windows/rdp/ms12_020_maxchannelids	2012-03-16	normal	No	MS12-020 Microsoft Remote Desktop Use-After-Free DoS
14	auxiliary/dos/http/ms15_034_ulonglongadd	.	normal	Yes	MS15-034 HTTP Protocol Stack Request Handling Denial-of-Service
15	auxiliary/scanner/http/ms15_034_http_sys_memory_dump	.	normal	Yes	MS15-034 HTTP Protocol Stack Request Handling HTTP.SYS Memory Information Disclosure

16 auxiliary/scanner/http/rdp_web_login 2020-12-23 normal No Microsoft RDP Web Client Login Enumeration

17 auxiliary/gather/wp_all_in_one_migration_export 2015-03-19 normal Yes WordPress All-in-One Migration Export

18 auxiliary/scanner/http/wordpress_login_enum . normal No WordPress Brute Force and User Enumeration Utility

19 auxiliary/scanner/http/wordpress_cp_calendar_sqli 2015-03-03 normal No WordPress CP Multi-View Calendar Unauthenticated SQL Injection Scanner

20 auxiliary/scanner/http/wp_chopslider_id_sqli 2020-05-12 normal No WordPress ChopSlider3 id SQLi Scanner

21 auxiliary/scanner/http/wp_contus_video_gallery_sqli 2015-02-24 normal No WordPress Contus Video Gallery Unauthenticated SQL Injection Scanner

22 auxiliary/gather/wp_depicter_sqli_cve_2025_2011 2025-05-08 normal Yes WordPress Depicter Plugin SQL Injection (CVE-2025-2011)

23 auxiliary/scanner/http/wp_dukapress_file_read . normal No WordPress DukaPress Plugin File Read Vulnerability

24 auxiliary/scanner/http/wp_duplicator_file_read 2020-02-19 normal No WordPress Duplicator File Read Vulnerability

25 auxiliary/scanner/http/wp_easy_wp_smtp 2020-12-06 normal No WordPress Easy WP SMTP Password Reset

26 auxiliary/scanner/http/wp_email_sub_news_sqli 2019-11-13 normal No WordPress Email Subscribers and Newsletter Hash SQLi Scanner

27 auxiliary/scanner/http/wp_gimedia_library_file_read . normal No WordPress GI-Media Library Plugin Directory Traversal Vulnerability

28 auxiliary/admin/http/wp_google_maps_sqli 2019-04-02 normal Yes WordPress Google Maps Plugin SQL Injection

29 auxiliary/scanner/http/wp_learnpress_c_fields_sqli 2024-09-11 normal No WordPress LearnPress Unauthenticated SQLi (CVE-2024-8522, CVE-2024-8529)

30 _ action: CVE-2024-8522 . . . SQL Injection via c_only_fields parameter

31 _ action: CVE-2024-8529 . . . SQL Injection via c_fields parameter

32 auxiliary/scanner/http/wp_loginizer_log_sqli 2020-10-21 normal No WordPress Loginizer log SQLi Scanner

33 auxiliary/dos/http/wordpress_long_password_dos 2014-11-20 normal No WordPress Long Password DoS

34 auxiliary/scanner/http/wp_mobileedition_file_read . normal No WordPress Mobile Edition File Read Vulnerability

35 auxiliary/scanner/http/wp_mobile_pack_info_disclosure . normal No WordPress Mobile Pack Information Disclosure Vulnerability

36 auxiliary/scanner/http/wp_modern_events_calendar_sqli 2021-12-13 normal Yes WordPress Modern Events Calendar SQLi Scanner

37 auxiliary/scanner/http/wp_nextgen_galley_file_read . normal No WordPress NextGEN Gallery Directory Read Vulnerability

38 auxiliary/gather/wp_photo_gallery_sqli 2022-03-14 normal Yes WordPress Photo Gallery Plugin SQL Injection (CVE-2022-0169)

39 auxiliary/admin/http/wp_automatic_plugin_privesc 2021-09-06 normal Yes WordPress Plugin Automatic Config Change to RCE

40 auxiliary/scanner/http/wp_perfect_survey_sqli 2021-10-05 normal Yes WordPress Plugin Perfect Survey 1.5.1 SQLi (Unauthenticated)

41 auxiliary/scanner/http/wordpress_content_injection 2017-02-01 normal Yes WordPress REST API Content Injection

42 _ action: LIST . . . List posts

43 _ action: UPDATE . . . Update post

44 auxiliary/scanner/http/wp_simple_backup_file_read . normal No WordPress Simple Backup File Read Vulnerability

45 auxiliary/scanner/http/wp_subscribe_comments_file_read . normal No WordPress Subscribe Comments File Read Vulnerability

46 auxiliary/admin/http/wp_symposium_sql_injection 2015-08-18 normal Yes WordPress Symposium Plugin SQL Injection

47 auxiliary/scanner/http/wp_ti_woocommerce_wishlist_sqli 2024-09-25 normal No WordPress TI WooCommerce Wishlist SQL Injection (CVE-2024-43917)

48 auxiliary/scanner/http/wp_total_upkeep_downloader 2020-12-12 normal No WordPress Total Upkeep Unauthenticated Backup Downloader

49 auxiliary/dos/http/wordpress_directory_traversal_dos . normal No WordPress Traversal Directory DoS

50 auxiliary/gather/wp_ultimate_csv_importer_user_extract 2015-02-02 normal Yes WordPress Ultimate CSV Importer User Table Extract

51 auxiliary/scanner/http/wp_ultimate_member_sorting_sqli 2024-02-10 normal No WordPress Ultimate Member SQL Injection (CVE-2024-1071)

52 auxiliary/gather/wp_w3_total_cache_hash_extract . normal No WordPress W3-Total-Cache Plugin 0.9.2.4 (or before) Username and Hash Extract

53 auxiliary/admin/http/wp_easycart_privilege_escalation 2015-02-25 normal Yes WordPress WP EasyCart Plugin Privilege Escalation

54 auxiliary/scanner/http/wp_fastest_cache_sqli 2023-11-14 normal No WordPress WP Fastest Cache Unauthenticated SQLi (CVE-2023-6063)

55 auxiliary/admin/http/wp_gdpr_compliance_privesc 2018-11-08 normal Yes WordPress WP GDPR Compliance Plugin Privilege Escalation

56 auxiliary/admin/http/wp_wplms_privilege_escalation 2015-02-09 normal Yes WordPress WPLMS Theme Privilege Escalation

57 auxiliary/scanner/http/wp_wps_hide_login_revealer 2021-10-27 normal No WordPress WPS Hide Login Login Page Revealer

58 auxiliary/scanner/http/wordpress_ghost_scanner . normal No WordPress XMLRPC GHOST Vulnerability Scanner

59 auxiliary/admin/http/wp_custom_contact_forms 2014-08-07 normal No WordPress custom-contact-forms Plugin SQL Upload

60 auxiliary/scanner/http/wp_arbitrary_file_deletion 2018-06-26 normal No Wordpress Arbitrary File Deletion

61 auxiliary/gather/wp_bookingpress_category_services_sqli 2022-02-28 normal Yes Wordpress BookingPress bookingpress_front_get_category_services SQLi

62 auxiliary/scanner/http/wp_bulletproofsecurity_backups 2021-09-17 normal No Wordpress BulletProof Security Backup Disclosure

63 auxiliary/scanner/http/wp_learnpress_sqli 2020-04-29 normal No Wordpress LearnPress current_items Authenticated SQLi

64 auxiliary/admin/http/wp_masterstudy_privesc 2022-02-18 normal Yes Wordpress MasterStudy Admin Account Creation

65 auxiliary/admin/http/wp_post_smtp_acct_takeover 2024-01-10 normal Yes Wordpress POST SMTP Account Takeover

66 auxiliary/scanner/http/wp_paid_membership_pro_code_sqli 2023-01-12 normal Yes Wordpress Paid Membership Pro code Unauthenticated SQLi

67 auxiliary/scanner/http/wordpress_pingback_access . normal No Wordpress Pingback Locator

68 auxiliary/scanner/http/wp_woocommerce_payments_add_user 2023-03-22 normal Yes Wordpress Plugin WooCommerce Payments Unauthenticated Admin Creation

69 auxiliary/scanner/http/wp_registrationmagic_sqli 2022-01-23 normal Yes Wordpress RegistrationMagic task_ids Authenticated SQLi

70 auxiliary/scanner/http/wordpress_scanner . normal No Wordpress Scanner

71 auxiliary/scanner/http/wp_secure_copy_content_protection_sqli 2021-11-08 normal Yes Wordpress Secure Copy Content Protection and Content Locking sccp_id Unauthenticated SQLi

72 auxiliary/scanner/http/wordpress_xmlrpc_login . normal No Wordpress XML-RPC Username/Password Login Scanner

73 auxiliary/scanner/http/wordpress_multicall_creds . normal No Wordpress XML-RPC system.multicall Credential Collector

74 auxiliary/dos/http/wordpress_xmlrpc_dos 2014-08-06 normal No Wordpress XMLRPC DoS

Interact with a module by name or index. For example info 74, use 74 or use auxiliary/dos/http/wordpress_xmlrpc_dos

```
msf auxiliary(scanner/smb/smb_version) > use auxiliary/scanner/rdp/rdp_scanner
msf auxiliary(scanner/rdp/rdp_scanner) > ping -c 3 192.168.56.20
[*] exec: ping -c 3 192.168.56.20

PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data.
64 bytes from 192.168.56.20: icmp_seq=1 ttl=128 time=0.444 ms
64 bytes from 192.168.56.20: icmp_seq=2 ttl=128 time=0.732 ms
64 bytes from 192.168.56.20: icmp_seq=3 ttl=128 time=0.921 ms

--- 192.168.56.20 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2055ms
rtt min/avg/max/mdev = 0.444/0.699/0.921/0.196 ms
msf auxiliary(scanner/rdp/rdp_scanner) > nmap -Pn -p445 192.168.56.20
[*] exec: nmap -Pn -p445 192.168.56.20

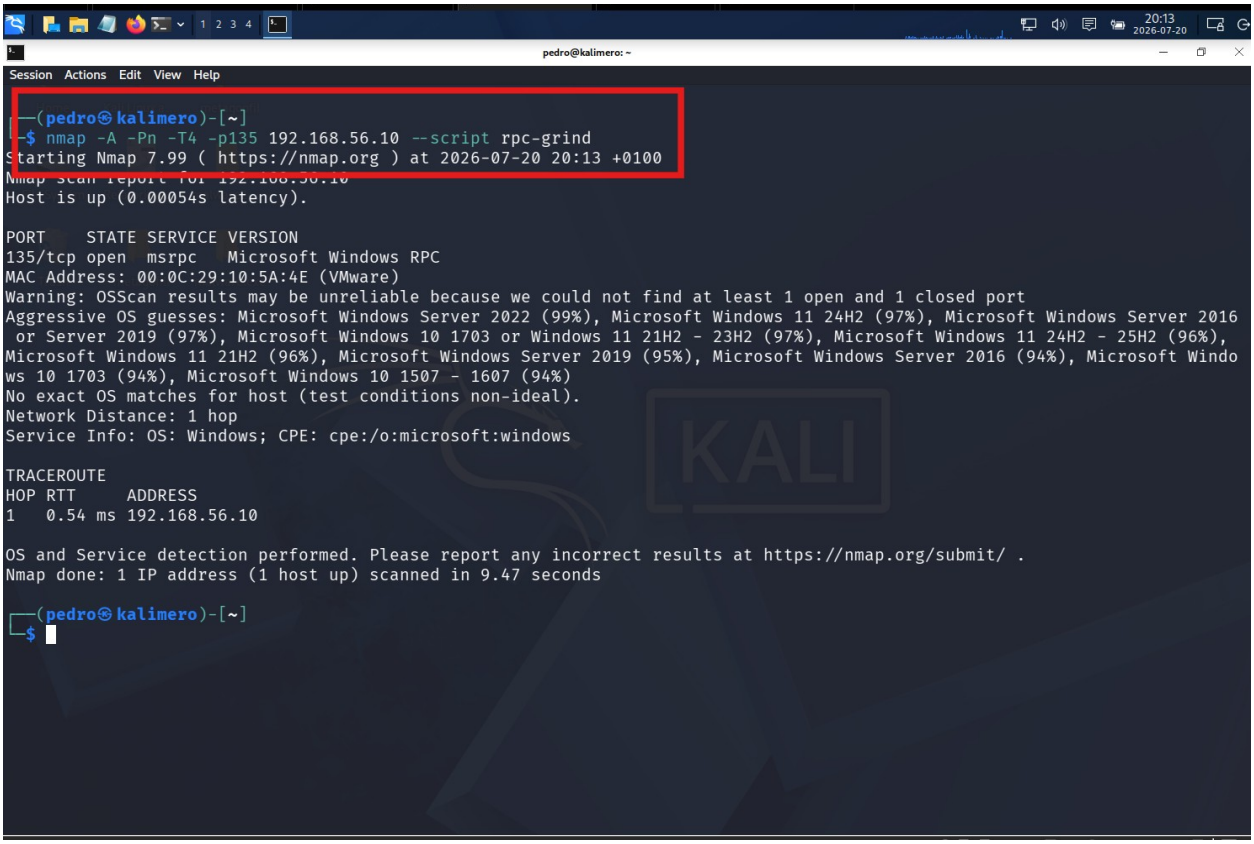
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 21:03 +0100
Nmap scan report for 192.168.56.20
Host is up (0.00034s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:04:C9:6A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.69 seconds
```

8. RPC (se porta 135 estiver aberta no WIN Server)

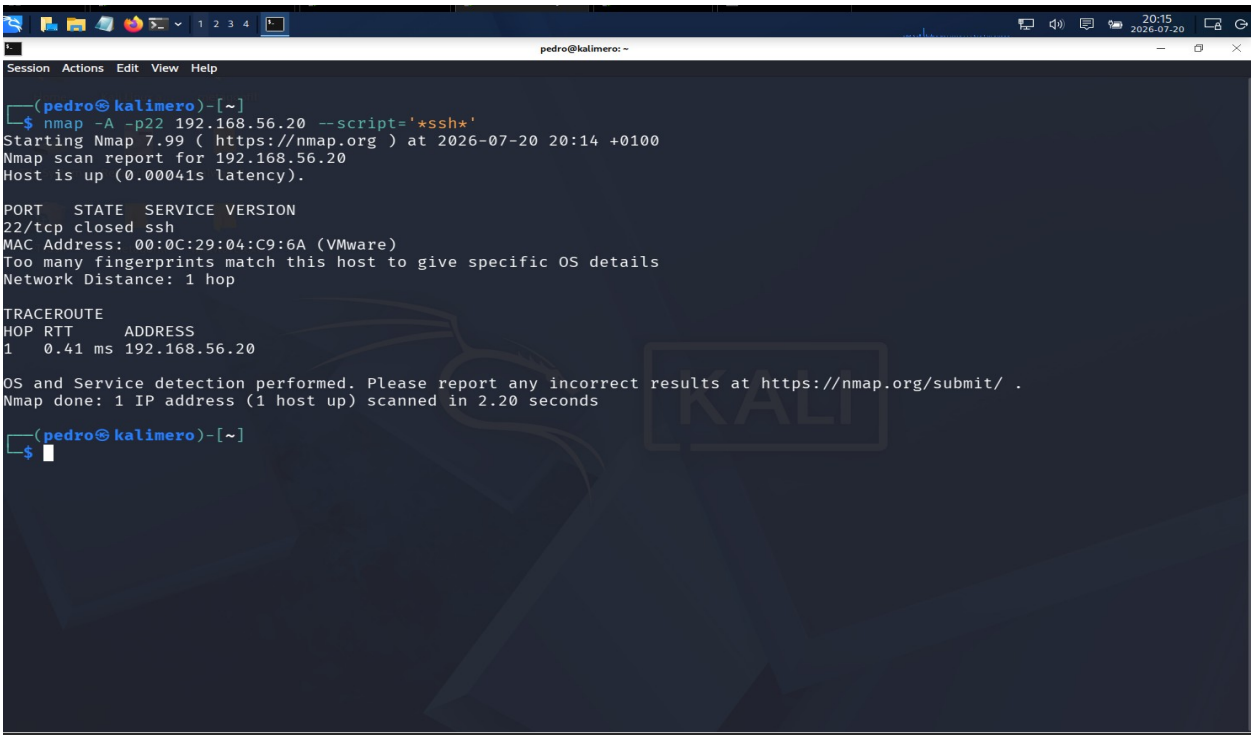
nmap -A -Pn -T5 -p- --script rpc-grind 192.168.56.10



9. SSH (caso o Kali tenha de aceder a algum serviço SSH exposto, incomum em Windows mas possível com WSL/OpenSSH ativado)

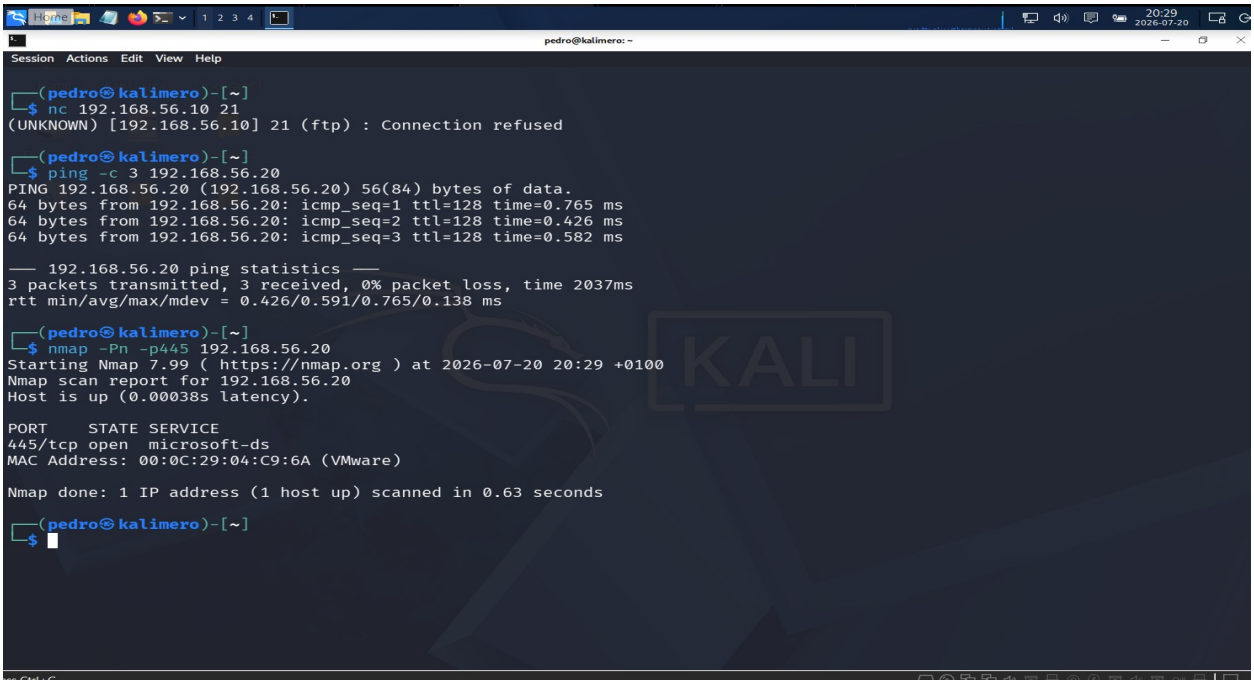
nmap -A -p22 192.168.56.20 --script='*ssh*'

ssh 192.168.56.20

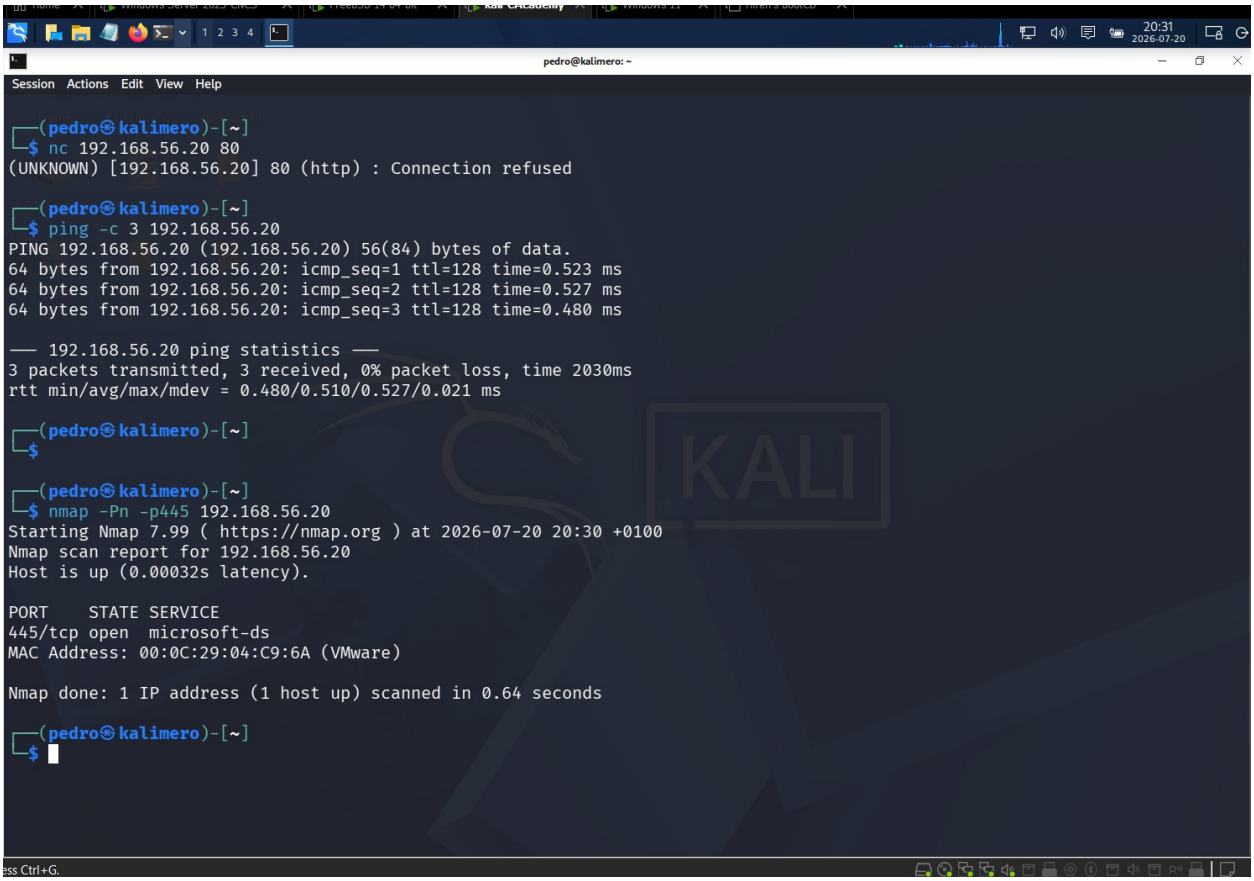


10. Testes protocolares manuais (FTP/HTTP, se detetados no scan)

nc 192.168.56.10 21



nc 192.168.56.20 80



CONFIDENCIAL

Relatório de Informação

Footprinting / Reconhecimento Passivo

Relatório para apresentação de resultados

Campo	Informação
Cliente	Interno / Formação — Laboratório de Testes de Intrusão (Módulo 5, Nível E, Ficha 3)
Domínio analisado	N/A — não foi analisado um domínio público. Âmbito real: rede sem fios local (ESSID "raaj") e rede interna de laboratório 192.168.56.0/24, incluindo os hosts Windows Server 192.168.56.10 e Windows 10/11 192.168.56.20, atacados a partir do posto Kali 192.168.56.100
Data da recolha	da no documento de origem
Preparado por	
Classificação	
Versão	1.0
N/Referência	Lab_Modulo5_NivelE_Ficha3.00001.v1
V/Referência	xxxxxxxxxxx

Nota de confidencialidade
Este documento contém informação sensível sobre a presença pública e a exposição digital da organização analisada. A sua distribuição deve ser limitada às pessoas autorizadas. Os dados apresentados são exemplificativos e devem ser substituídos pelos resultados reais do exercício.

Índice

Nota: a numeração de páginas desta secção segue a paginação global do documento. Consulte o Índice geral no início do ficheiro para a localização exacta de cada parte e anexo.

1. Apresentação, Objecto e Metodologia

O presente Relatório tem como objectivo apresentar os resultados da fase de footprinting realizada sobre activos públicos associados à Empresa Exemplo, Lda. Esta fase procura identificar informação disponível publicamente que possa ajudar a compreender a exposição digital da organização.

O exercício foi realizado numa perspectiva de reconhecimento passivo e de baixa intrusão, sem exploração activa de vulnerabilidades, sem tentativas de autenticação e sem impacto operacional nos sistemas analisados.

Elemento	Descrição
Objectivo	Documentar as técnicas e os resultados obtidos num exercício de testes de intrusão em redes sem fios (Airgeddon) e de reconhecimento/enumeração de rede interna (Nmap, SMB, sniffing), realizado em ambiente de laboratório.
Âmbito	Rede sem fios local com ESSID "raaj" (interfaces virtuais wlan0/wlan1/wlan2, modo Monitor via wlan0mon) e rede interna de laboratório 192.168.56.0/24, incluindo o host Windows Server 192.168.56.10 e o host Windows 10/11 192.168.56.20, testados a partir do posto de ataque Kali 192.168.56.100.
Fora do âmbito	Sistemas de produção reais, redes de terceiros e activos fora do ambiente de laboratório. Nota: ao contrário de um footprinting passivo clássico, este exercício incluiu ataques activos (desautenticação, quebra de chave WPA/WPA2, PMKID, Evil Twin) e scanning activo de portas, pelo que não se tratou de reconhecimento exclusivamente passivo.
Metodologia	Airgeddon para captura de handshakes WPA/WPA2 e PMKID, ataques de desautenticação e Evil Twin com portal cativo; Netdiscover, Arp-scan e Nmap para descoberta de hosts; Nmap, Unicornscan, Masscan e Hping3 para scanning de portas; enumeração SMB/RPC (smbmap, smbclient, scripts Nmap); sniffing de tráfego com tcpdump/Wireshark.
Limitação	Os resultados representam uma fotografia obtida em ambiente de laboratório controlado; não reflectem necessariamente a exposição de sistemas em produção.

2. Quadro Recapitulativo de Informação

O quadro seguinte apresenta uma visão executiva da informação identificada durante o footprinting. A coluna "Evidência" indica onde está a prova ou detalhe técnico dentro dos anexos integrados no final do relatório.

Item	Informação identificada	Possível impacto	Medida recomendada	Criticidade	Estado	Evidência
20260716-1	Captura de handshake WPA/WPA2 do AP "raaj" após ataque de desautenticação (Airgeddon)	Possibilidade de quebra offline da chave Wi-Fi (dicionário, força bruta ou Hashcat)	Utilizar palavras-passe fortes e únicas, considerar WPA3 e monitorizar desautenticações anómalas	Alta	Explorado com sucesso	Anexo C
20260716-2	Captura de PMKID do AP alvo sem necessidade de cliente associado	Permite ataque offline à chave Wi-Fi sem forçar desautenticação de clientes	Desativar roaming assistido por PMKID quando suportado; reforçar a password Wi-Fi	Alta	Explorado com sucesso	Anexo C
20260716-3	Ataque Evil Twin com portal cativo (AP falso, DHCP/DNS fraudulentos) para captura de credenciais Wi-Fi	Recolha de credenciais de utilizadores legítimos por engano	Sensibilização de utilizadores, deteção de APs não autorizados (WIDS/WIPS), 802.1X/EAP	Alta	Explorado com sucesso	Anexo C
20260716-4	Portas e serviços expostos nos hosts 192.168.56.10 (SMB 445, RPC 135/139, FTP 21) e 192.168.56.20 (SMB 445, RDP 3389, SSH 22, HTTP 80), entre outros, identificados via Nmap/Masscan/Hping3	Potencial enumeração e exploração de serviços Windows expostos	Restringir a exposição de SMB/RPC na rede; aplicar firewall e segmentação	Alta	Identificado	Anexo C
20260716-5	Enumeração SMB (smbmap, smbclient, Nmap smb-enum-users, enum4linux, crackmapexec) no host 192.168.56.10, revelando utilizadores e partilhas via sessão anónima/nula (ex.: smbmap -u DoesNotExist); mesmo conjunto de testes repetido em 192.168.56.20	Divulgação de informação interna que facilita ataques subsequentes	Desativar sessões nulas/anónimas, reforçar políticas de partilha e autenticação SMB	Média	Identificado	Anexo C
20260716-6	Divulgação da versão do SO (build 10.0.26100) e confirmação de que a assinatura SMB não é obrigatória no host 192.168.56.10, via módulo Metasploit smb_version	Facilita ataques de relay SMB (NTLM relay) e seleção de exploits específicos para o SO identificado	Tornar a assinatura SMB obrigatória e restringir a divulgação de versões/banners de serviço	Média	Identificado	Anexo C

Item	Informação identificada	Possível impacto	Medida recomendada	Criticidade	Estado	Evidência
20260716-7	Tentativa de ligação RDP ao host 192.168.56.20 com utilizador "Administrator" e palavra-passe em branco (xfreerdp3); testes manuais adicionais aos serviços FTP (192.168.56.10) e HTTP (192.168.56.20). Resultados das tentativas não documentados no texto de origem.	Caso as credenciais por defeito ou os serviços não estejam devidamente protegidos, permite acesso remoto não autorizado	Restringir RDP a redes de confiança, aplicar MFA, eliminar contas com palavra-passe em branco e validar a exposição de FTP/HTTP	Alta	Testado (sem confirmação)	Anexo C

Nota: Item – YYYMMDD-Seq++ = ex: 20260708-1; 20260708-2; 20260708-3; ....

3. Recomendações Adicionais

Para além das medidas específicas indicadas no quadro recapitulativo, recomenda-se a adopção das seguintes acções de melhoria:

- Criar um inventário actualizado de domínios, subdomínios, IPs públicos e serviços expostos.
- Definir responsáveis pela gestão de DNS, certificados digitais e configurações de email.
- Implementar revisão periódica da exposição pública, pelo menos trimestralmente.
- Garantir que ambientes de desenvolvimento, staging ou administração não estão expostos sem necessidade.
- Formalizar um procedimento de limpeza de metadados antes da publicação de documentos externos.
- Avaliar a execução de uma fase posterior de análise de vulnerabilidades ou pentest autorizado sobre os activos em risco.

Prioridade	Acção sugerida	Prazo recomendado
Alta	Reforçar a segurança da rede Wi-Fi (password forte, considerar WPA3, monitorização de desautenticações).	Até 15 dias
Alta	Restringir e segmentar o acesso aos serviços SMB/RPC expostos nos hosts 192.168.56.10 e 192.168.56.20, e restringir o acesso RDP ao host 192.168.56.20.	Até 30 dias
Média	Implementar deteção de pontos de acesso não autorizados (rogue AP / Evil Twin).	Até 30 dias
Média	Desativar sessões SMB nulas/anónimas e rever as partilhas de rede.	Até 45 dias

4. Entrega / Assinaturas

O presente Relatório é entregue ao cliente para análise interna e definição das acções correctivas consideradas adequadas. A aceitação deste documento não substitui uma validação técnica posterior das medidas implementadas.

[redacted]ade	[redacted]	Função	Data	Assinatura
		Responsável pelo Relatório	08/07/2026	
Cliente	[Nome do responsável]	[Função]	__/__/____	

5. Anexos integrados no relatório

Os anexos seguintes estão integrados no próprio documento. Isto significa que não são ficheiros separados: encontram-se nas páginas seguintes e contêm as evidências que suportam o quadro recapitulativo da secção 2.

Anexo	Conteúdo	Localização
Anexo A	Não aplicável neste exercício — sem domínio/DNS público analisado (ver Anexo A)	Integrado neste documento
Anexo B	Não aplicável neste exercício — sem email/SPF/DKIM/DMARC analisado (ver Anexo B)	Integrado neste documento
Anexo C	IPs, portas, serviços e ataques identificados na rede Wi-Fi e na rede interna	Integrado neste documento
Anexo D	Não aplicável neste exercício — sem OSINT documental/metadados analisado (ver Anexo D)	Integrado neste documento
Anexo E	Evidências adicionais, notas e capturas complementares (ver Anexo E)	Integrado neste documento

Anexo A - Domínios, DNS e subdomínios

Este anexo contém exemplos de registos e subdomínios identificados durante a recolha. Em ambiente real, esta tabela deve ser preenchida com os resultados efectivos obtidos nas fontes consultadas.

Tipo	Valor identificado	Observação
Rede sem fios (ESSID)	raaj	Rede Wi-Fi alvo identificada e utilizada para os ataques de captura de handshake/PMKID/Evil Twin (não constitui domínio DNS público).
Endereço MAC (BSSID, exemplo)	02:00:00:00:01:00	Endereço MAC de referência observado no nome do ficheiro de saída do Aircrack.
Rede interna	192.168.56.0/24	Sub-rede de laboratório (host-only) onde se encontra o Windows Server alvo.
Host alvo	192.168.56.10 e 192.168.56.20	Windows Server (.10) e host Windows 10/11 (.20) utilizados como alvo de scanning e enumeração de rede.
N/A	N/A	Não aplicável — não foi analisado domínio/DNS público neste exercício (âmbito: Wi-Fi e rede interna de laboratório).
N/A	N/A	Não aplicável — idem.

Anexo B - Email, SPF, DKIM, DMARC e MX

Este anexo apresenta a validação exemplificativa dos mecanismos de protecção de email associados ao domínio.

Controlo	Resultado exemplificativo	Interpretação
SPF	Não aplicável	Não foi realizada análise de email/SPF/DKIM/DMARC neste exercício (âmbito: Wi-Fi e rede interna de laboratório).
DKIM	Não aplicável	Não foi realizada análise de email/SPF/DKIM/DMARC neste exercício (âmbito: Wi-Fi e rede interna de laboratório).
DMARC	Não aplicável	Não foi realizada análise de email/SPF/DKIM/DMARC neste exercício (âmbito: Wi-Fi e rede interna de laboratório).
MX	Não aplicável	Não foi realizada análise de email/SPF/DKIM/DMARC neste exercício (âmbito: Wi-Fi e rede interna de laboratório).

Anexo C - IPs, portas, serviços e tecnologias

Este anexo reúne informação pública sobre serviços e tecnologias detectadas. A existência de uma porta aberta não significa, por si só, vulnerabilidade; indica apenas exposição que deve ser validada.

Activo	Porta	Serviço/tecnologia	Observação
192.168.56.10	445/tcp	SMB (Microsoft-DS)	Identificado via Nmap/smbmap/smbclient; permitiu enumeração de utilizadores e partilhas (ex.: smbmap -u DoesNotExist).
192.168.56.10	135, 139/tcp	RPC / NetBIOS	Testado com nmap --script rpc-grind e scripts smb; relevante em ambiente Windows Server.
192.168.56.10	53,67,68,123,137,138,161/udp	DNS/DHCP/NTP/NetBIOS/SNMP	Varrimento UDP com nmap -sU para portas comuns.
192.168.56.10	1-65535/tcp (todas)	Descoberta completa de portas	Scan completo com nmap -p-, masscan --rate=1000 e hping3 -S -p 445.
192.168.56.20	445/tcp	SMB (Microsoft-DS)	Identificado via Nmap; mesmo conjunto de testes SMB (smbmap, smbclient, smb-enum-users) aplicado ao Windows Server.
192.168.56.20	3389/tcp	RDP	Ligação testada com xfreerdp3 (utilizador Administrator, sem palavra-passe) e módulo Metasploit rdp_scanner; resultado da tentativa não documentado no texto de origem.
192.168.56.20	22/tcp	SSH	Testado com nmap --script "*ssh*" e cliente ssh; serviço incomum em Windows (possível via WSL/OpenSSH), presença não confirmada no texto de origem.
192.168.56.10	21/tcp	FTP	Testado manualmente com nc; resultado não documentado no texto de origem.
192.168.56.20	80/tcp	HTTP	Testado manualmente com nc; resultado não documentado no texto de origem.
AP Wi-Fi "raaj"	N/A (802.11)	WPA/WPA2	Handshake e PMKID capturados via Airgeddon/Aircrack; posteriormente alvo de ataque Evil Twin com portal cativo.

Anexo D - OSINT, documentos e metadados

Este anexo documenta exemplos de informação pública potencialmente útil para reconhecimento. Em contexto real, devem ser incluídas apenas evidências relevantes e autorizadas.

Fonte/ficheiro	Informação observada	Risco potencial	Recomendação
brochura-comercial.pdf	Não aplicável	Não aplicável	Não foi realizada recolha de OSINT documental/metadados neste exercício (âmbito: Wi-Fi e rede interna de laboratório).
apresentacao-servicos.pptx	Não aplicável	Não aplicável	Não foi realizada recolha de OSINT documental/metadados neste exercício (âmbito: Wi-Fi e rede interna de laboratório).
motor de pesquisa	Não aplicável	Não aplicável	Não foi realizada recolha de OSINT documental/metadados neste exercício (âmbito: Wi-Fi e rede interna de laboratório).

Fonte/ficheiro	Informação observada	Risco potencial	Recomendação
LinkedIn / fontes públicas	Não aplicável	Não aplicável	Não foi realizada recolha de OSINT documental/metadados neste exercício (âmbito: Wi-Fi e rede interna de laboratório).

Anexo E - Evidências adicionais

Espaço reservado para capturas de ecrã, outputs de ferramentas, notas de validação ou outras evidências complementares. Em relatórios reais, cada evidência deve incluir data, fonte e breve explicação.

ID	Descrição da evidência	Fonte	Data
E-01	Captura de ecrã do handshake WPA capturado (AP "raaj")	Airgeddon / Aircrack (laboratório)	N/D
E-02	Captura de ecrã do PMKID capturado com sucesso	Airgeddon (laboratório)	N/D
E-03	Outputs de Nmap / SMB (scans de portas e enumeração SMB) no host 192.168.56.10 e 192.168.56.20	Nmap / smbmap / smbclient (laboratório)	N/D
E-04	Outputs de Metasploit (smb_version, rdp_scanner), crackmapexec e enum4linux nos hosts 192.168.56.10 e 192.168.56.20; testes manuais adicionais a RDP, SSH, FTP e HTTP	Metasploit / CrackMapExec / enum4linux / xfreerdp3 / nc (laboratório)	N/D

6. Anexos externos ao relatório

Os anexos seguintes são externos ao documento. Isto significa que são ficheiros separados e serão entregues de forma encriptada utilizando o canal ou meio ***portal de partilha seguro com transferência cifrada (SFTP/HTTPS), acordado previamente com o cliente***.

Anexo	Conteúdo	Localização
Anexo E.1	Não aplicável neste exercício — sem domínio/DNS público analisado (ver Anexo A)	Pasta com o ficheiro ex: D:\ nome_do_relatorio\Anexos\E.1
Anexo E.2	Não aplicável neste exercício — sem email/SPF/DKIM/DMARC analisado (ver Anexo B)	Nome do ficheiro
Anexo E.3	IPs, portas, serviços e ataques identificados na rede Wi-Fi e na rede interna	Nome do ficheiro
Anexo E.4	Não aplicável neste exercício — sem OSINT documental/metadados analisado (ver Anexo D)	Nome do ficheiro
Anexo E.5	Evidências adicionais, notas e capturas complementares (ver Anexo E)	Nome do ficheiro

Anexo E.1 - Domínios, DNS e subdomínios

Este anexo contém exemplos de registos e subdomínios identificados durante a recolha. Em ambiente real, esta tabela deve ser preenchida com os resultados efectivos obtidos nas fontes consultadas.

Tipo	Valor identificado	Observação
Rede sem fios (ESSID)	raaj	Rede Wi-Fi alvo identificada e utilizada para os ataques de captura de handshake/PMKID/Evil Twin (não constitui domínio DNS público).
Endereço MAC (BSSID, exemplo)	02:00:00:00:01:00	Endereço MAC de referência observado no nome do ficheiro de saída do Aircrack.
Rede interna	192.168.56.0/24	Sub-rede de laboratório (host-only) onde se encontra o Windows Server alvo.
Host alvo	192.168.56.10 e 192.168.56.20	Windows Server (.10) e host Windows 10/11 (.20) utilizados como alvo de scanning e enumeração de rede.
N/A	N/A	Não aplicável — não foi analisado domínio/DNS público neste exercício (âmbito: Wi-Fi e rede interna de laboratório).

Tipo	Valor identificado	Observação
N/A	N/A	Não aplicável — idem.